

# CSE 331: Computer Security Fundamentals

Spring 2026

Hardware Security

Amir Rahmati  
Xinrui Yu



Stony Brook Institute  
at Anhui University

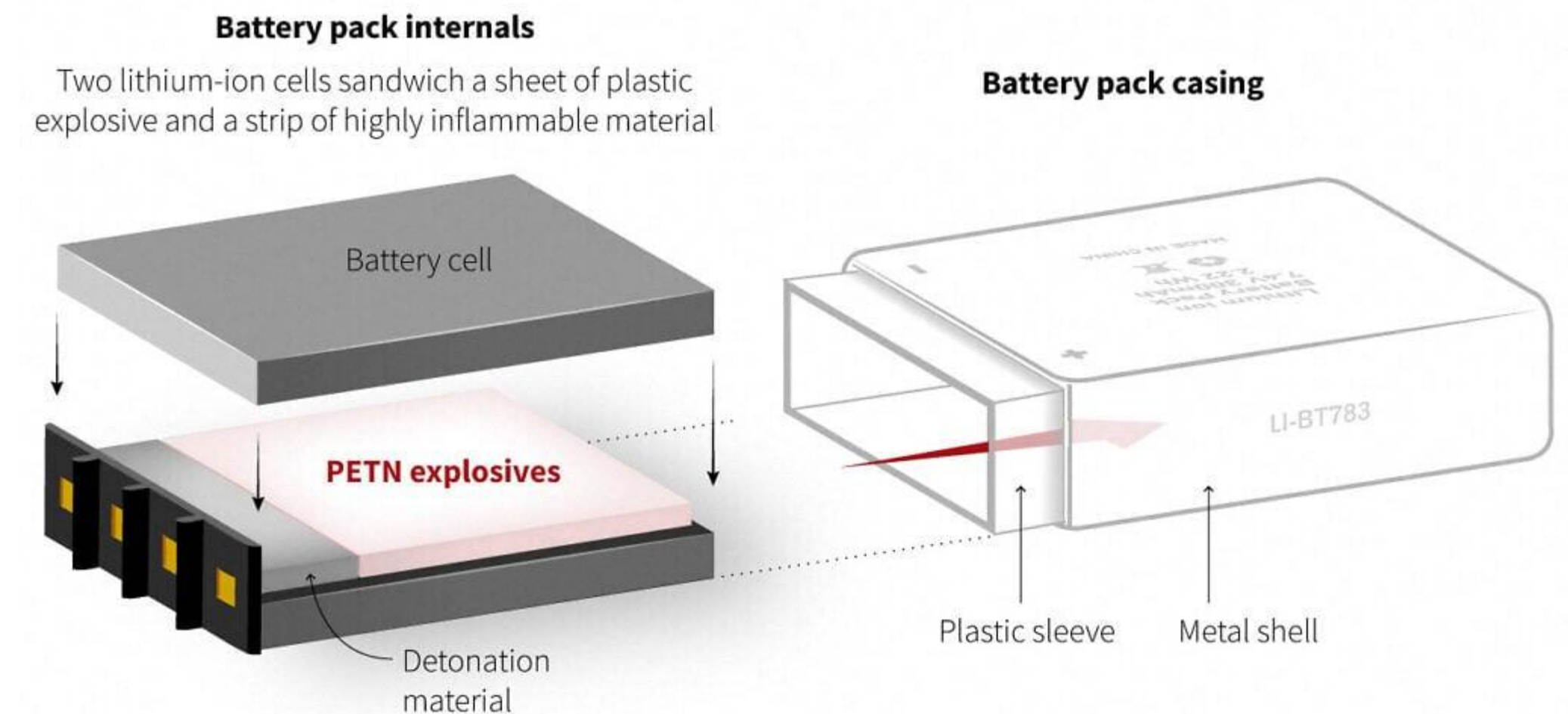
安徽大学纽约石溪学院

# Hardware Security

deceptive features. A thin, square sheet with six grams of white pentaerythritol tetranitrate (PETN) plastic explosive was squeezed between two rectangular battery cells, according to a Lebanese source and photos.

## Example: Lebanon pager attack (2024)

- Breaking Hardware Security
  - Direct physical tampering
  - Indirect supply chain tampering
- Mitigation
  - vs. supply chain attacks: User-verifiable hardware
  - vs. direct attacks: plausible deniability
  - vs. direct attacks: tamper-evident techniques



# Direct Physical Tampering

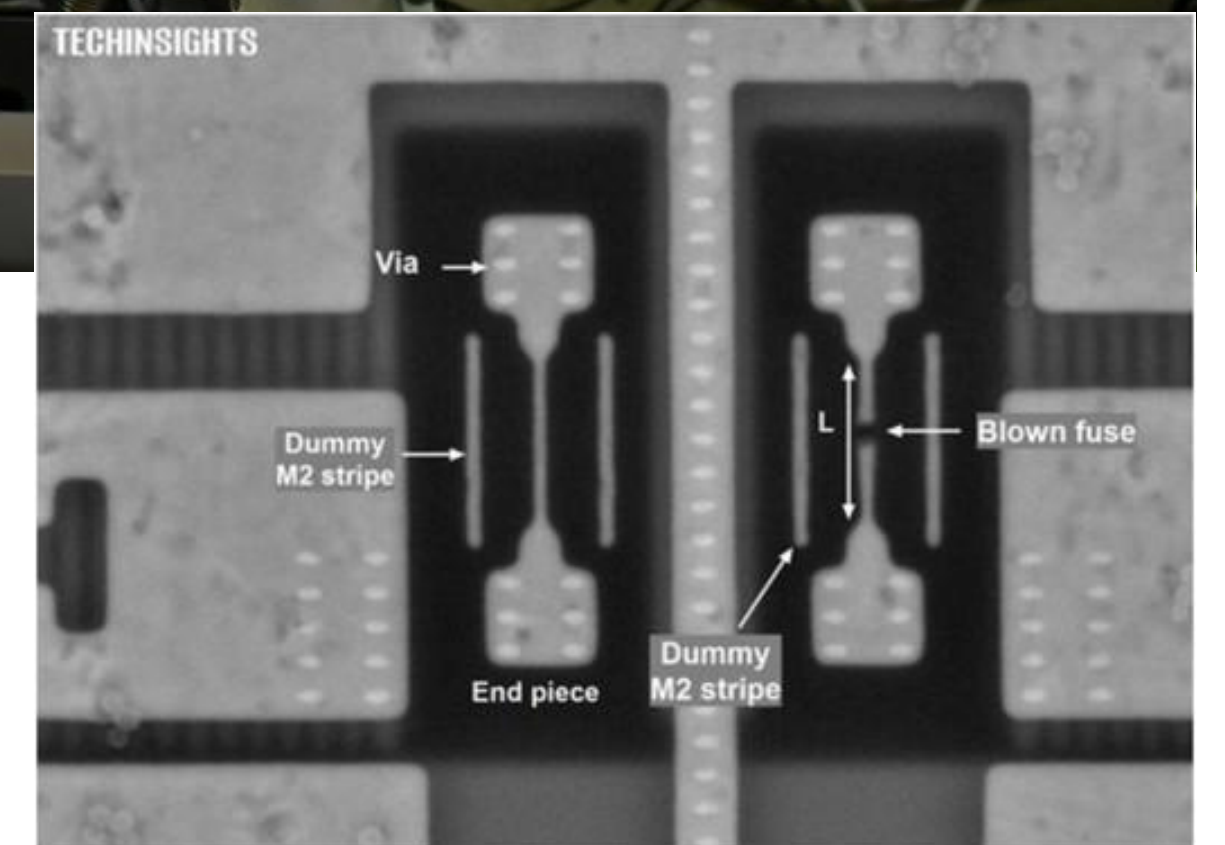
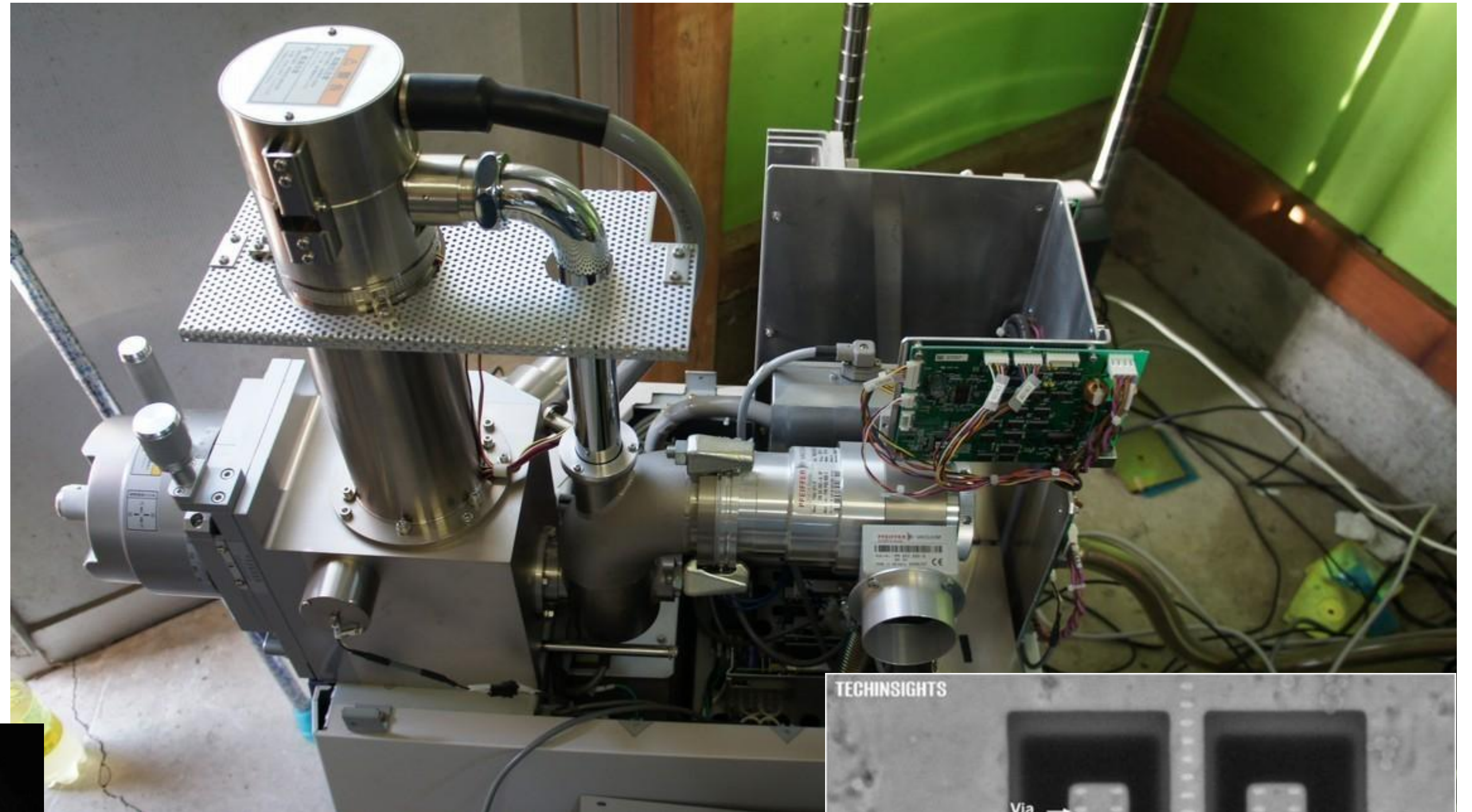
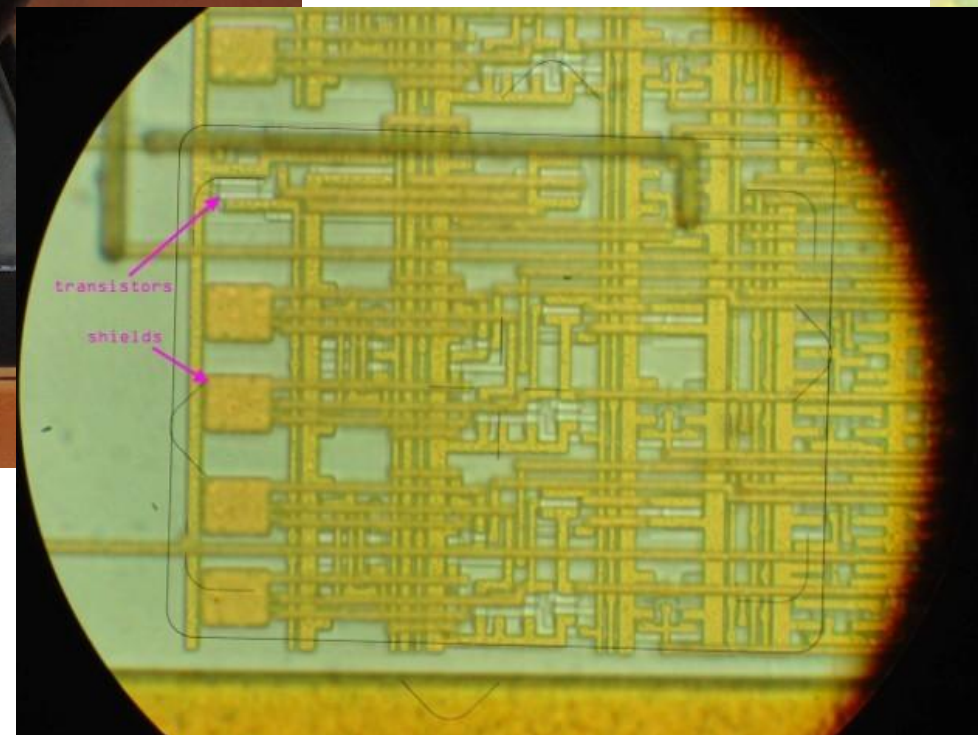
- Passive - little to no modification of target system
- Direct observation
  - Optical
    - SEM
    - Side-channel (emissions)
  - Power
    - RF
    - Optical
    - Active - no holds barred
- Fault induction
  - Glitching (clock/VDD)
    - Coupling (e.g. row hammer)
    - Photonic
    - FIB edit



# Passive: Direct Observation

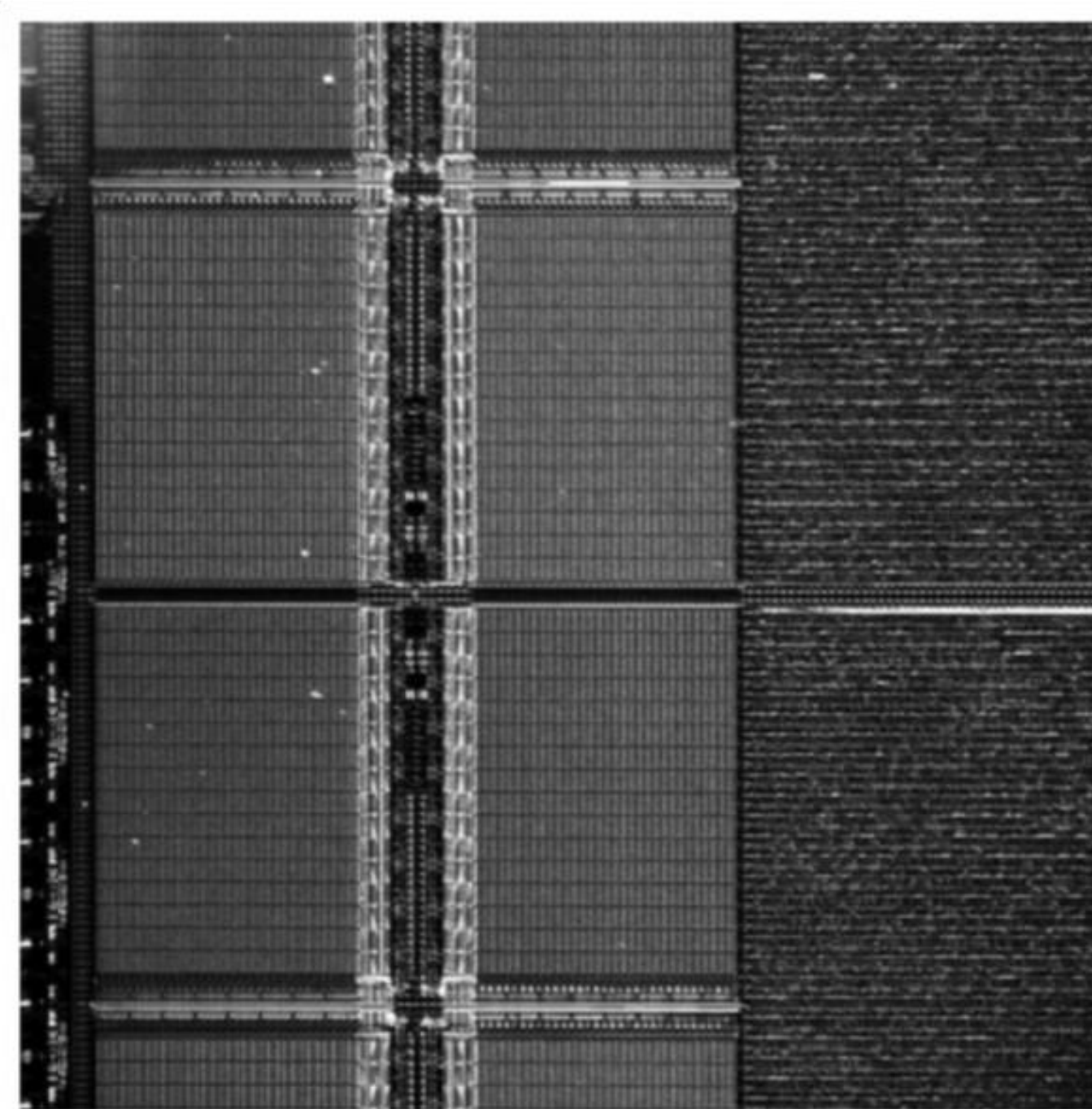
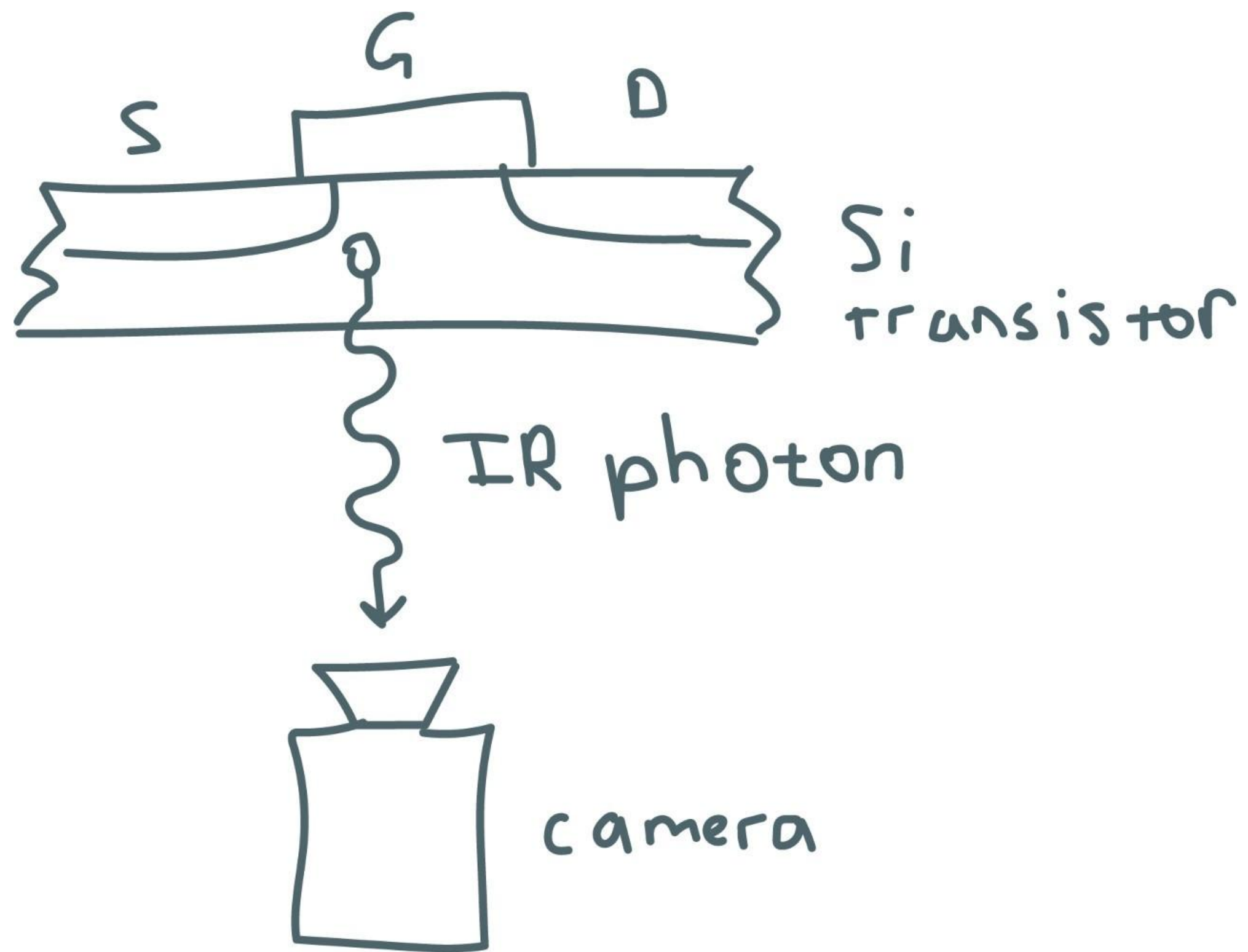


Acagasty - CC-BY-SA 4.0

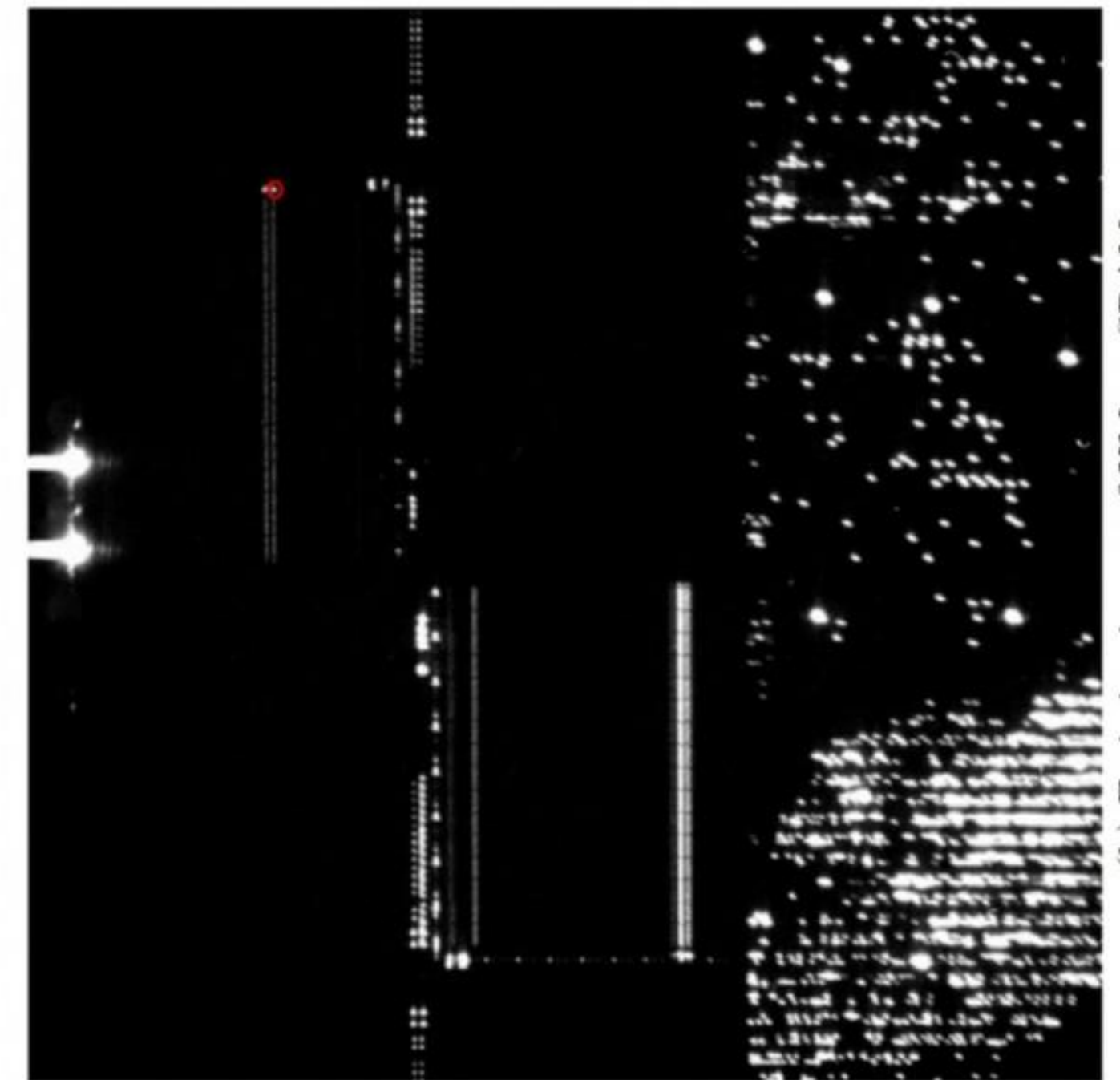




# Passive: Optical Emissions



(a) Reflective type image of X-Mega SRAM

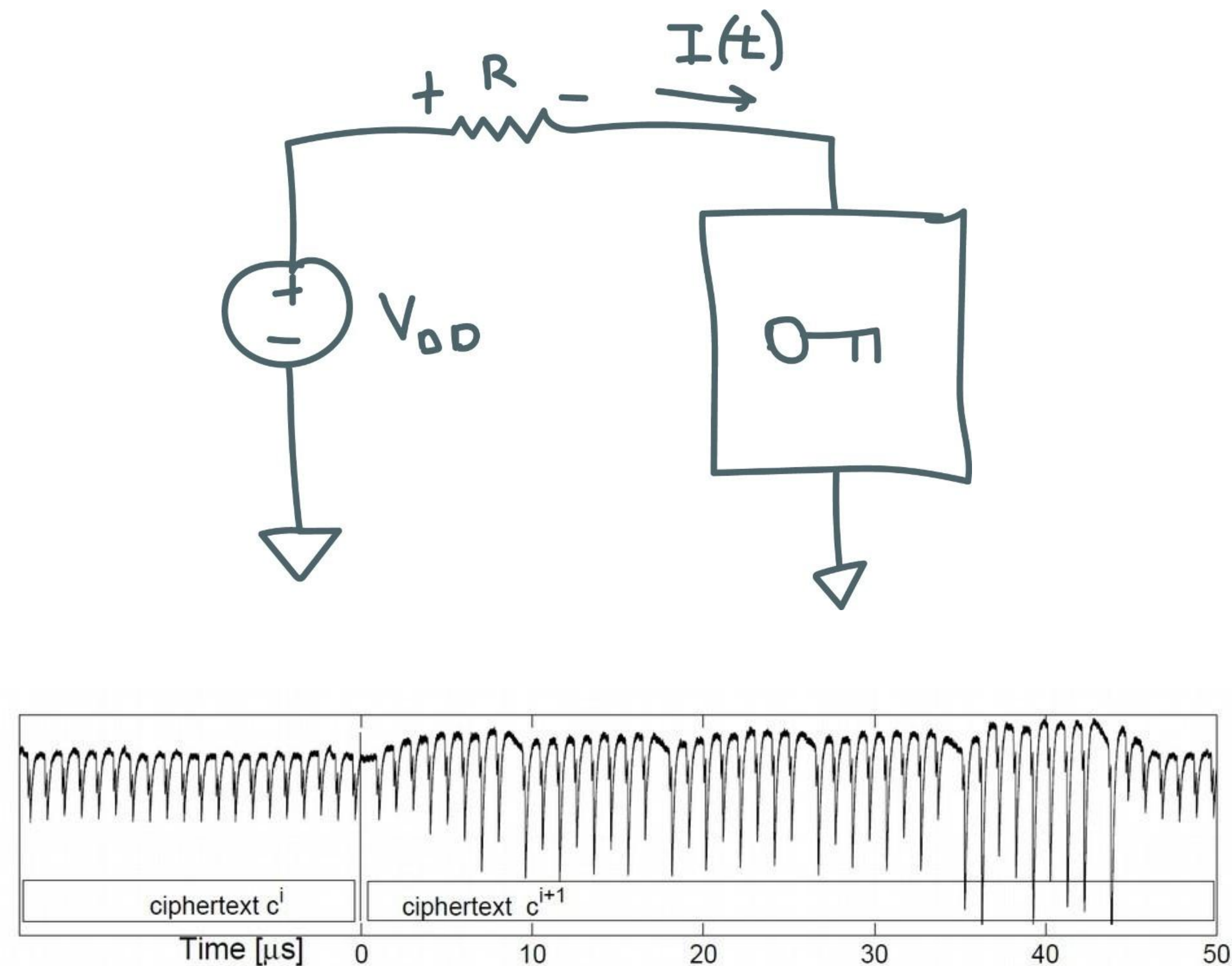


(b) Emission image of X-Mega SRAM

Schlosser, A., Nedospasov, D., Kramer J., Orlic, S., Seifert, JP. "Simple Photonic Emission Analysis of AES"



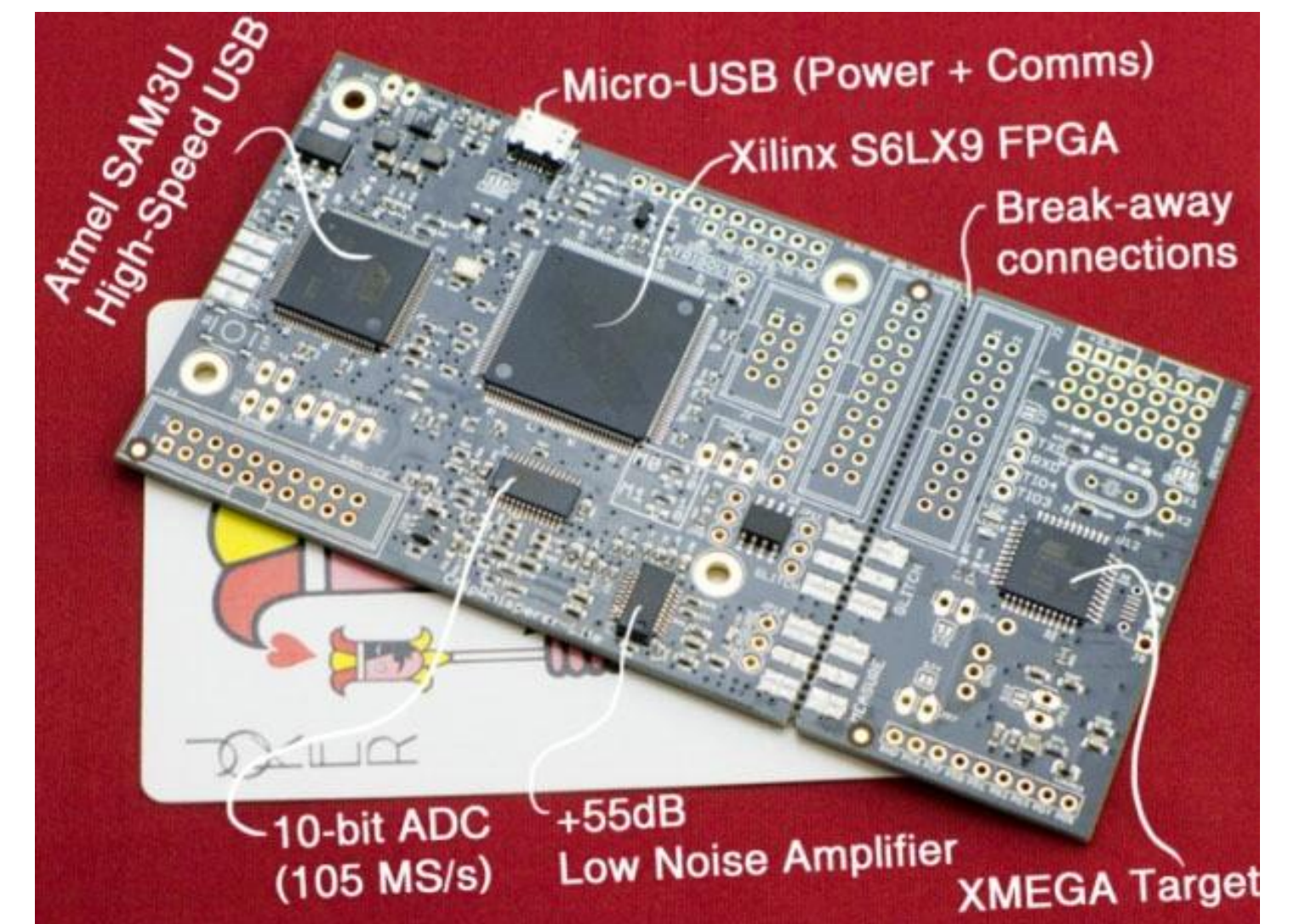
# Passive: Power Side-Channels



**Fig. 1.** A sample power trace of Spartan-6 (with 20MHz low-pass filter) during loading an encrypted bitstream

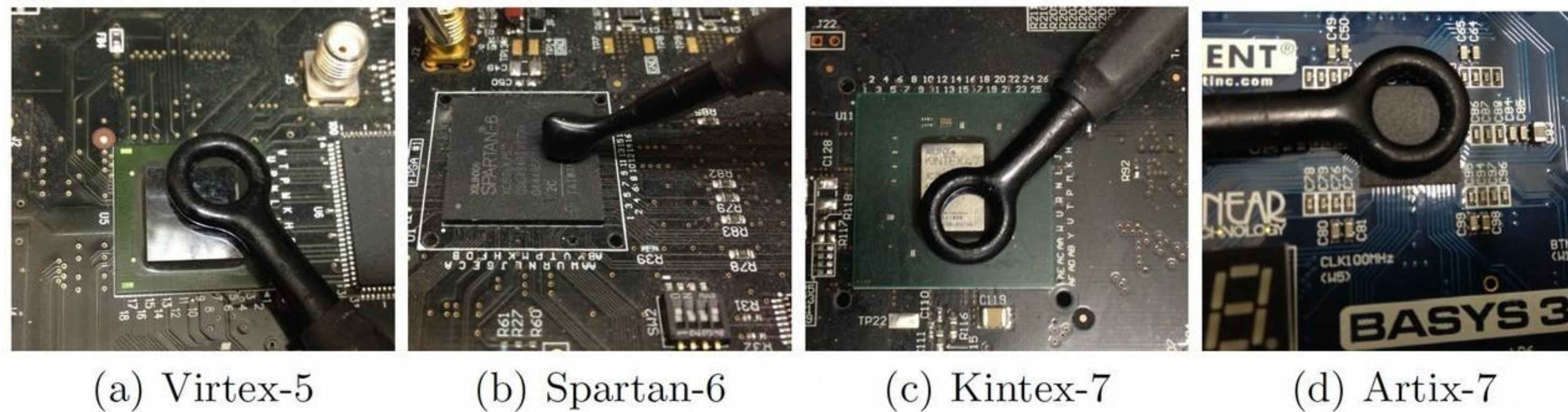
Moradi, A and Schneider, T. "Improved Side-Channel Analysis Attacks on Xilinx Bitstream Encryption of 5, 6, and 7 Series"

## ChipWhisperer-Lite (CW1173)





# Passive: RF Side-Channels

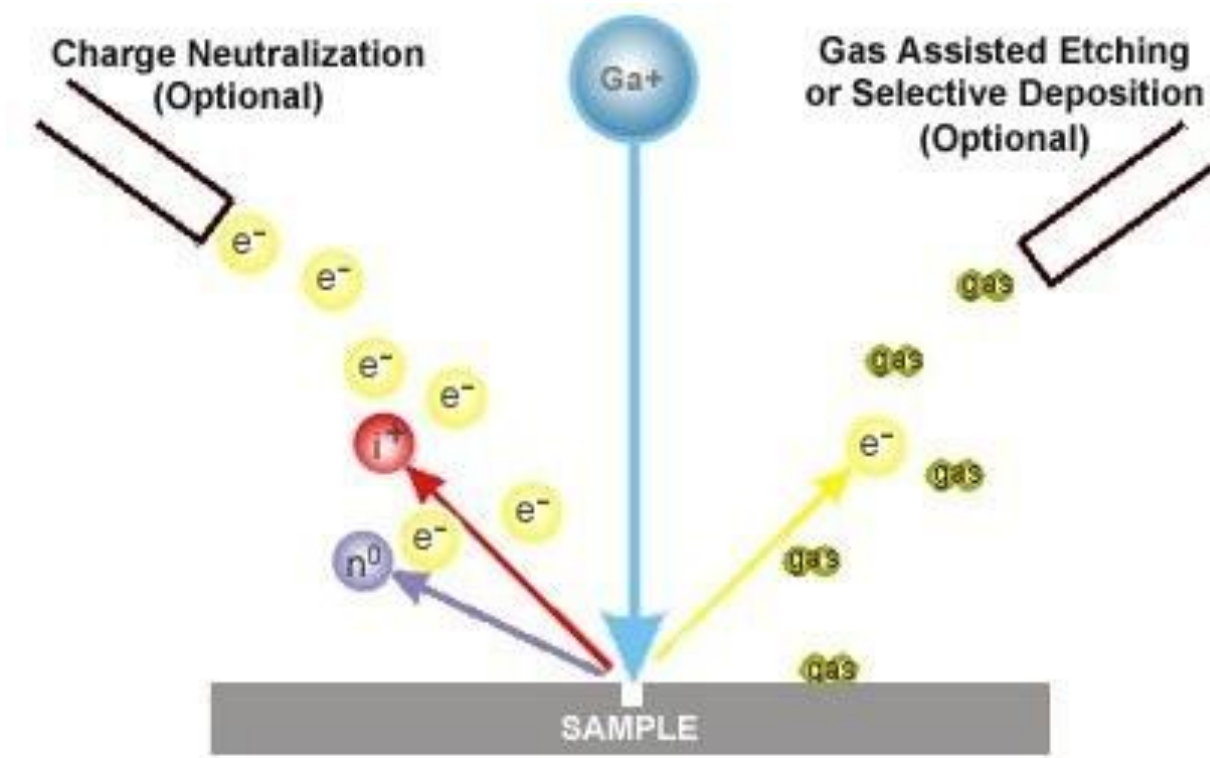


**Fig. 5.** EM probes and different FPGAs, (a) XC5VLX50-1FFG324, (b) XC6SLX75-2CSG484C, (c) XC7K160T-1FBGC, (d) XC7A35T-1CPG236C

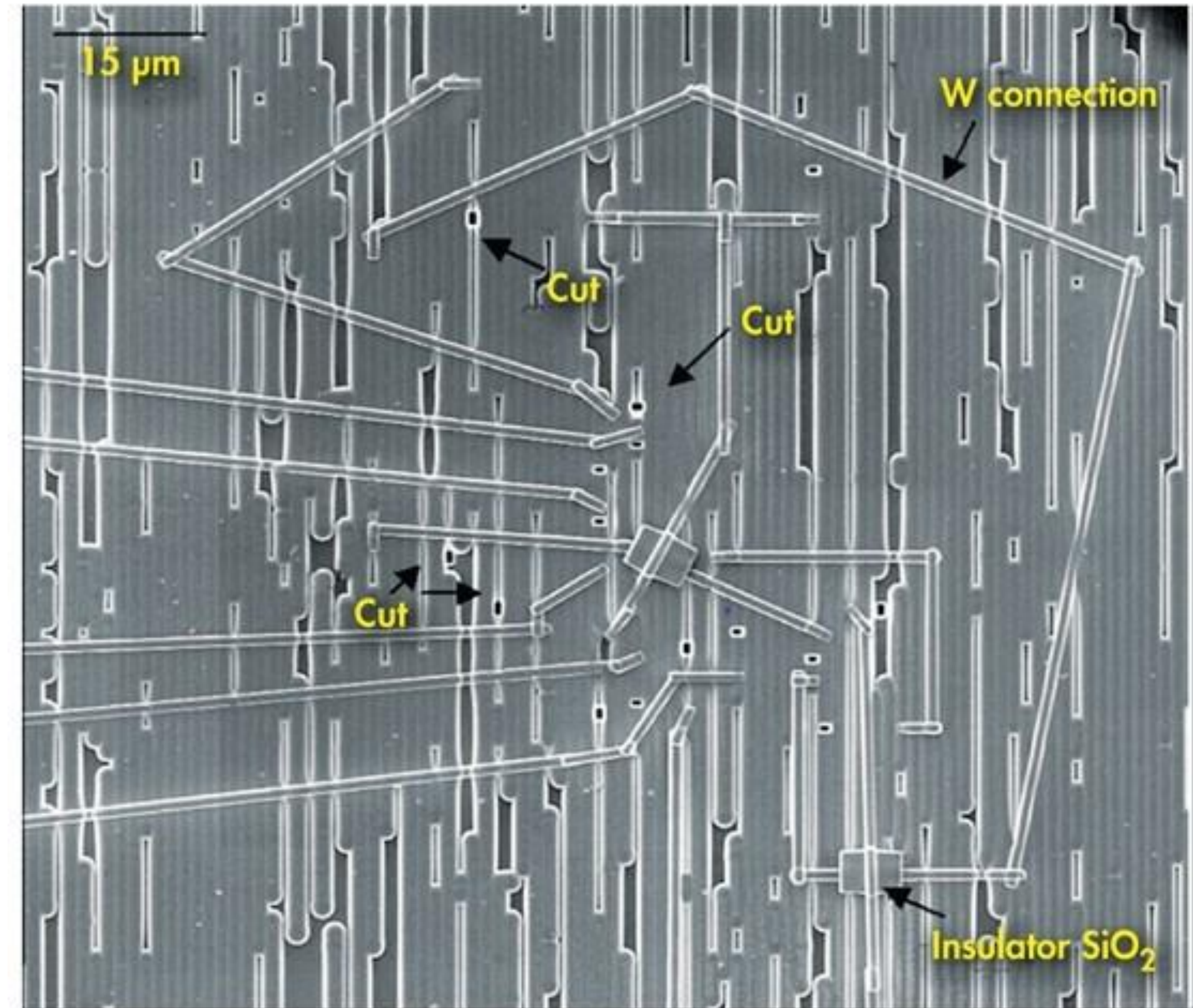
Moradi, A and Schneider, T. "Improved Side-Channel Analysis Attacks on Xilinx Bitstream Encryption of 5, 6, and 7 Series"



# Active: FIB



Kriegor27 - Public domain



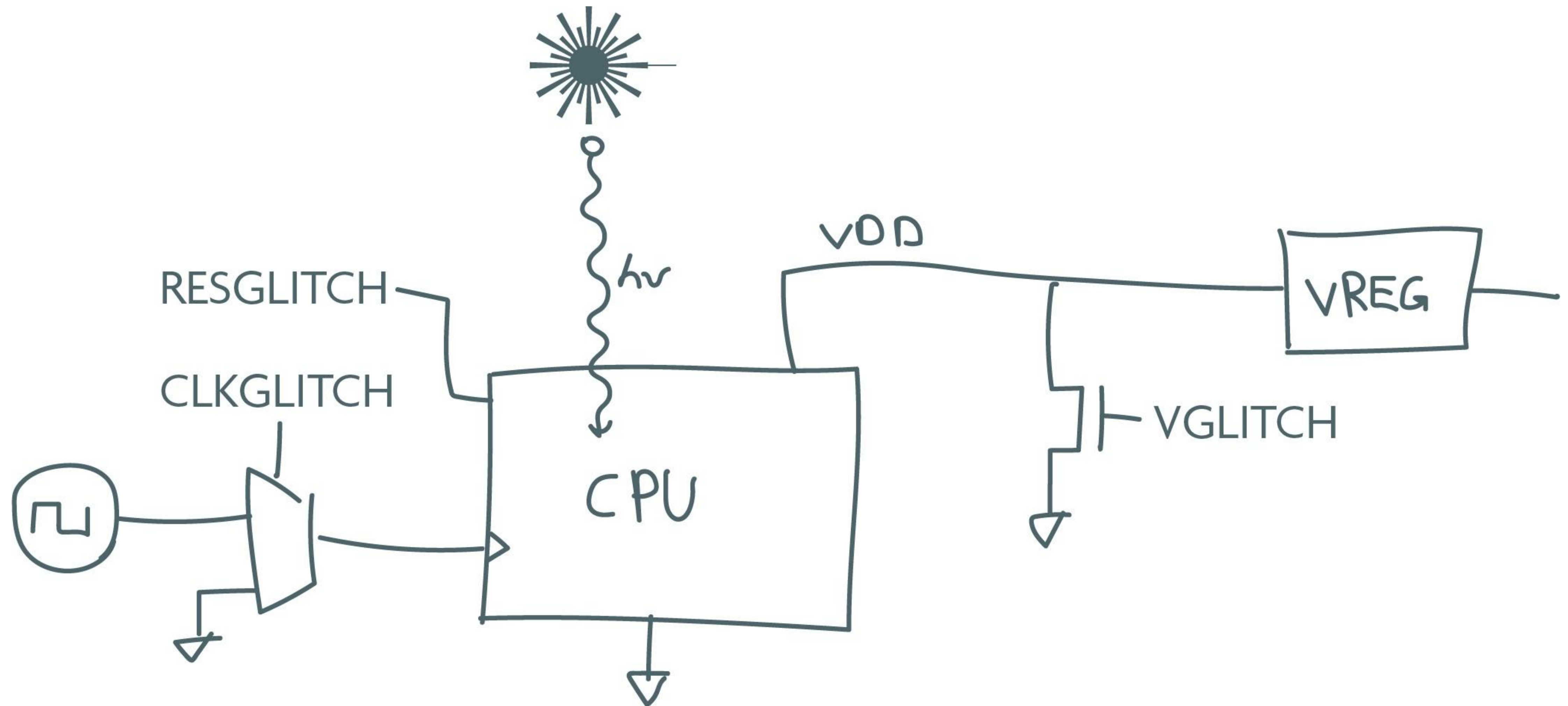
From <http://www.electronicdesign.com/eda/fib-circuit-edit-becomes-increasingly-valuable-advanced-node-design>



Cm the p, CC-BY-SA 3.0



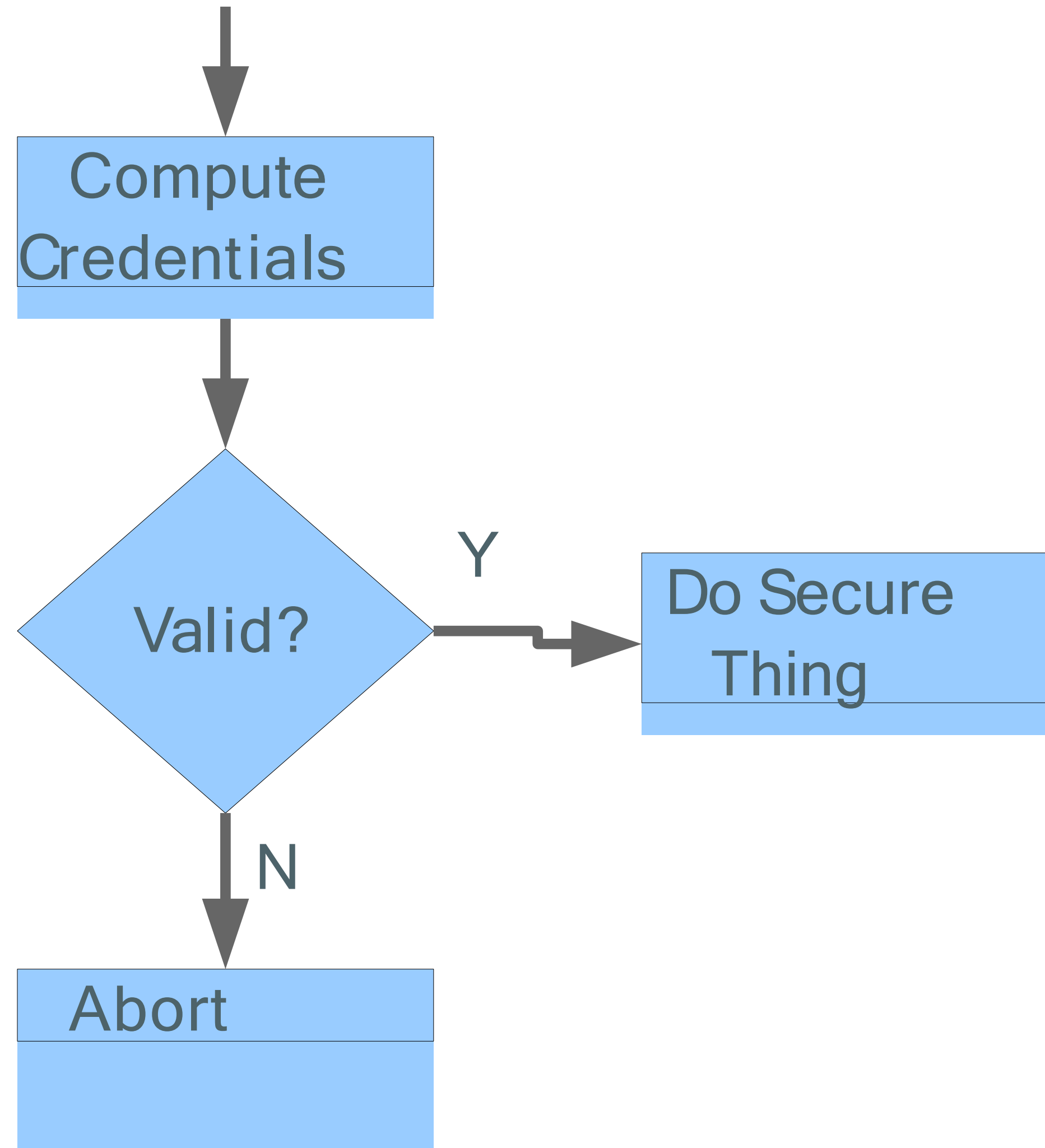
# Active: Fault Injection (Glitching, Optical)



Also available in remote attacks: See <https://plundervolt.com/doc/plundervolt.pdf>

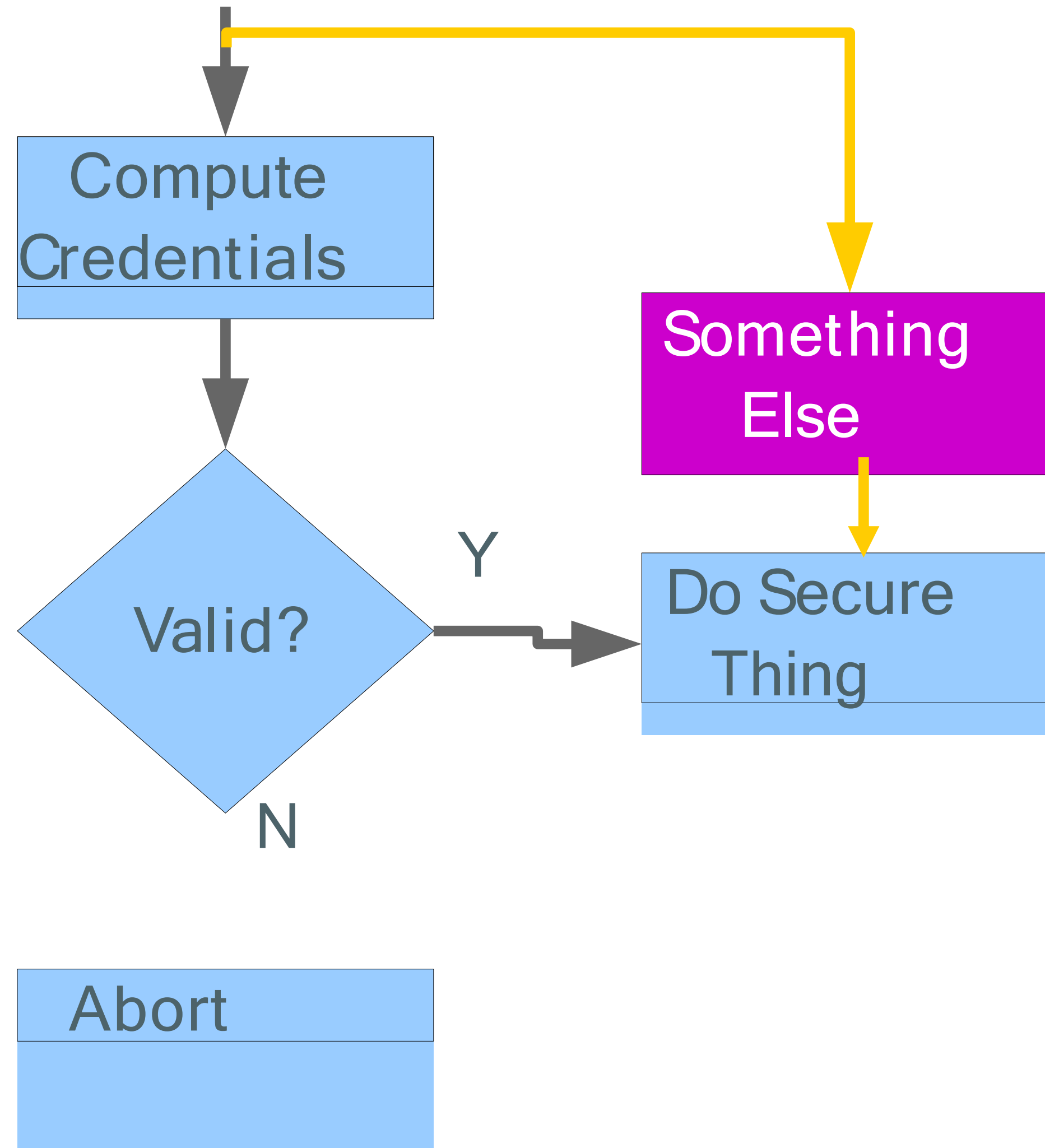


# Fault Injection: The General Idea



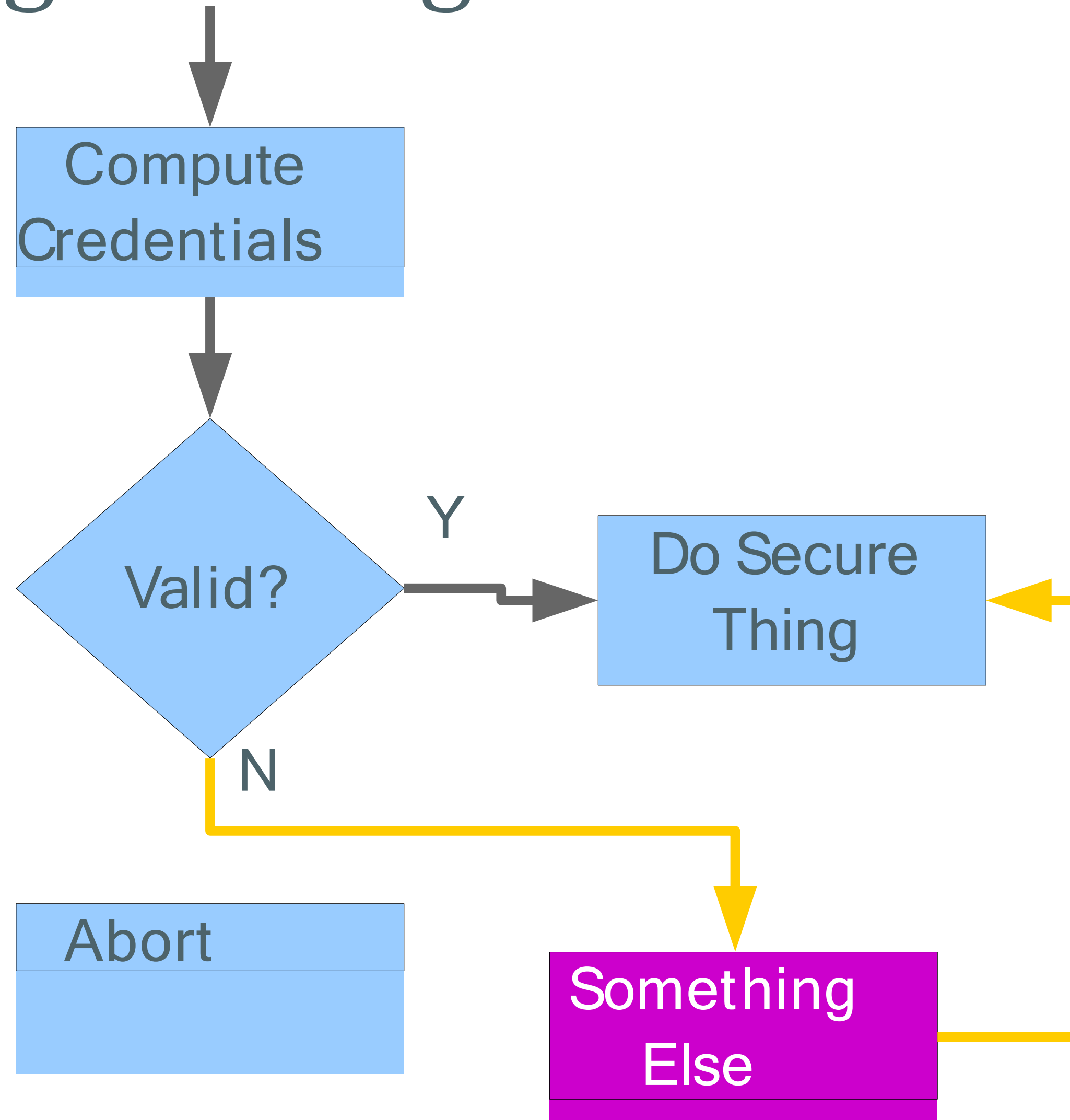


# Glitching To Run an Alternate Code Base





# Glitching to Change a Branch



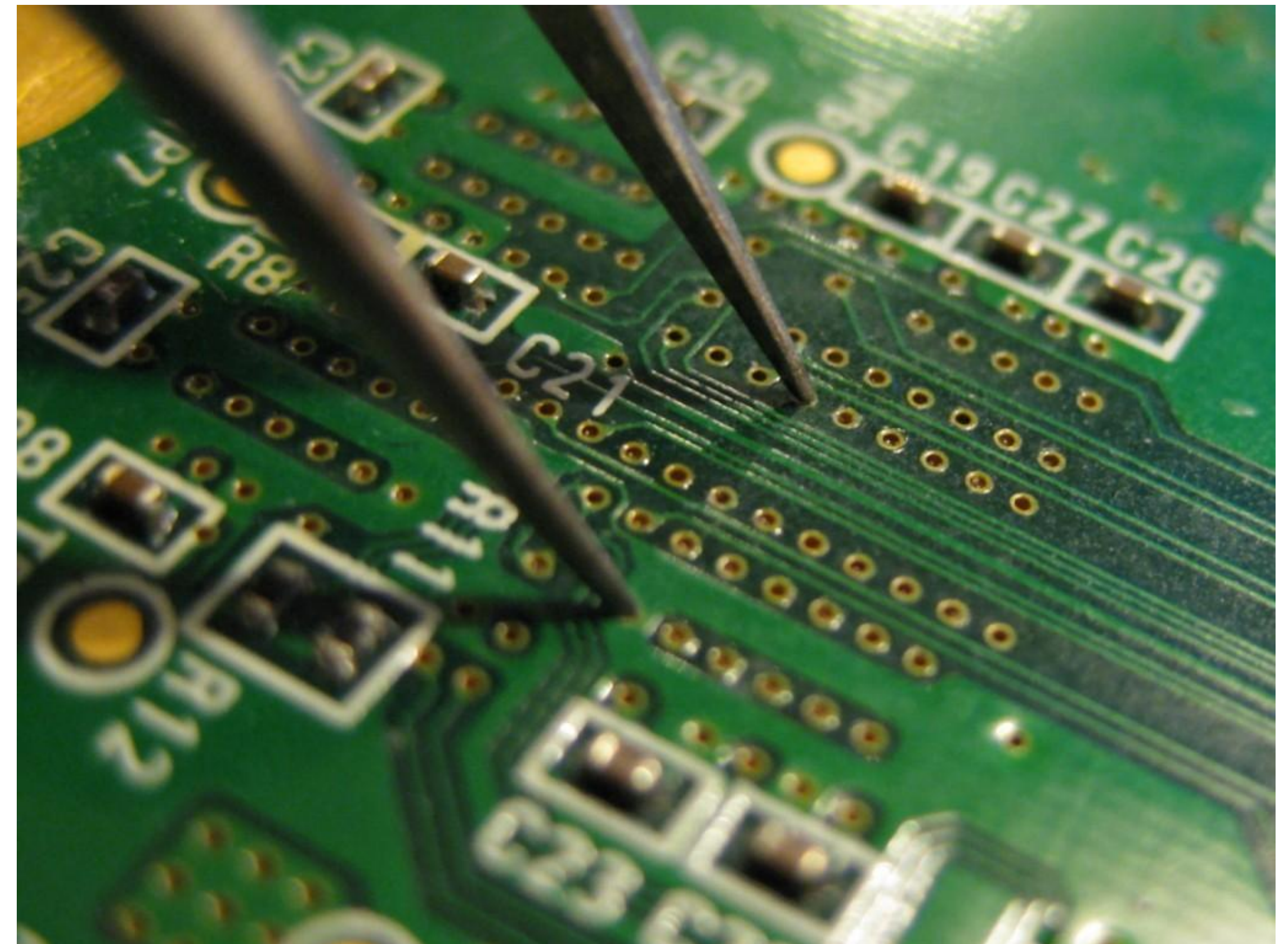


# Fault Injection

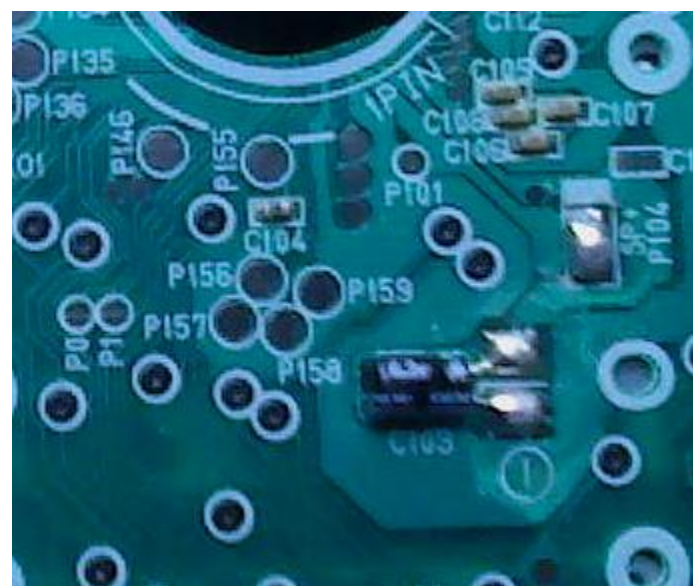
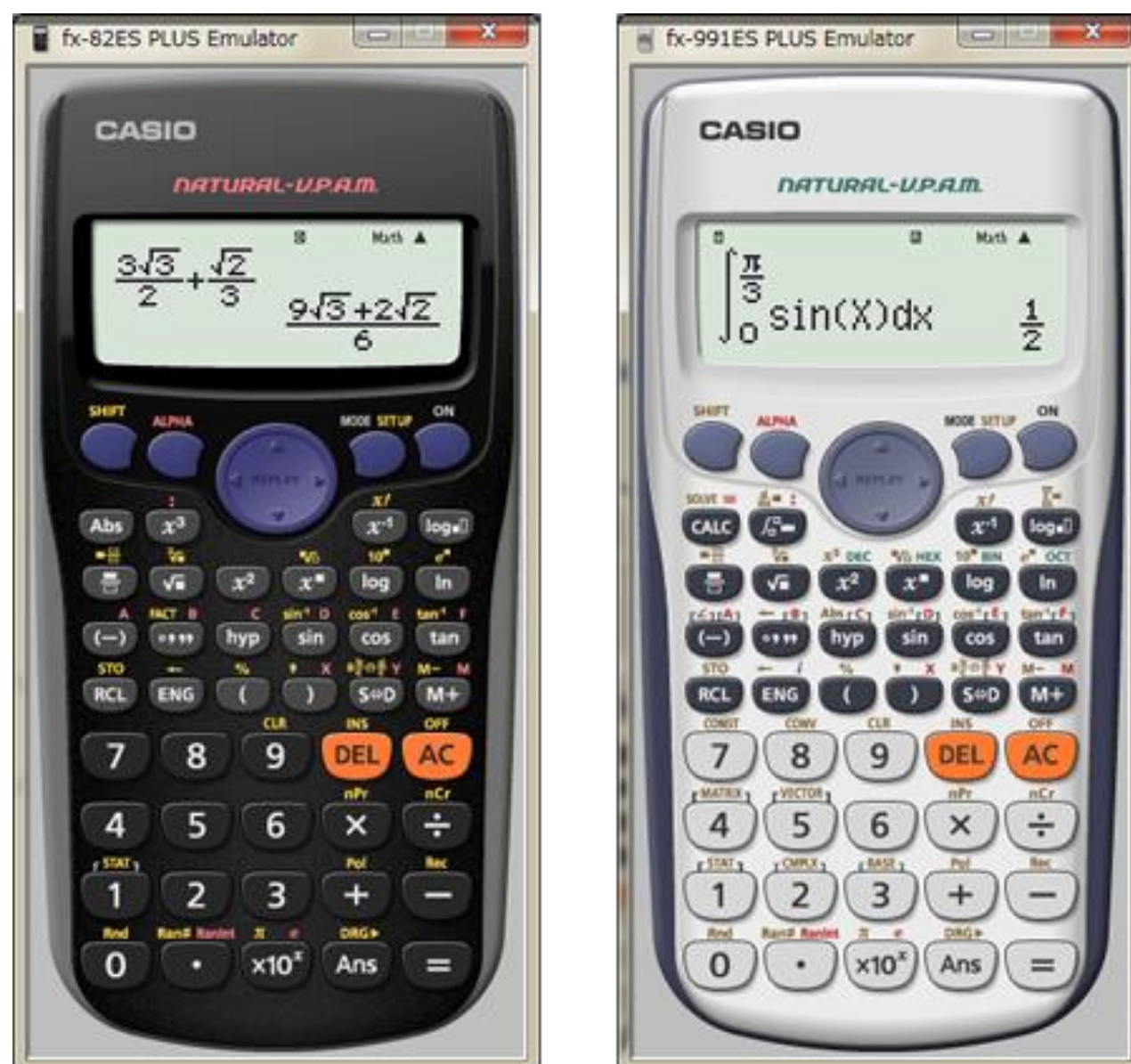


- Can be surprisingly trivial to execute ("twiizzer" attack) ---->

Also: -- 2B Pencil ->



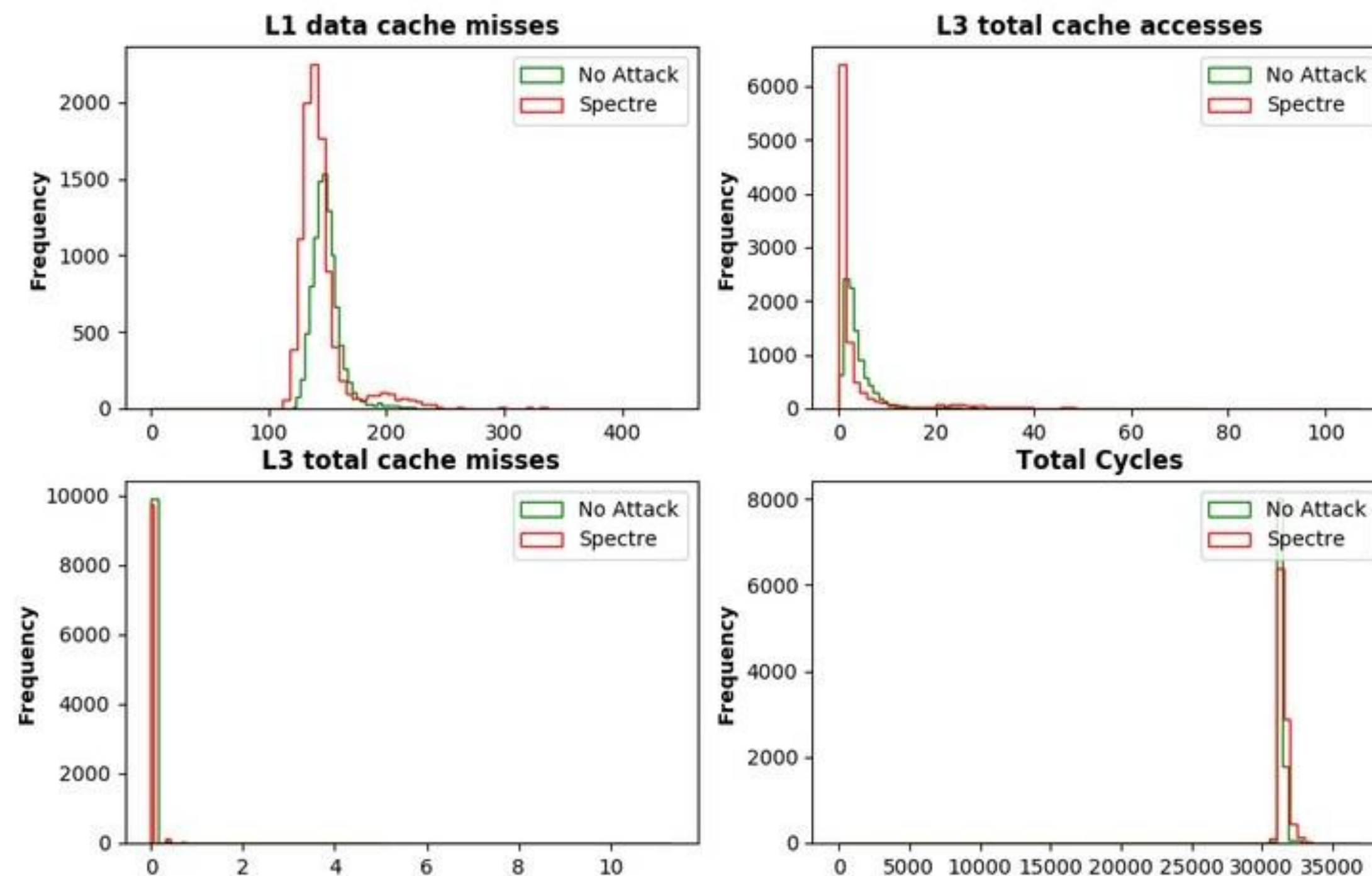
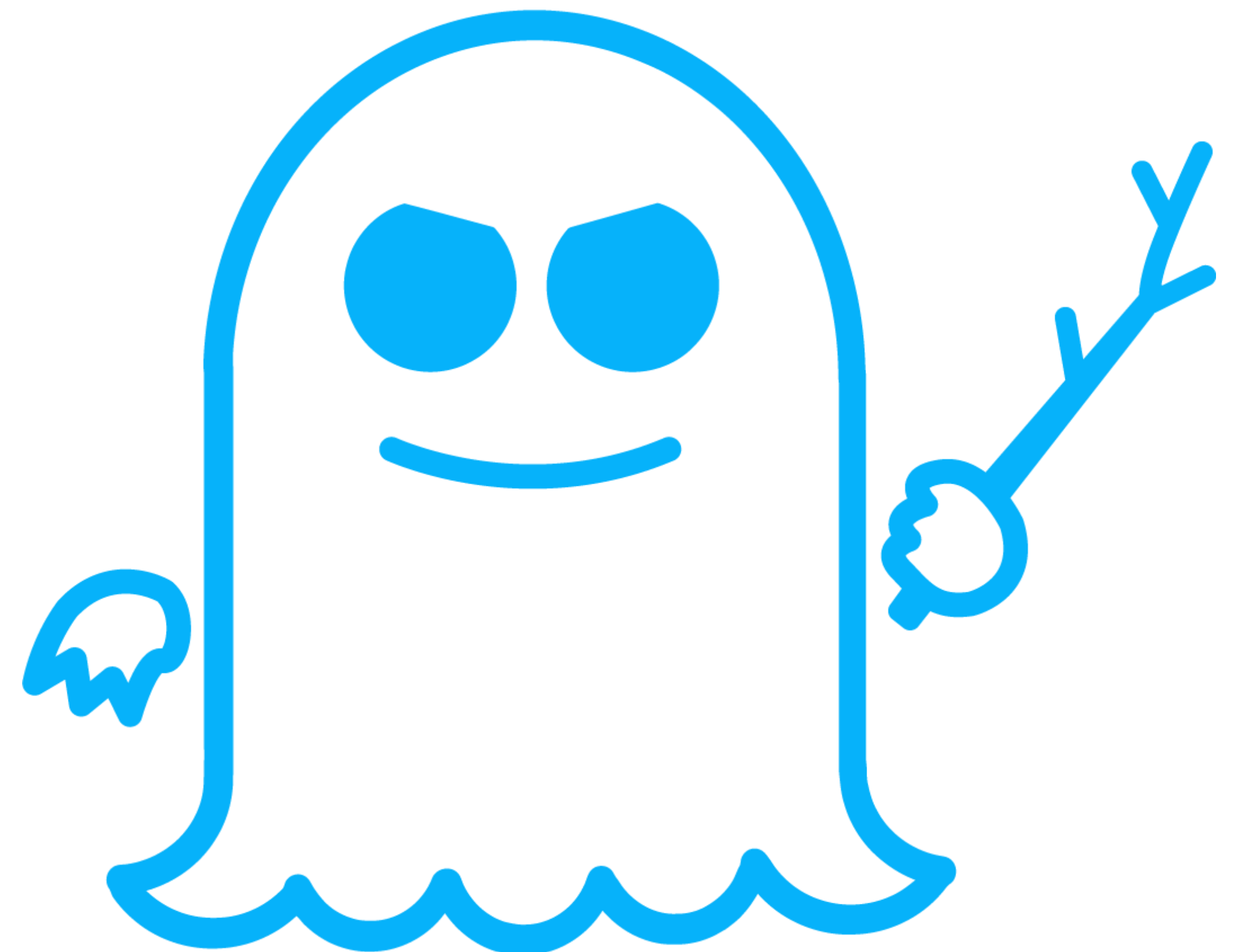
Twizzer hack via Marcan.st





# Active: Microarchitectural Side Channels

- Leverage timing differences in latency hiding features to leak secrets

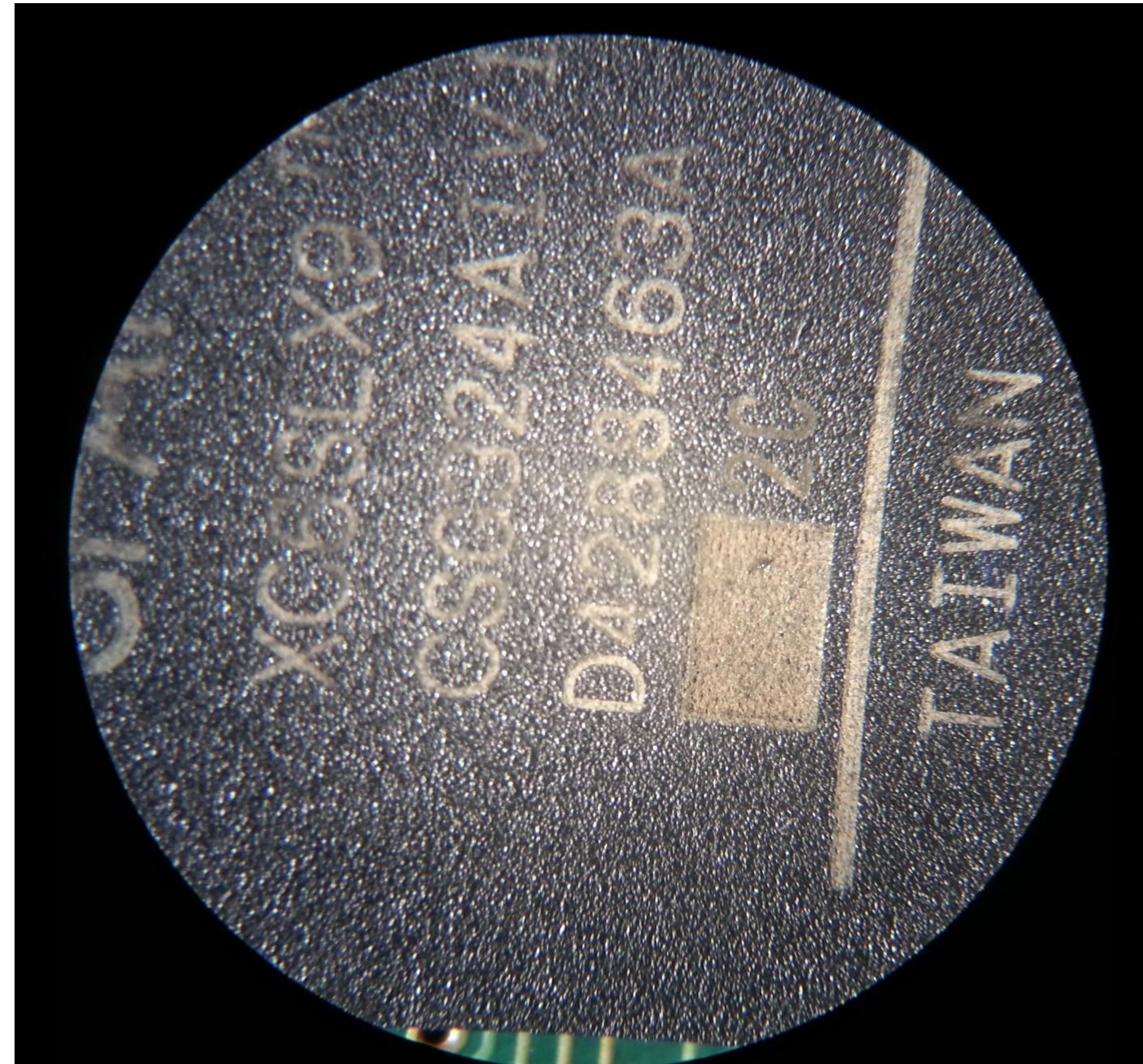
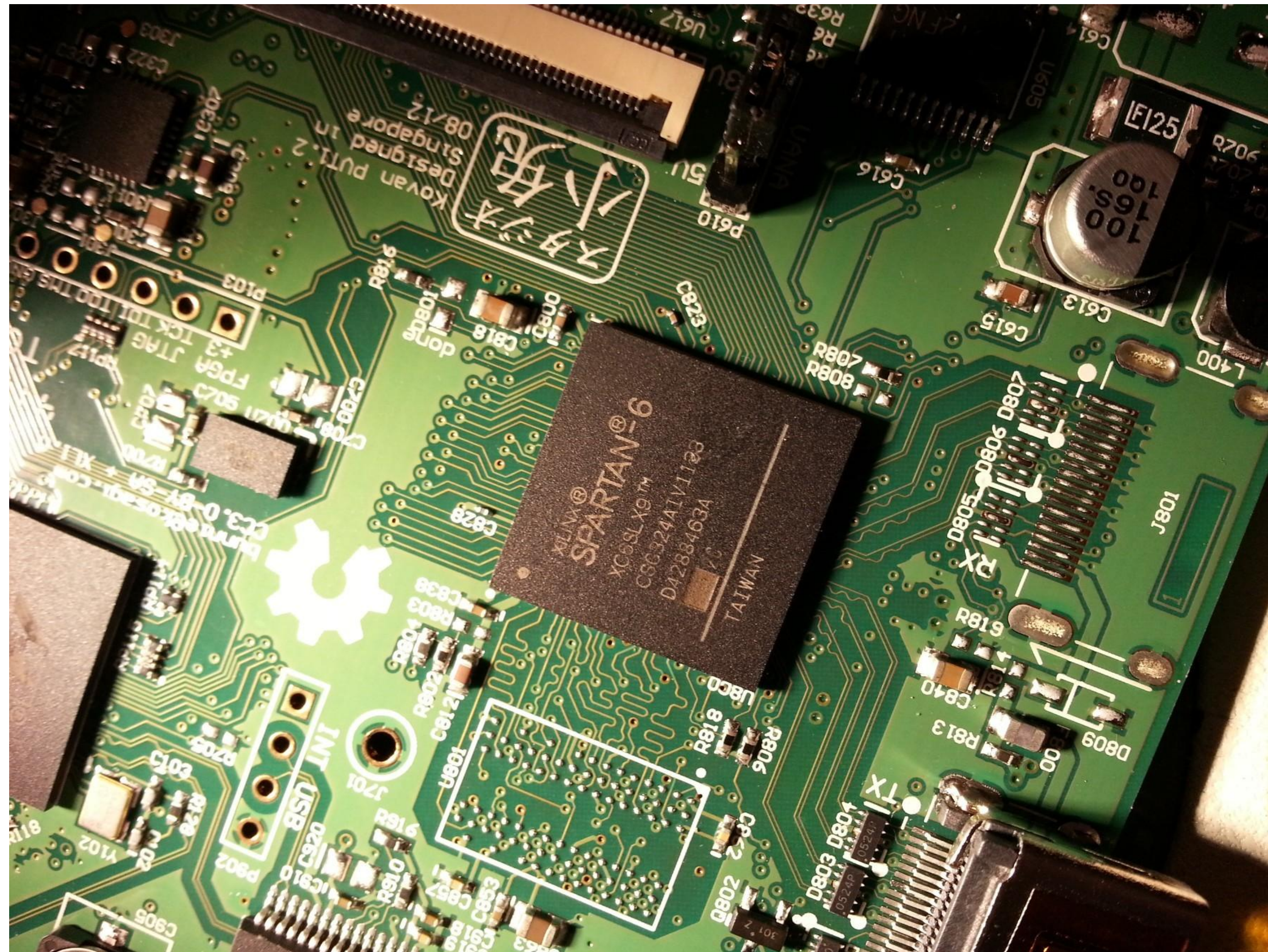


Can't Access the Hardware?

Attacks Prior to Installation:  
Supply Chain Tampering



# "State of the Practice" for Trusting Chips: Reading the Label on the Box





# Not Just Chips: Whole Assemblies Are Swapped Without Detection



(TS//SI//NF) Left: Intercepted packages are opened carefully; Right: A “load station” implants a beacon

## NSA: Implanting beacons in CISCO routers

<https://arstechnica.com/tech-policy/2014/05/photos-of-an-nsa-upgrade-factory-show-cisco-router-getting-implant/>



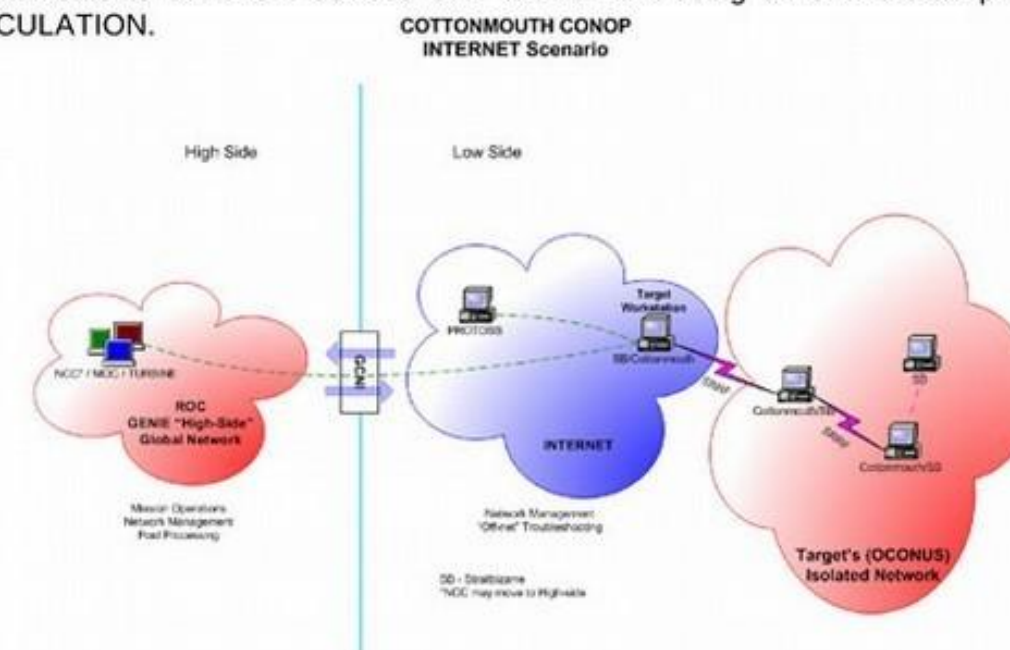
**(TS//SI//REL)** COTTONMOUTH-I (CM-I) is a Universal Serial Bus (USB) hardware implant which will provide a wireless bridge into a target network as well as the ability to load exploit software onto target PCs.

08/05/08



**(TS//SI//REL)** CM-I will provide air-gap bridging, software persistence capability, "in-field" re-programmability, and covert communications with a host software implant over the USB. The RF link will enable command and data infiltration and exfiltration. CM-I will also communicate with Data Network Technologies (DNT) software (STRAITBIZARRE) through a covert channel implemented on the USB, using this communication channel to pass commands and data between hardware and software implants. CM-I will be a GENIE-compliant implant based on CHIMNEYPOOL.

**(TS//SI//REL)** CM-I conceals digital components (TRINITY), USB 1.1 FS hub, switches, and HOWLERMONKEY (HM) RF Transceiver within the USB Series-A cable connector. MOCCASIN is the version permanently connected to a USB keyboard. Another version can be made with an unmodified USB connector at the other end. CM-I has the ability to communicate to other CM devices over the RF link using an over-the-air protocol called SPECULATION.



**Status:** Availability – January 2009

**Unit Cost:** 50 units: \$1,015K

POC: [REDACTED], S3223, [REDACTED], [REDACTED]@nsa.ic.gov  
ALT POC: [REDACTED], S3223, [REDACTED], [REDACTED]@nsa.ic.gov

Derived From: NSA/CSSM 1-52  
Dated: 20070108  
Declassify On: 20320108

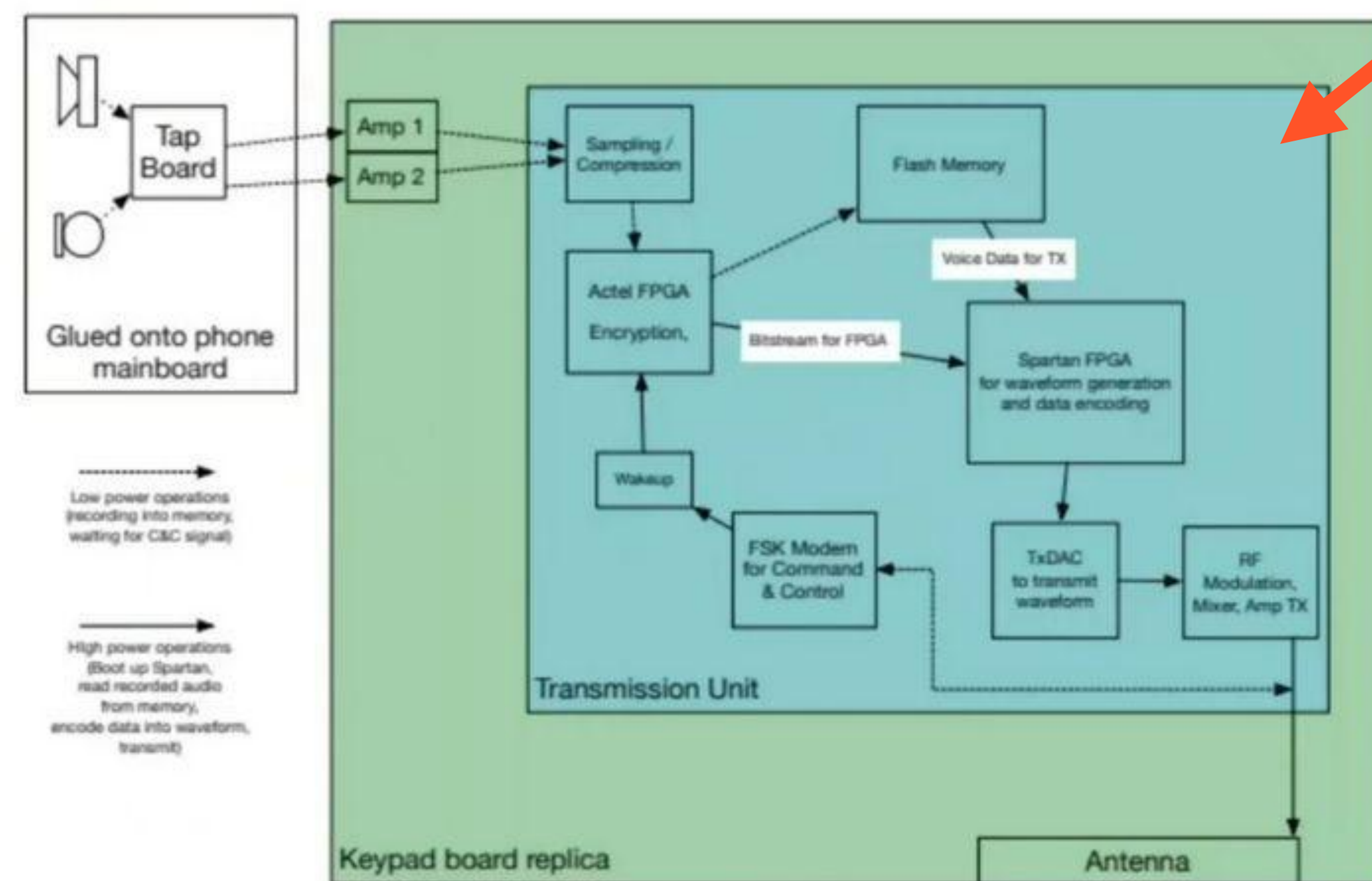
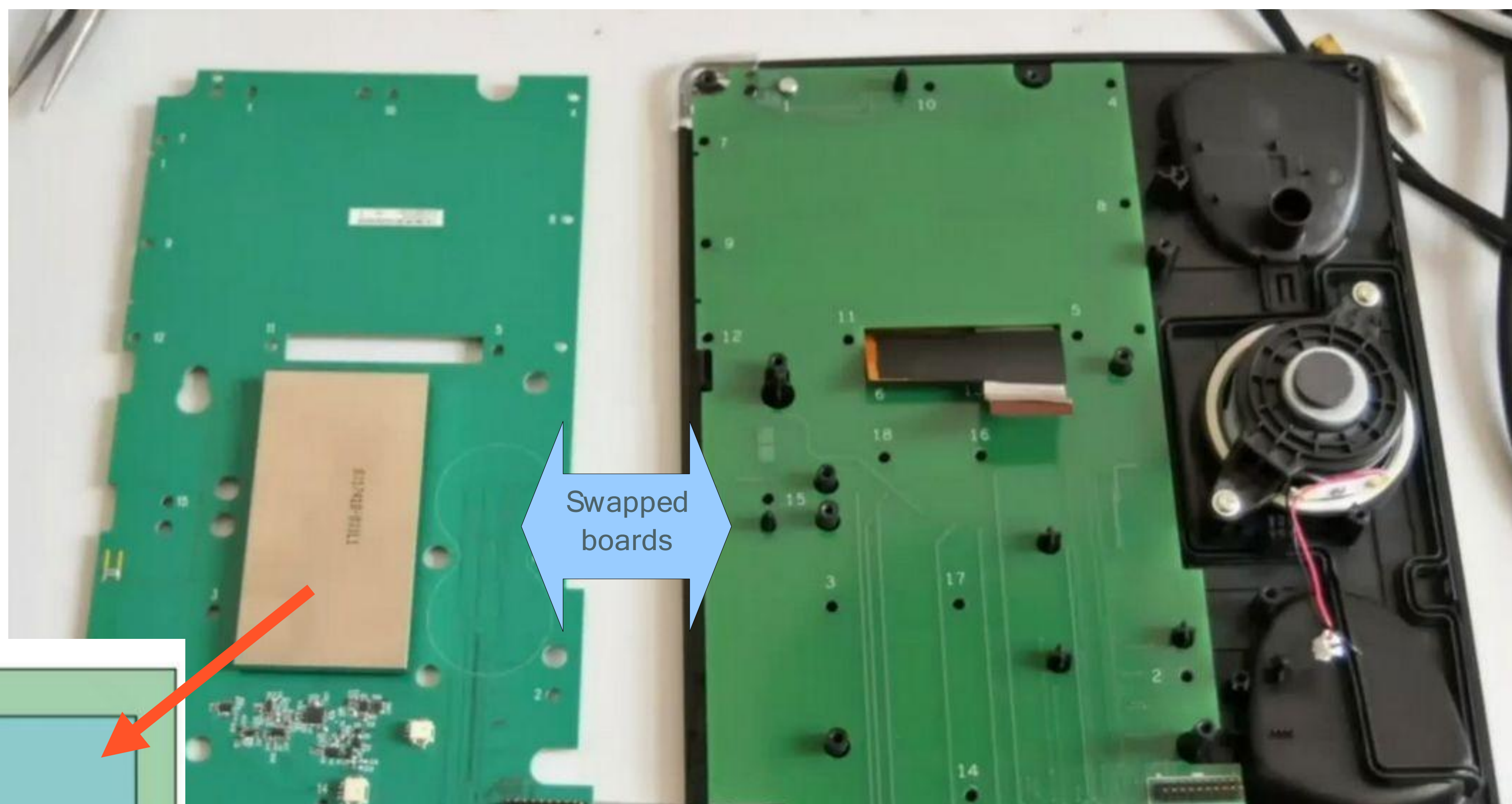
TOP SECRET//COMINT//REL TO USA, FVEY

(TS//SI//REL) GODSURGE runs on the FLUXBABBITT hardware implant and provides software application persistence on Dell PowerEdge servers by exploiting the JTAG debugging interface of the server's processors.

(TS//SI//REL) FLUXBABBITT Hardware  
Implant for PowerEdge 2950(TS//SI//REL) FLUXBABBITT Hardware  
Implant for PowerEdge 1950

## JTAG implants Dell PowerEdge servers



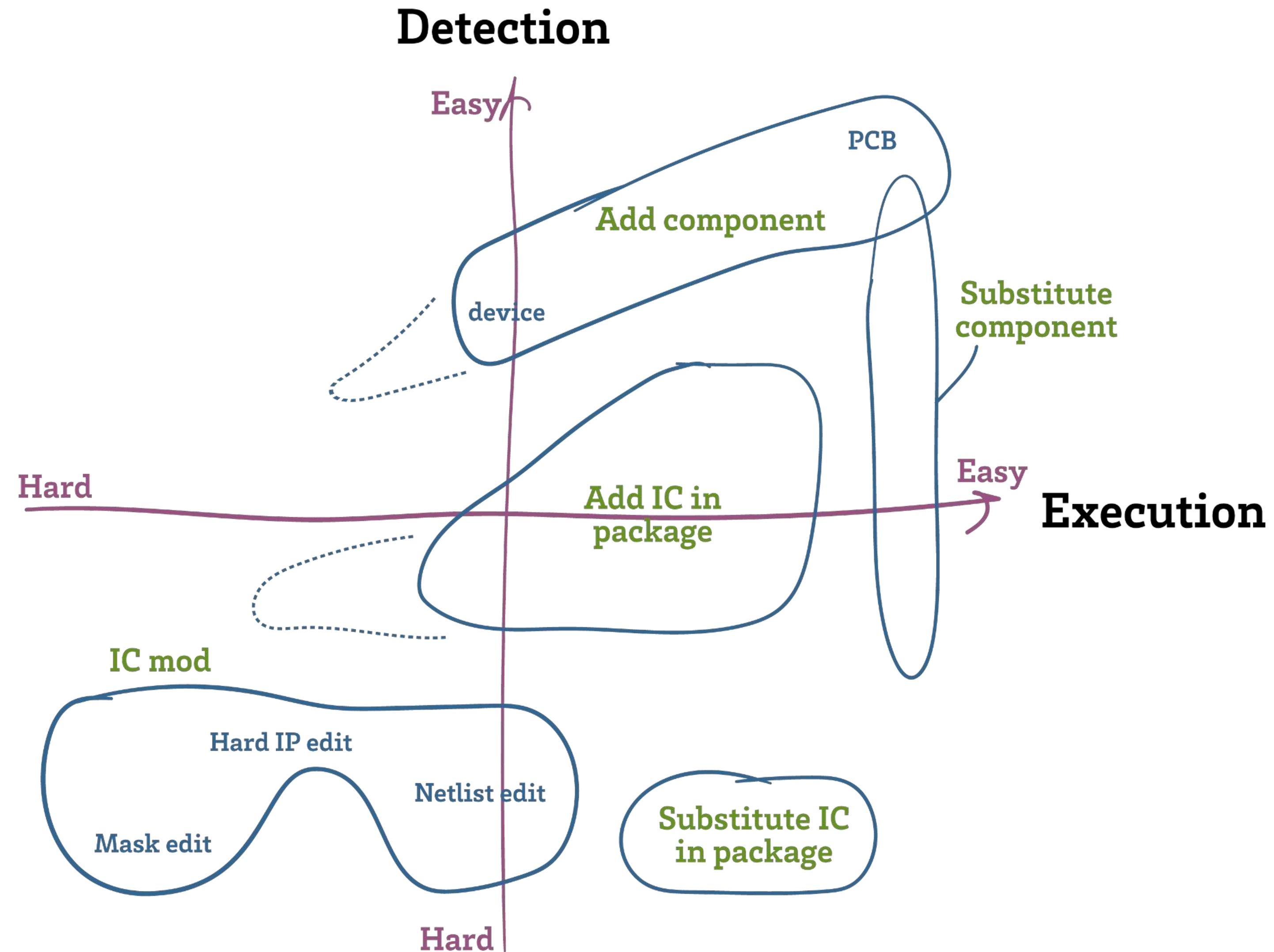


Andy Müller-Maguhn - listening device in cryptophone

[https:// datareisen.de/2020/20201228-RC3-AMM-CIA-VS-WL.pdf](https://datareisen.de/2020/20201228-RC3-AMM-CIA-VS-WL.pdf)

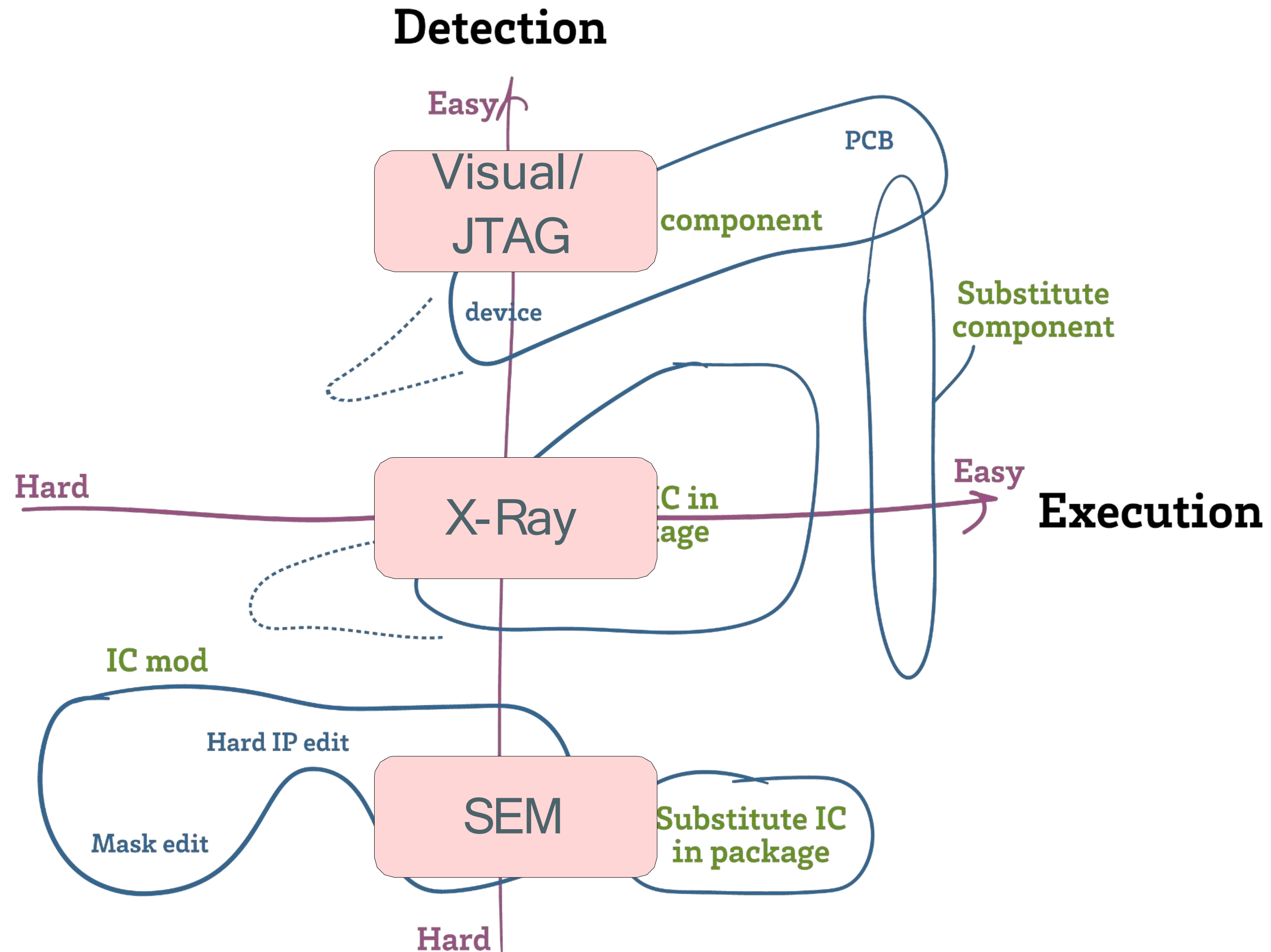


# An Ontology of Supply Chain Attacks



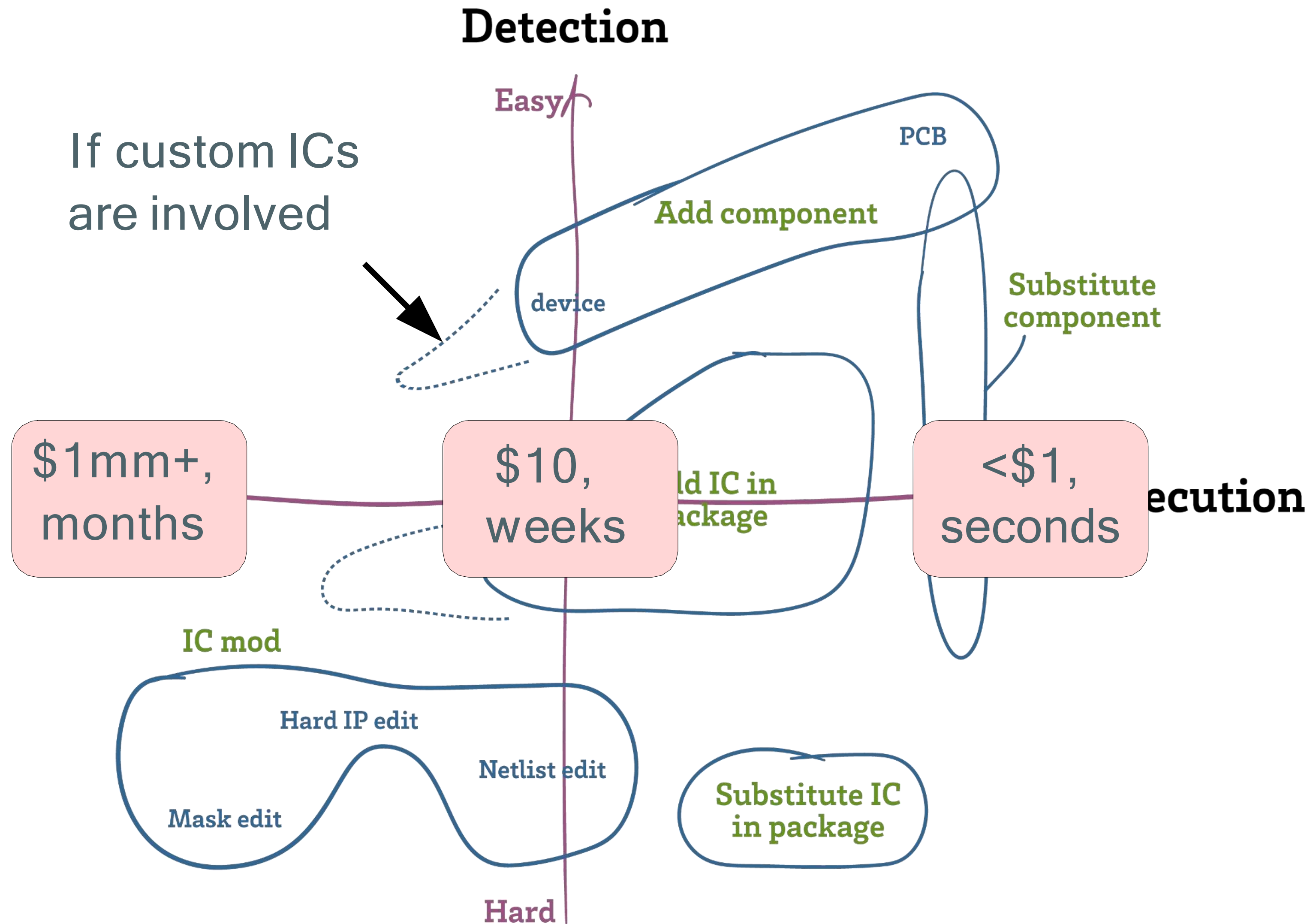


# Degrees of Detection Difficulty





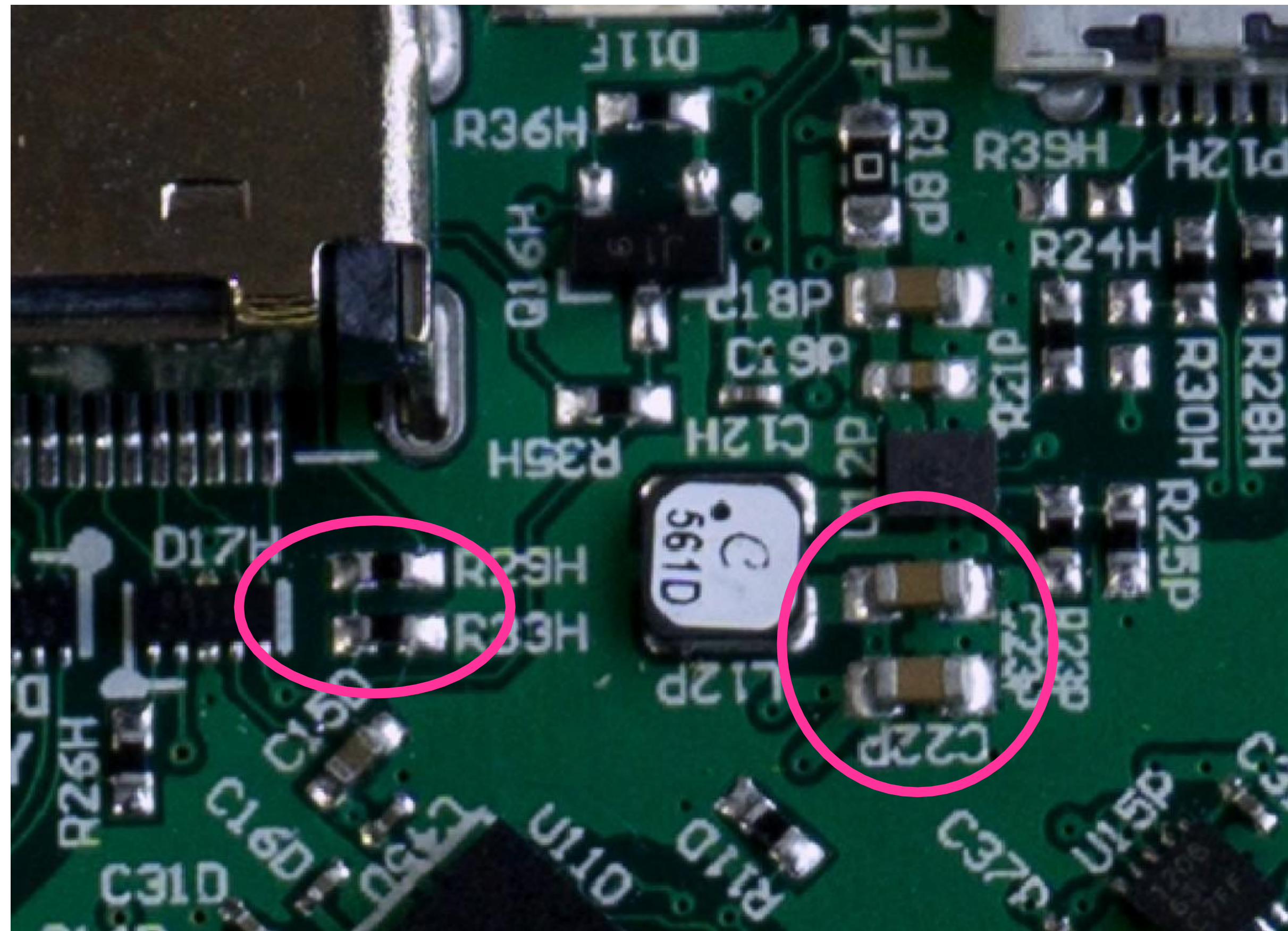
# Degrees of Execution Difficulty





# "Substitute Component"

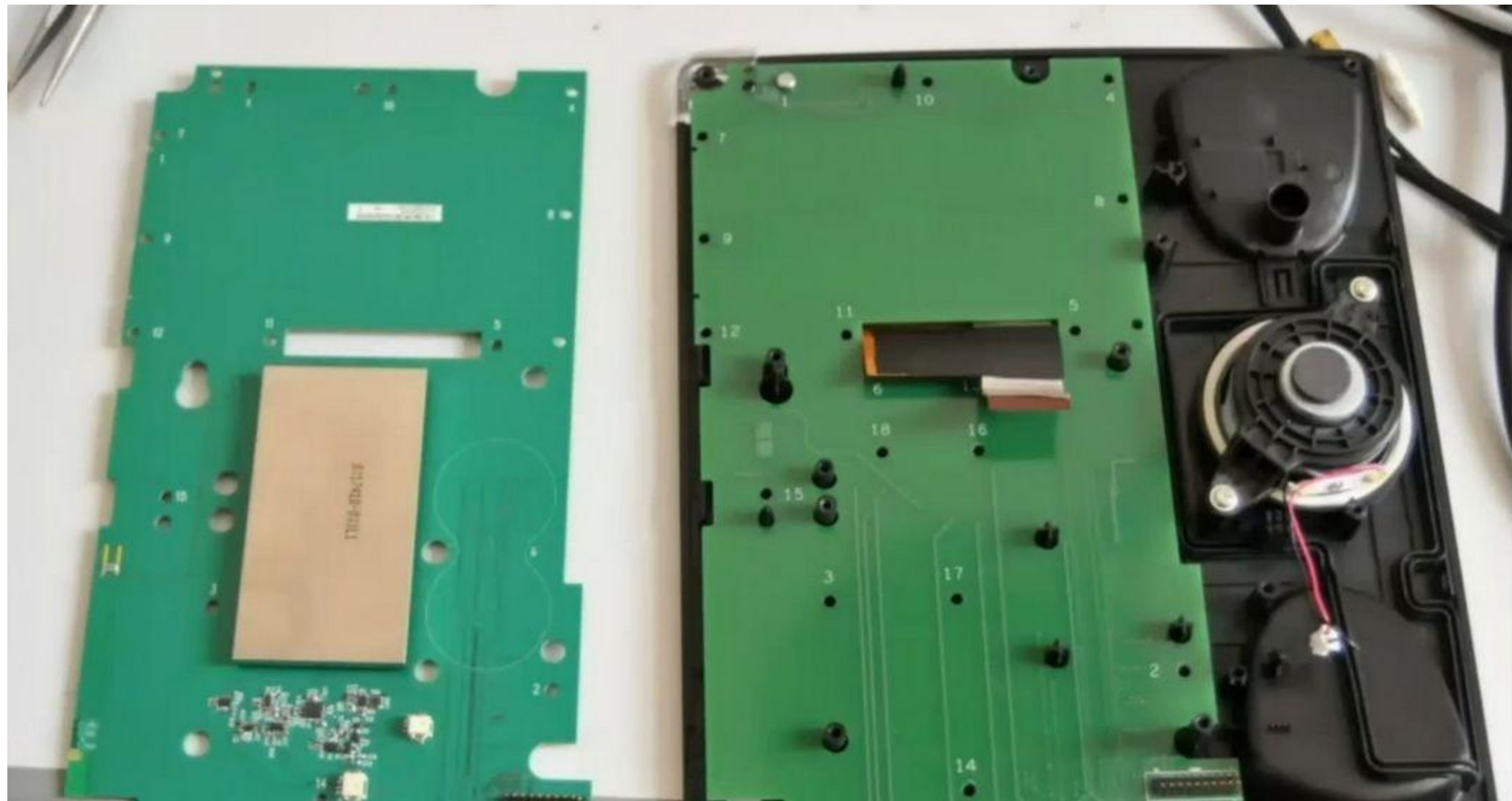
- Relies on the fact that many components look alike





# "Add A Component"

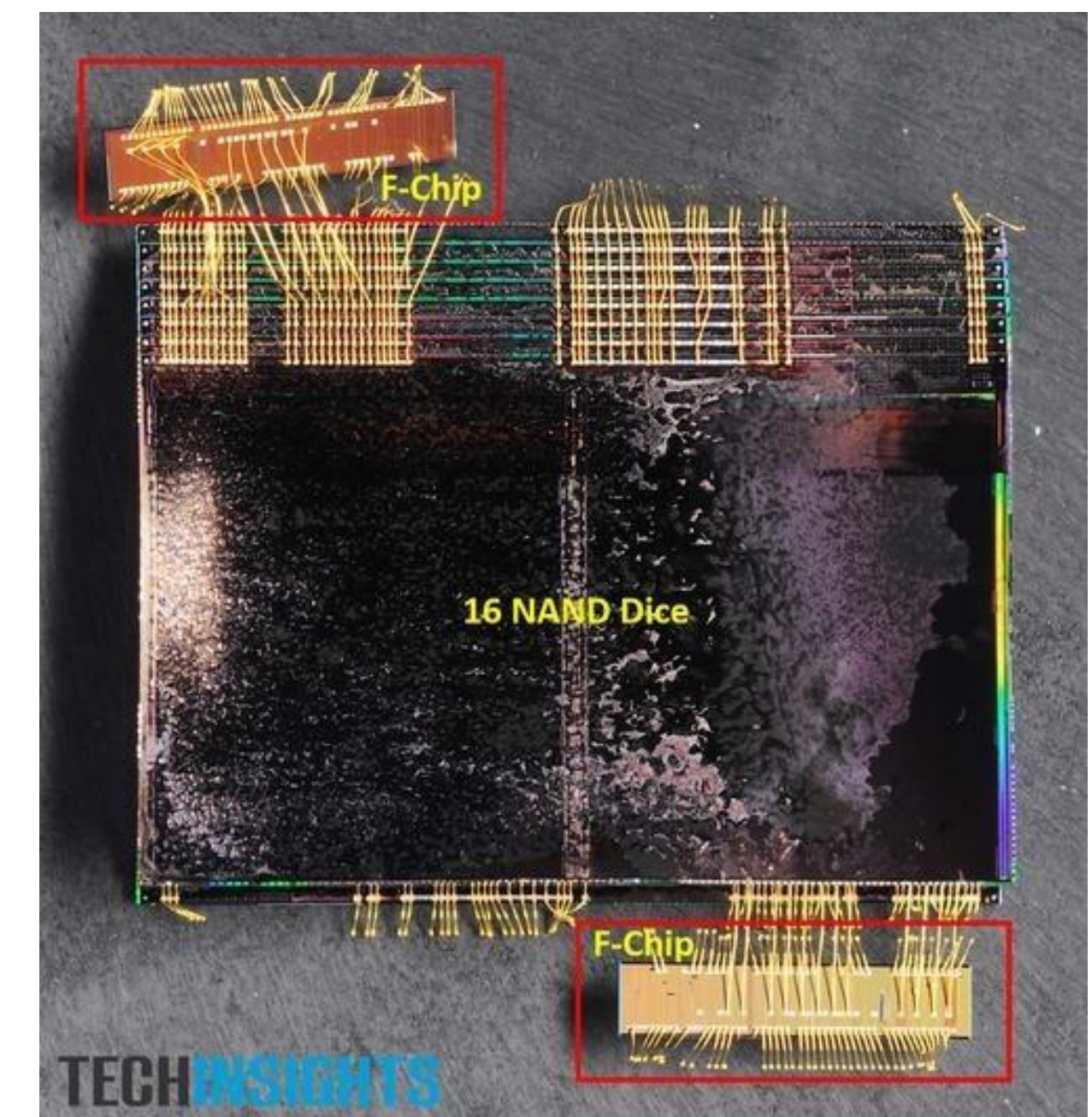
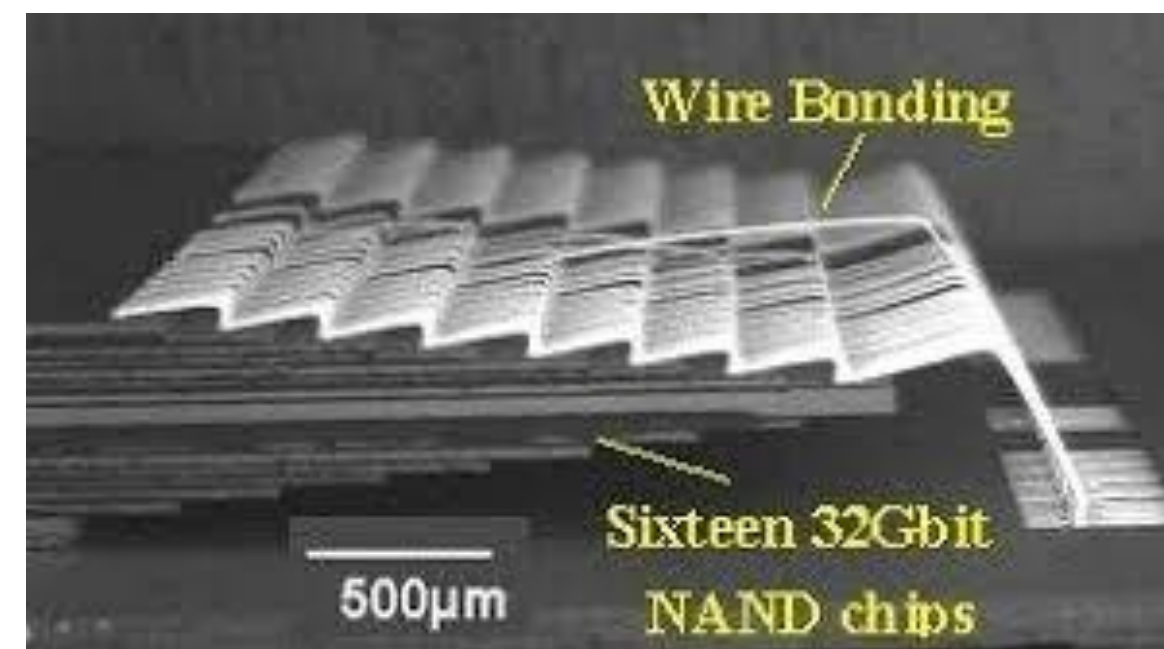
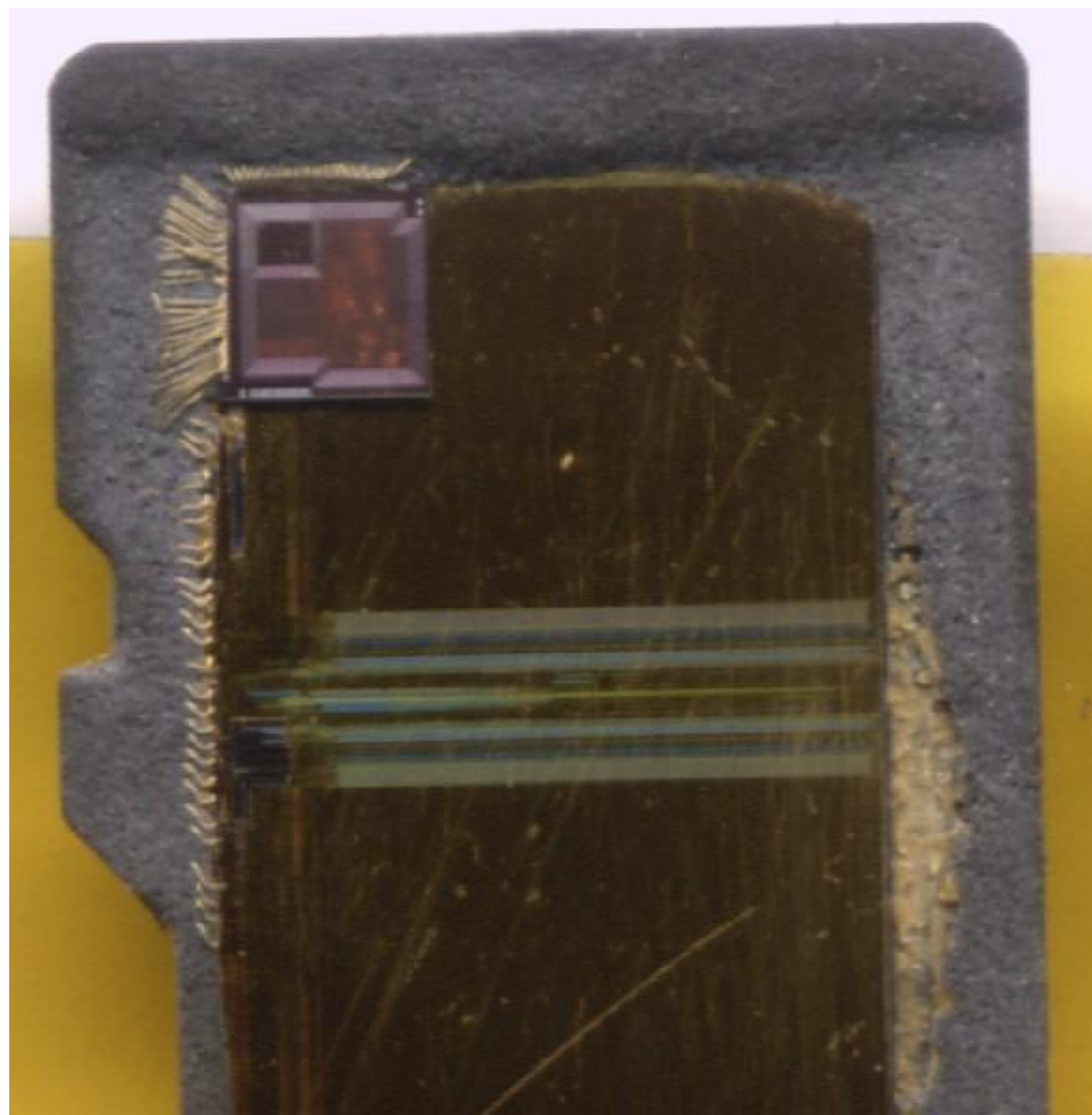
- Easily detectable -> higher awareness





# "Add IC in Package"

- Hide an additional chip inside a package
- Multiple chips in package is a mature technology

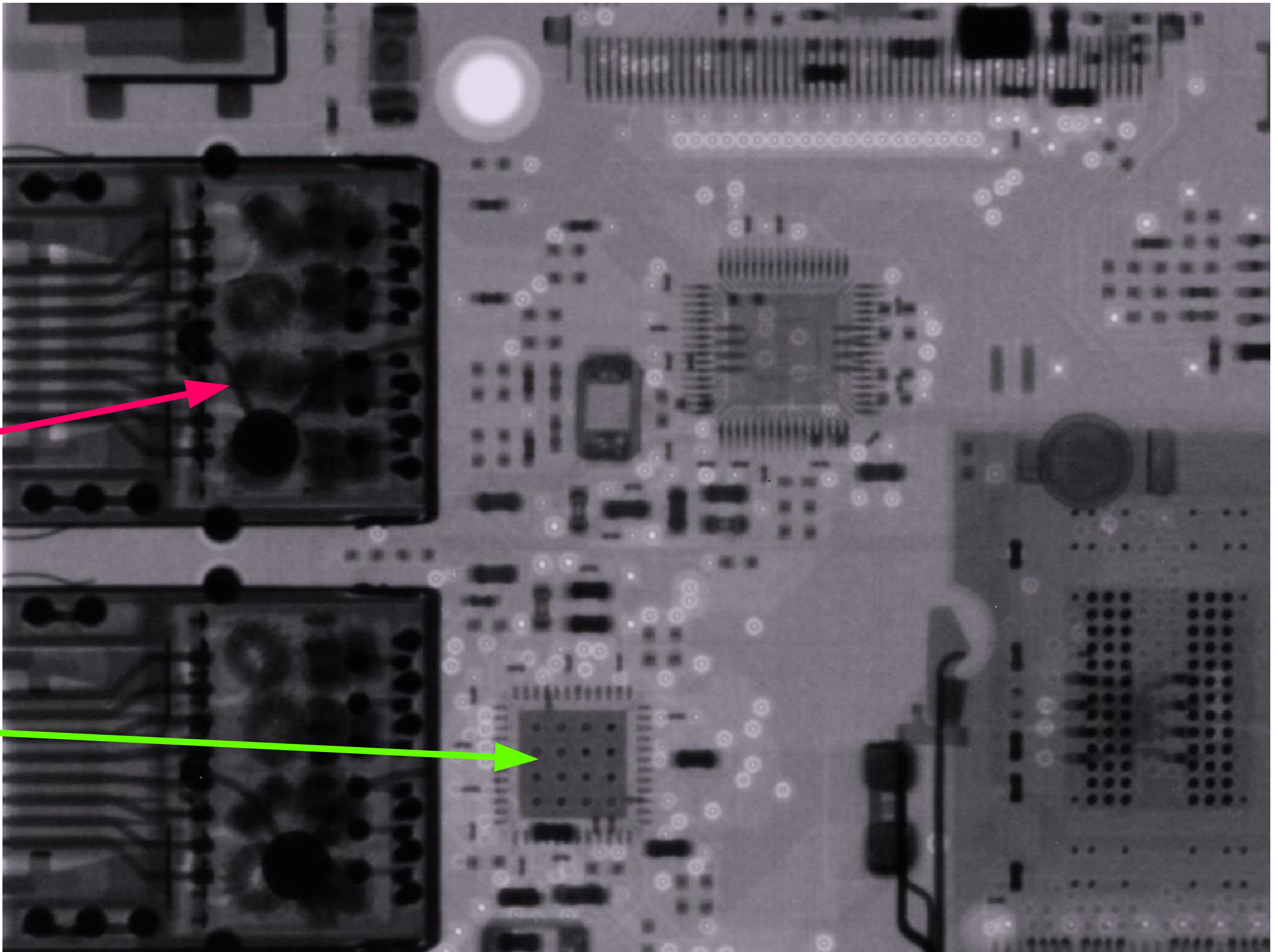




# Solution: X-Ray All the Things?



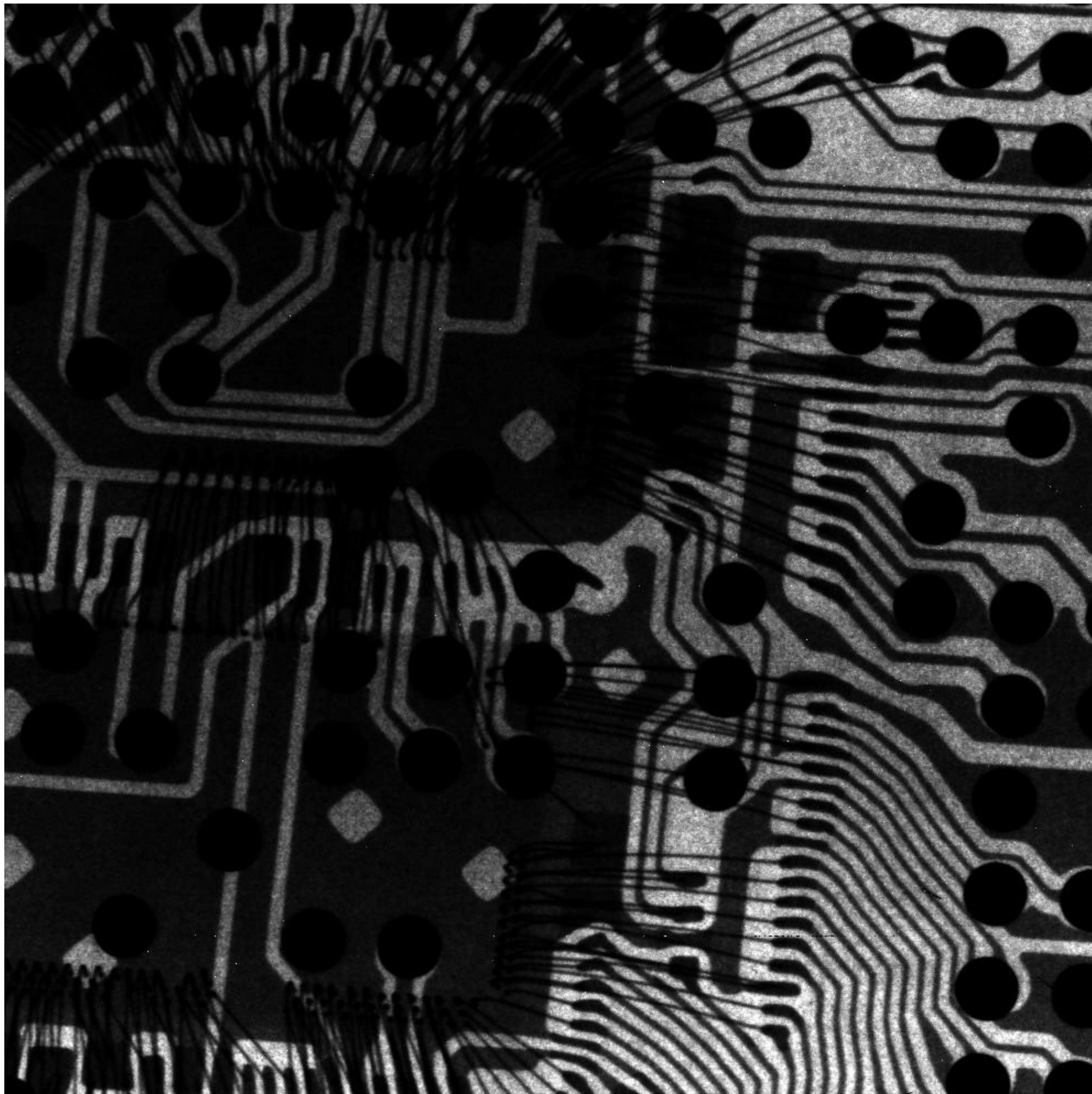




Obvious

Less  
obvious



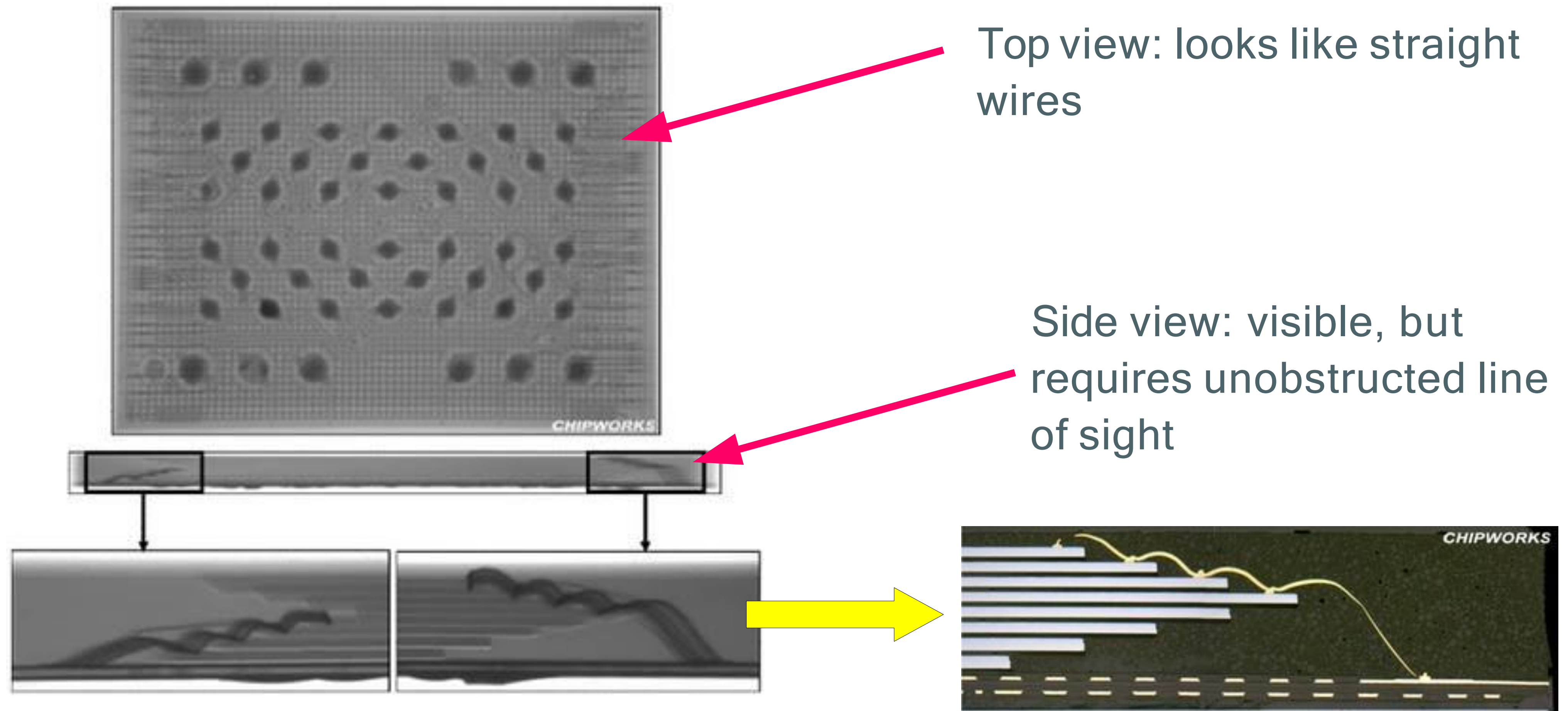


# Problem #1

- Silicon ( $Z=14$ ) is relatively transparent to X-rays
  - Copper traces, solder tend to mask the presence of silicon
- Mitigations
  - CT (Computerized Tomography) scanners
  - X-ray diffraction, spectroscopy

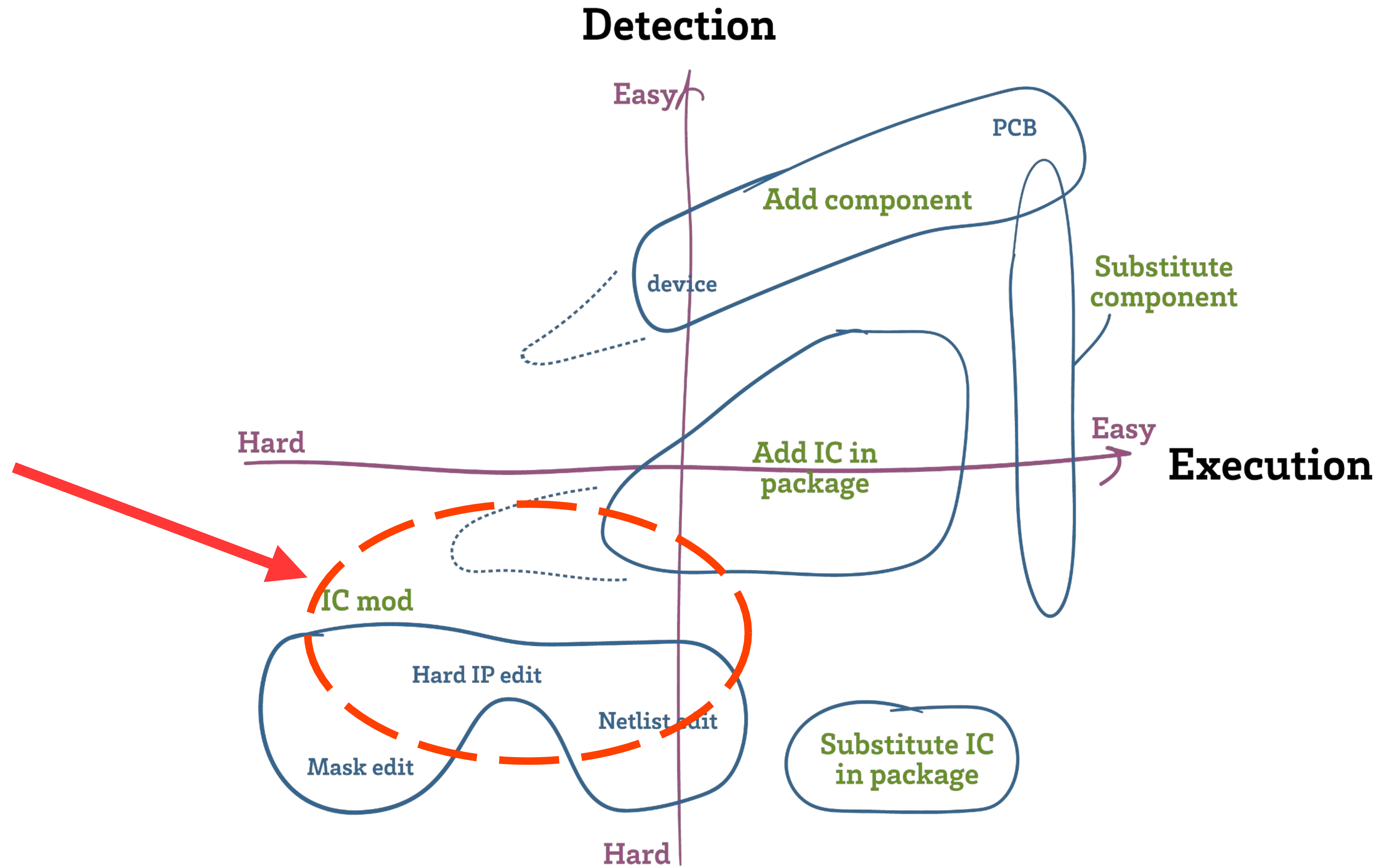


# Problem #2: X-Rays Don't Trivially Detect Multiple ICs



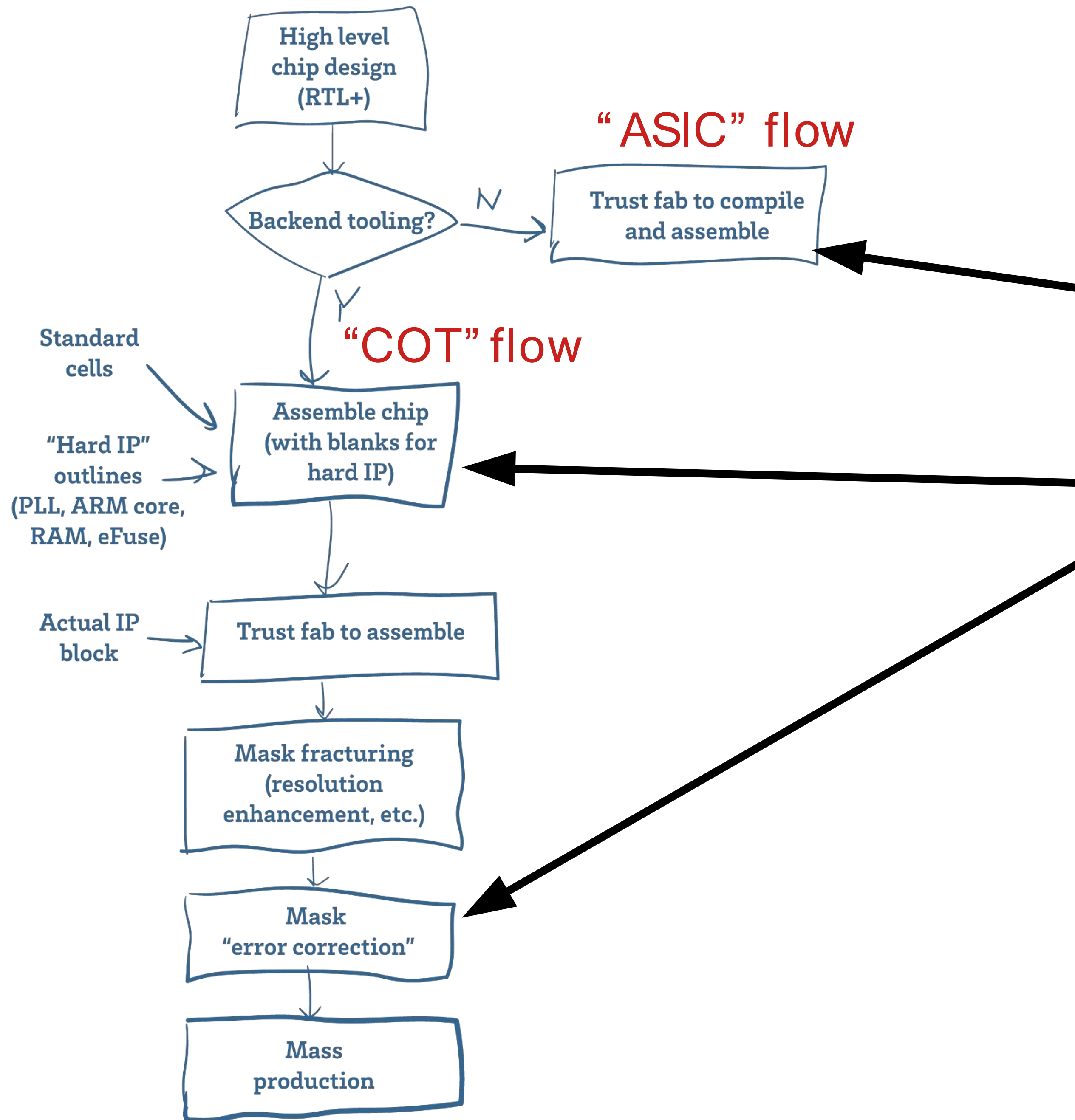


# IC Modifications





# IC Fab: Attack Surfaces



- Netlist Tampering
  - RTL = Verilog, VHDL, Python
- Hard IP Tampering
- Mask Tampering



# Netlist Tampering: ASIC vs COT

- ASIC - “Application Specific Integrated Circuit”

- Customer does RTL + floorplan
- Foundry does detail place/route, IP integration, pad ring
- Popular for e.g. cheap support chips:
  - Server BMC (Baseboard Management Controller)
  - Disk controllers
  - Mid-to-low end I/O controllers

- COT - “Customer Owned Tooling”

- Customer does full flow, down to a nominal GDS-II mask
- Several extra headcount + \$millions for back-end tooling software
- Necessary for high-performance / flagship products (CPU/GPU/router)

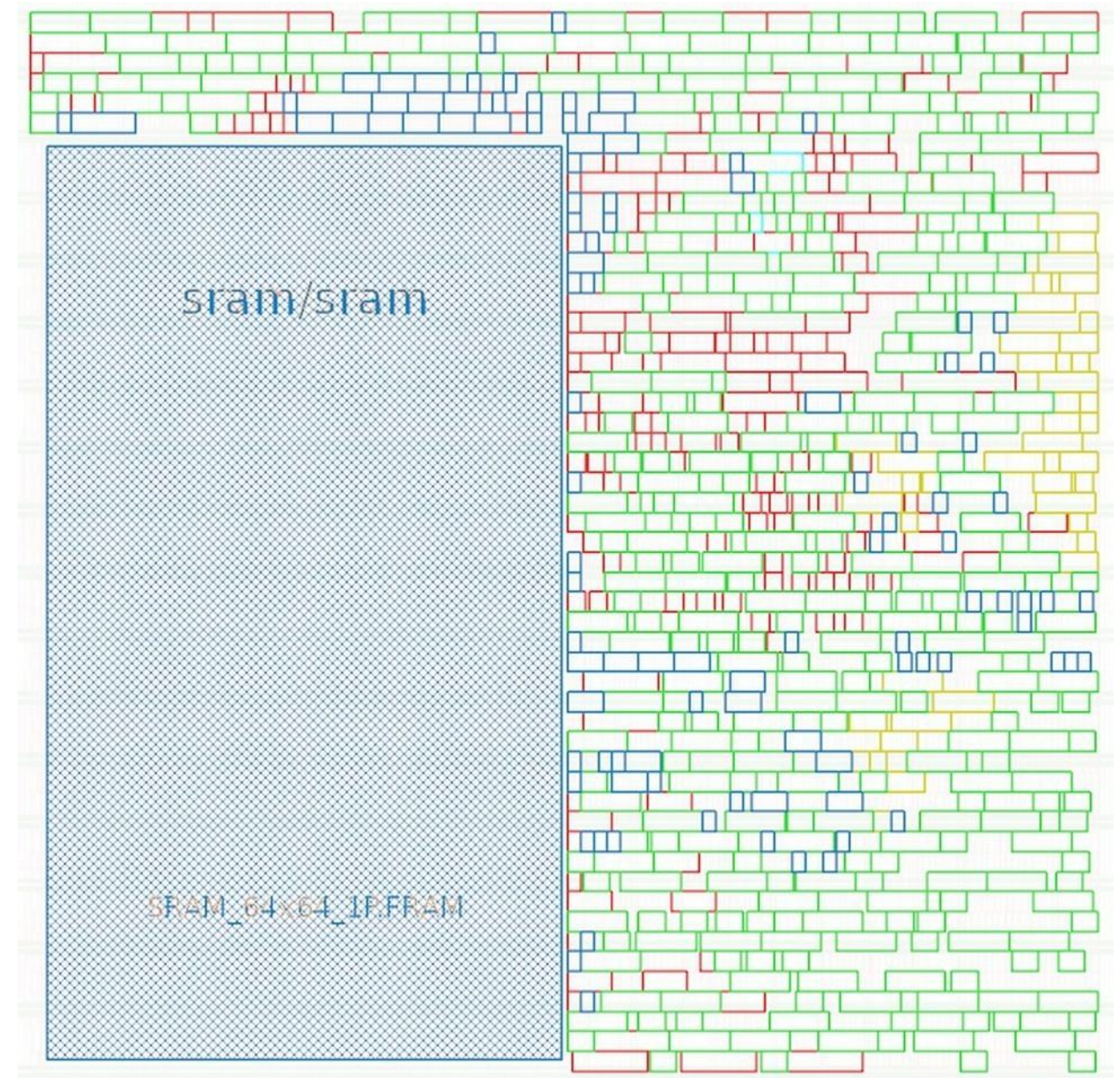


So I'm Safe with COT, Right?



# COT Weaknesses: "Hard IP"

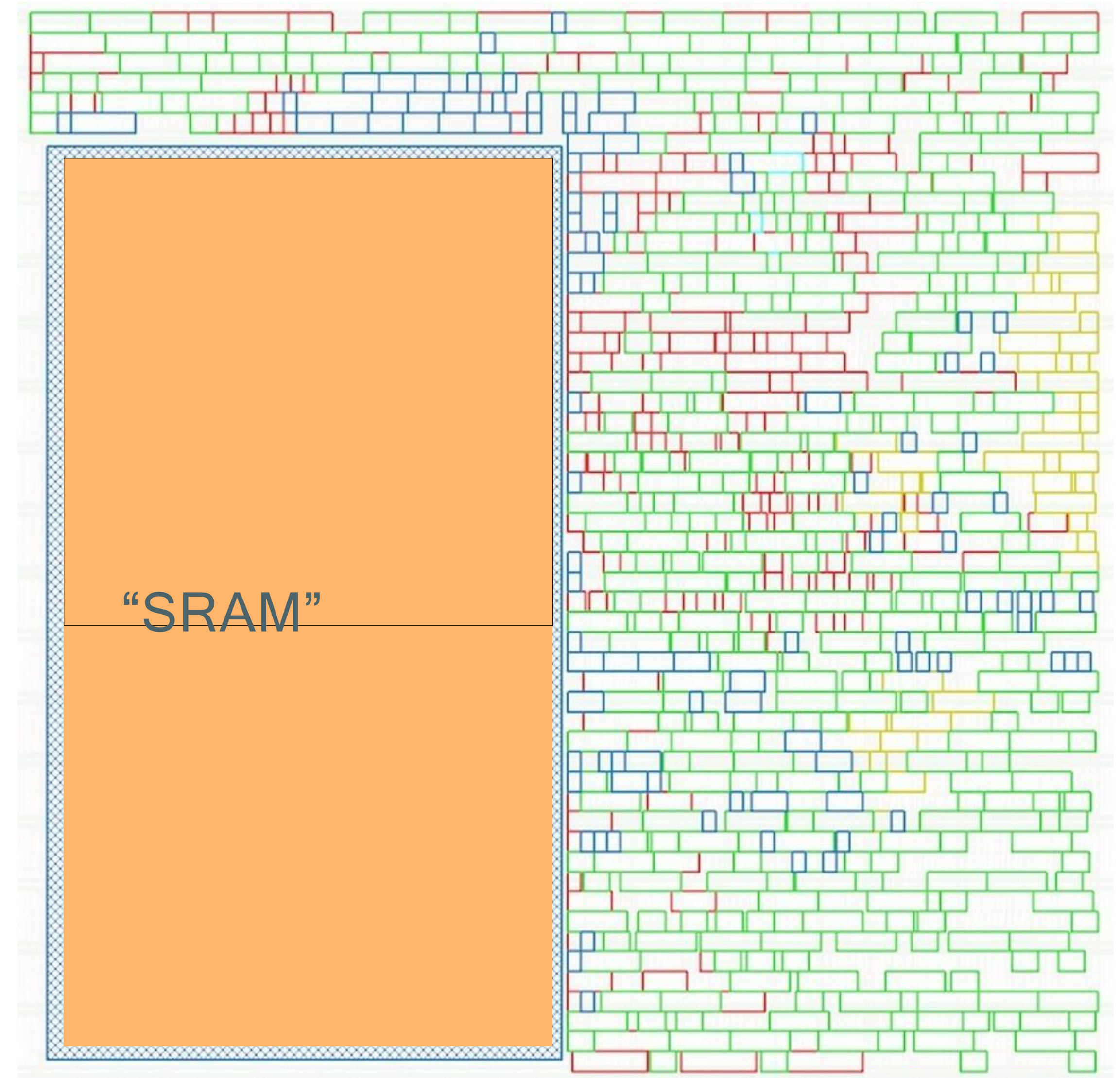
- COT designers still leave large “holes” in the layout for hard IP
  - Foundry merges proprietary blocks with agreed upon connection points





# COT Weaknesses: "Hard IP"

- COT designers still leave large “holes” in the layout for hard IP
  - Foundry merges proprietary blocks with agreed upon connection points





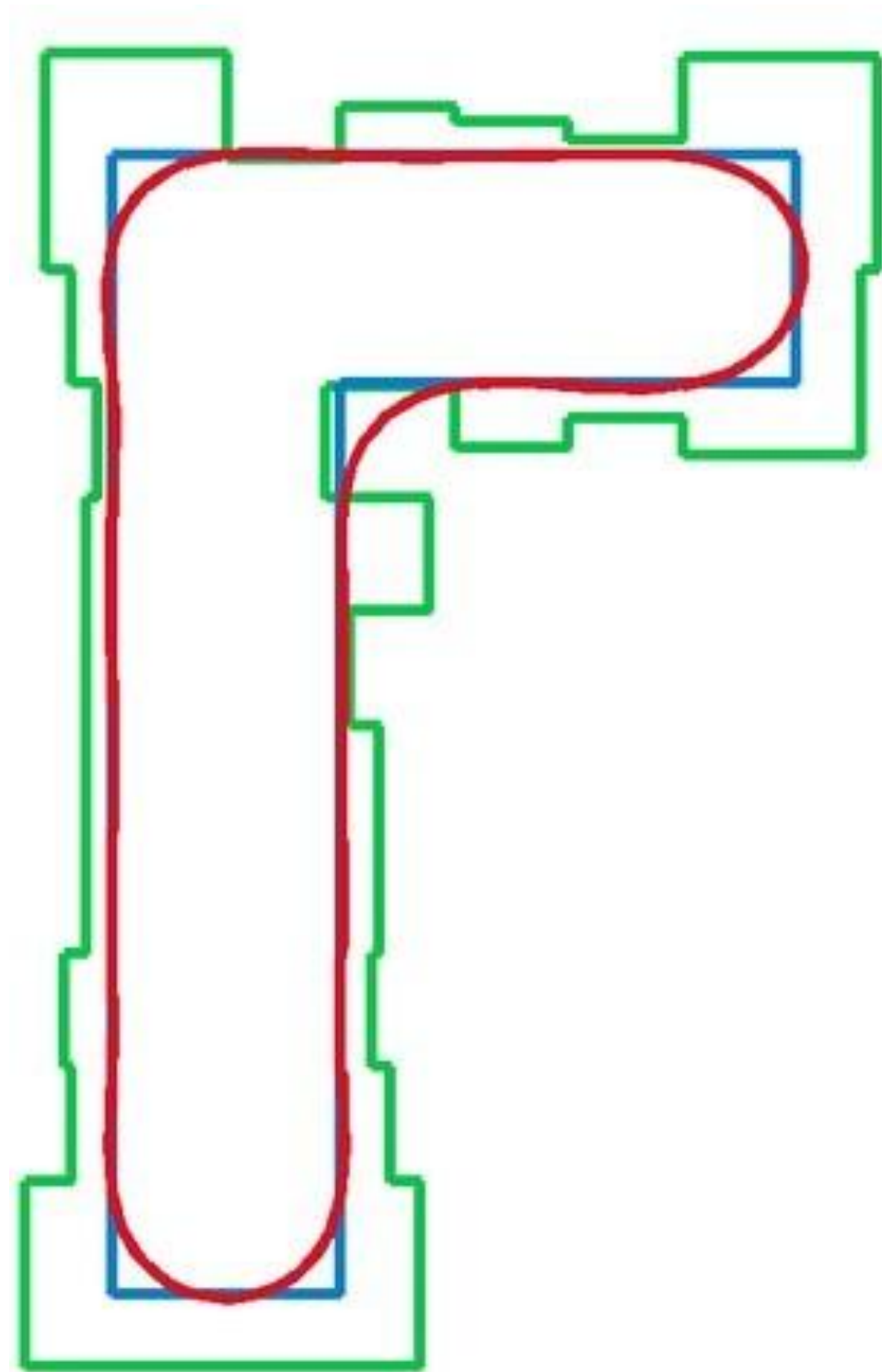
# Hard IP: Who Cares?

- RF/analog
  - PLL, ADC, DAC, bandgap
- RAM
- ROM
- eFuse
- Pad rings
- Basically, all the points you need to backdoor an IC



# Mask Tampering: Post-Design Processing

- Sub-wavelength features requires substantial mask post-processing

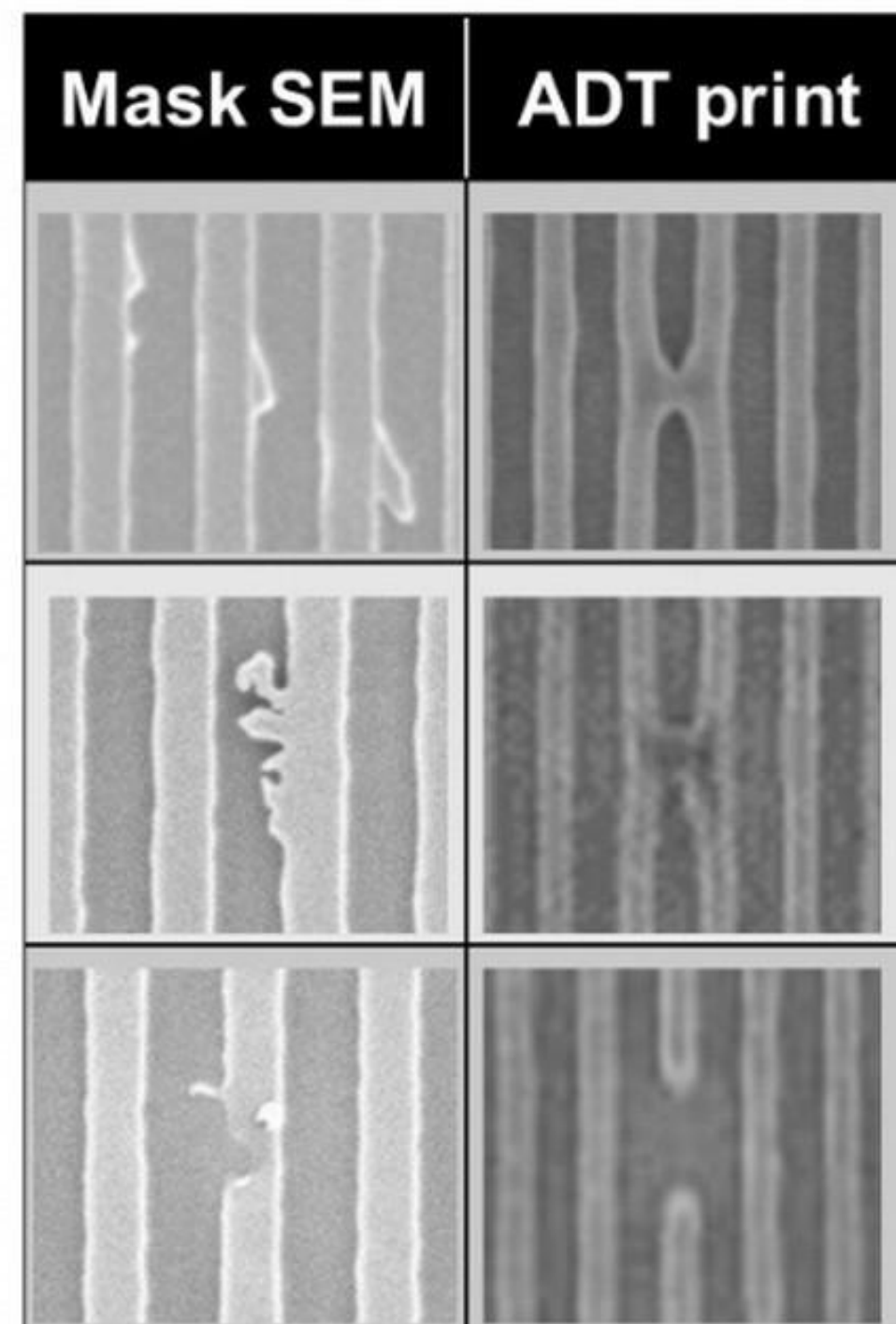




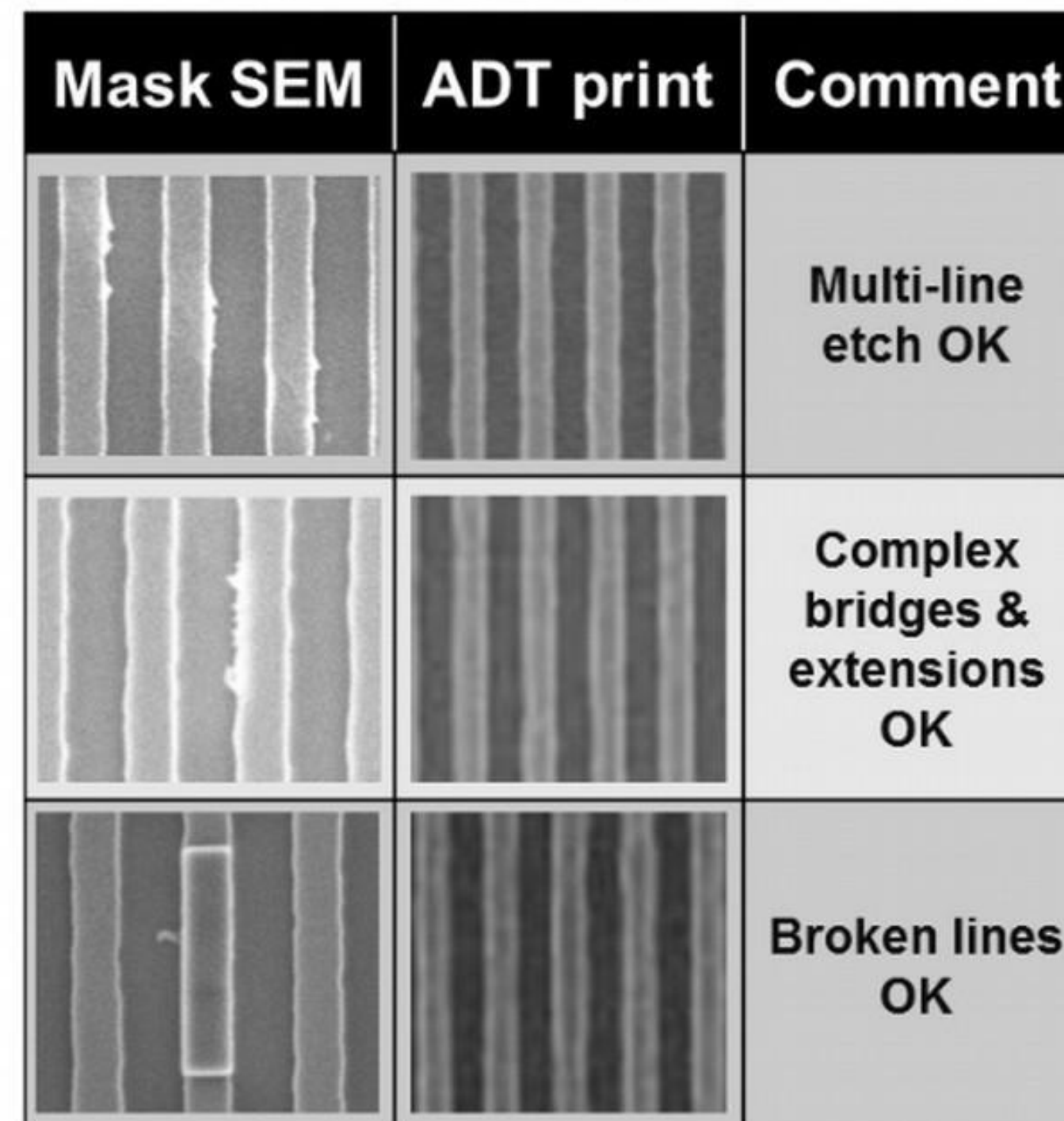
# Mask Editing

- All masks go through an editing ("checking") step

**40 nm real defects**



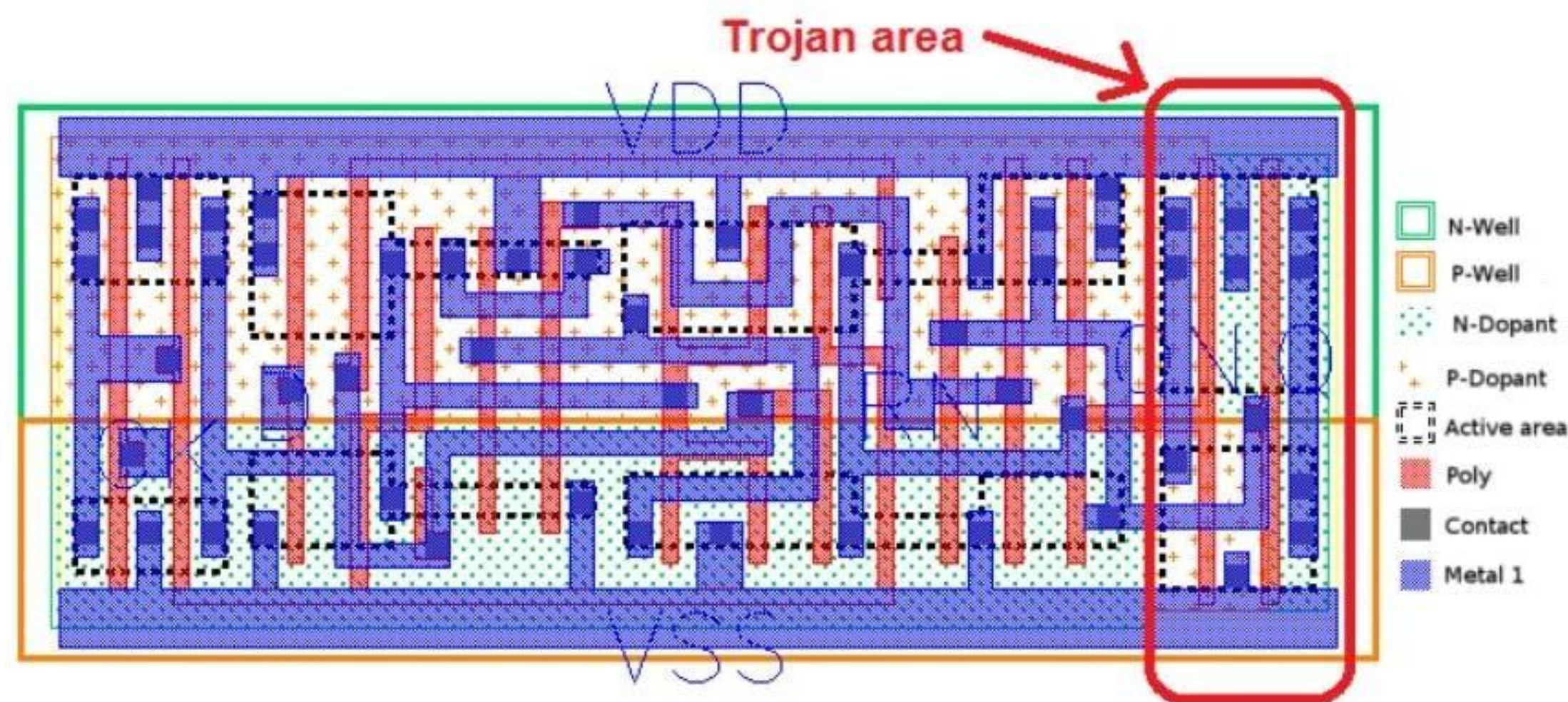
**After repair**





# What Can you Do with Mask Editing?

- Example: Dopant Tampering
  - No morphological change
  - Circuit-level behavioral change
- Spare cell rewiring
- Signal bypass

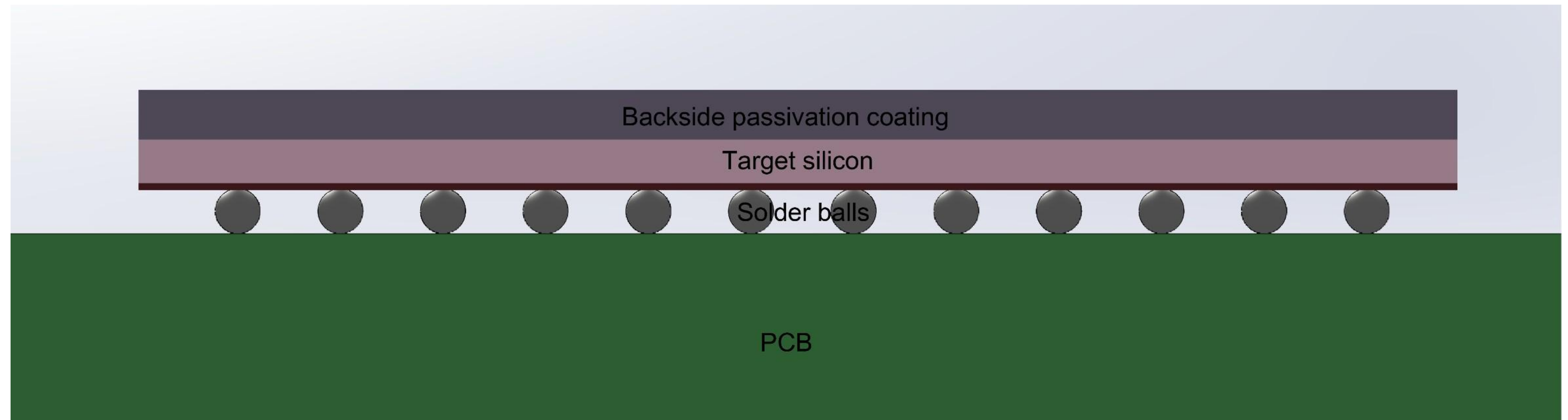


[http:// people.umass.edu/gbecker/BeckerChes13.pdf](http://people.umass.edu/gbecker/BeckerChes13.pdf)

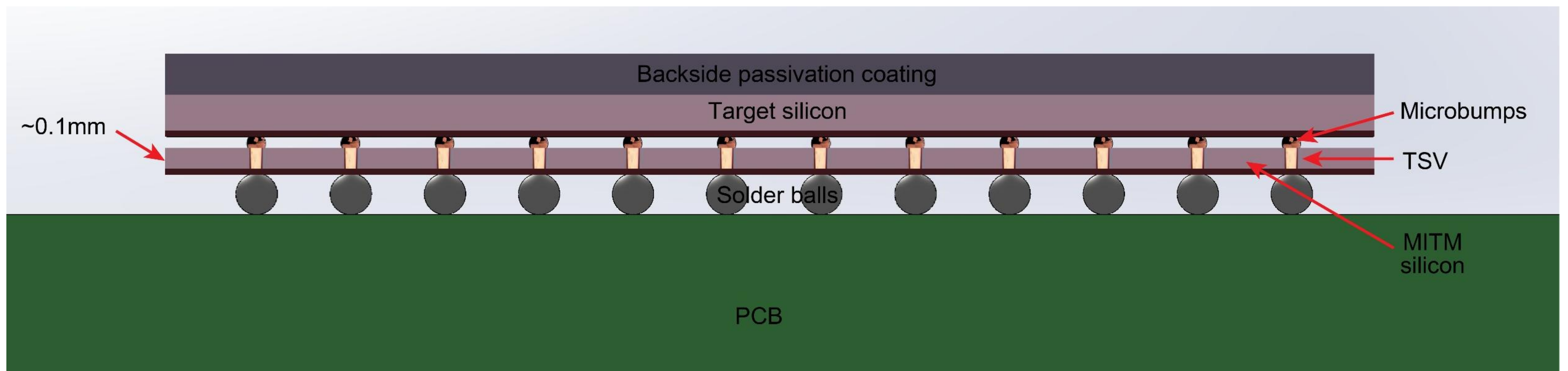


# TSV + WLCSP Implants

Unmodified

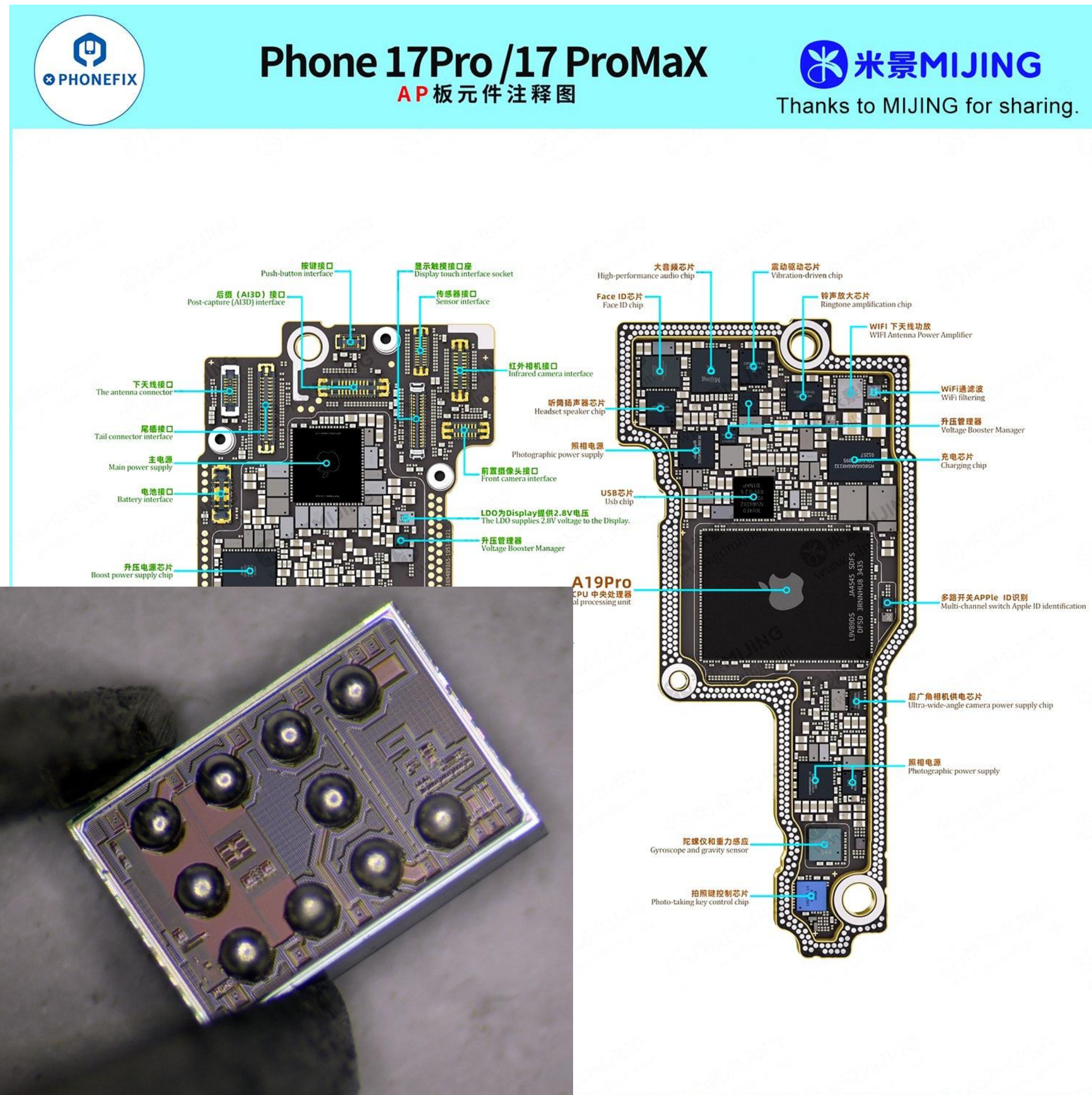


With TSV  
implant





# Concept: WLCSP



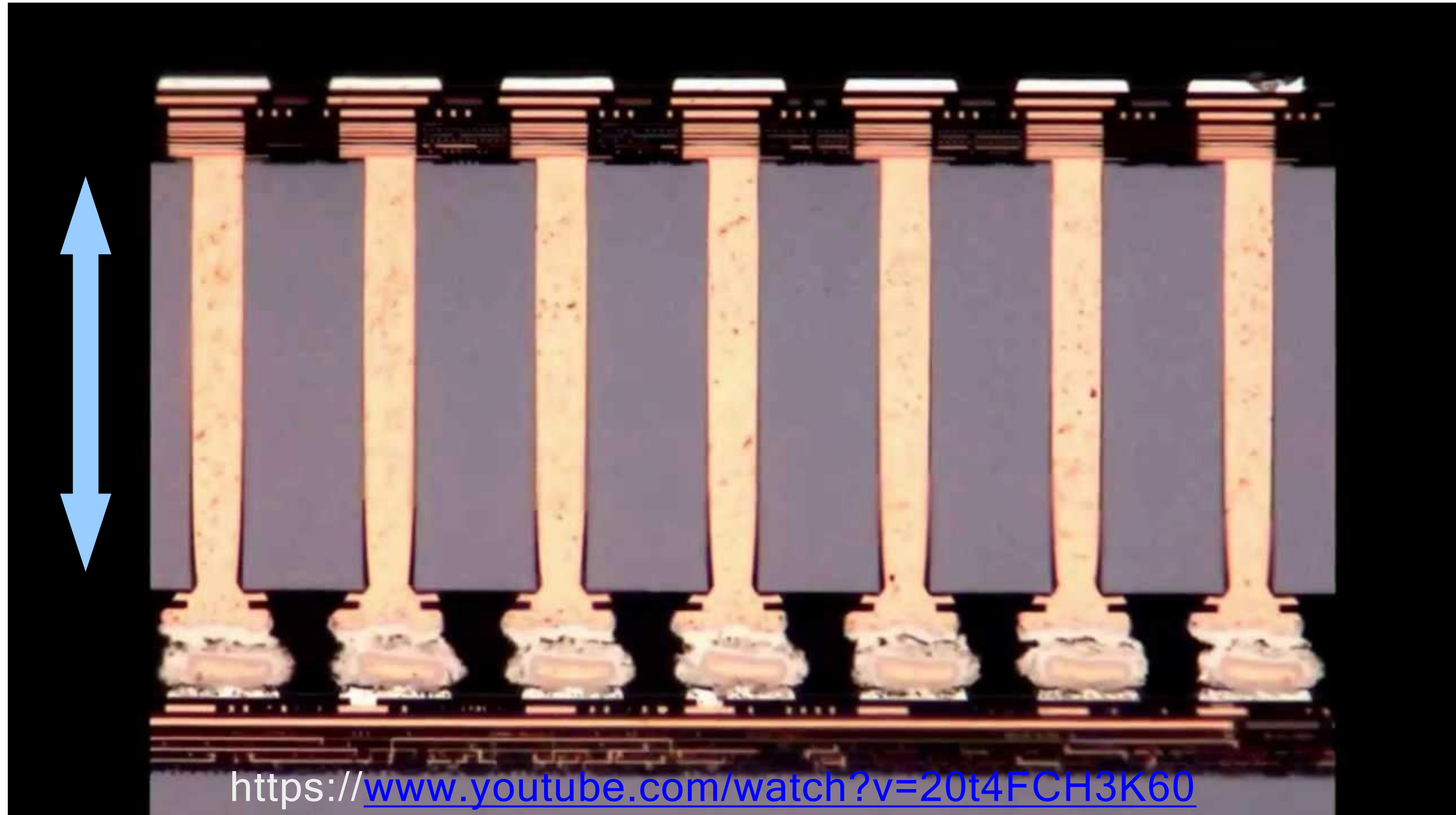
- Sold as "almost naked silicon"
- Direct chip-to-board solderballs
- Sold as "Ready to Hack"

Wafer  
Level  
Chip  
Scale  
Package



# Concept: Through-Silicon Via "Mature" Tech (Used in HBM RAM)

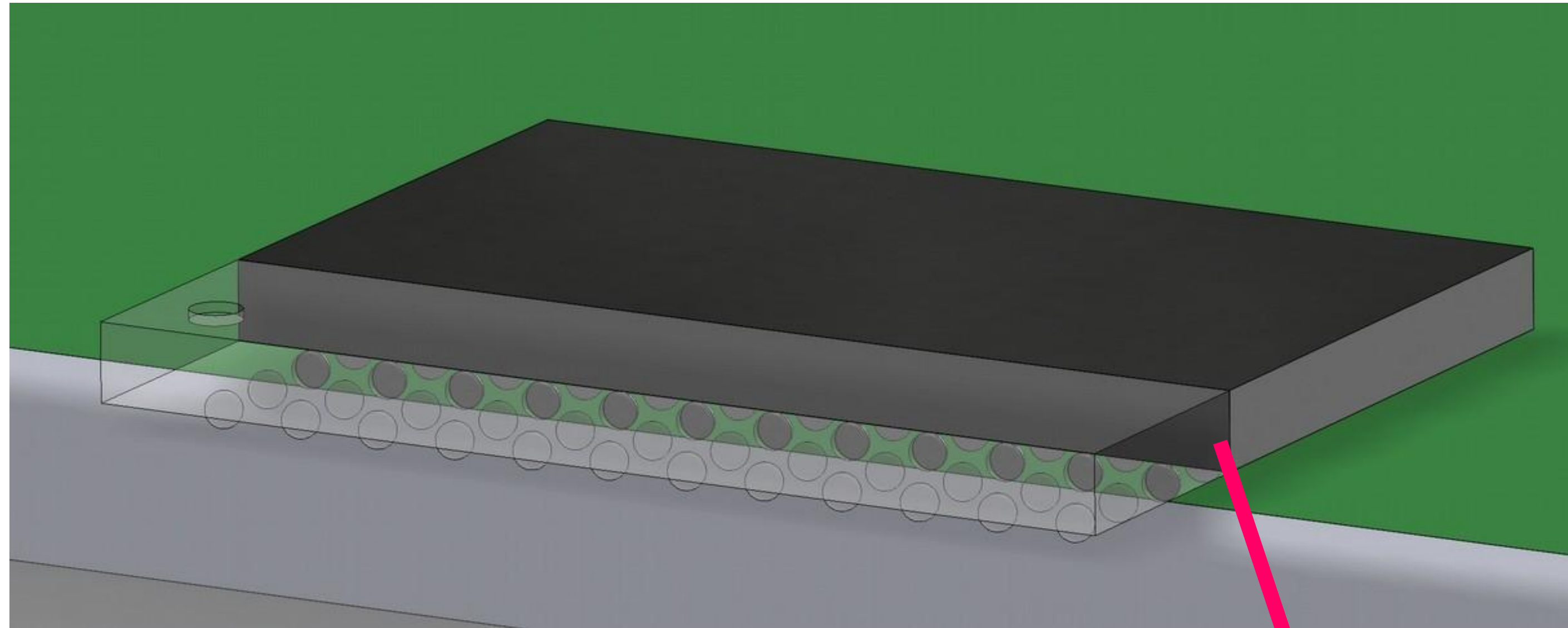
0.1-  
0.2mm



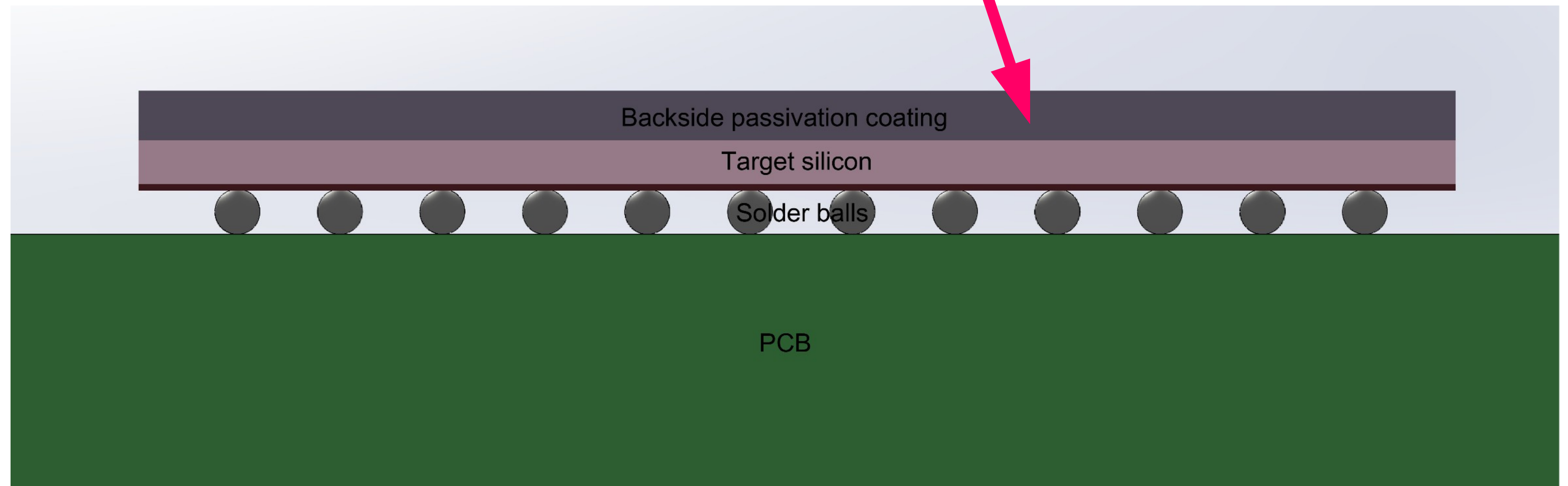


# WLCSP Cross Section

3D view



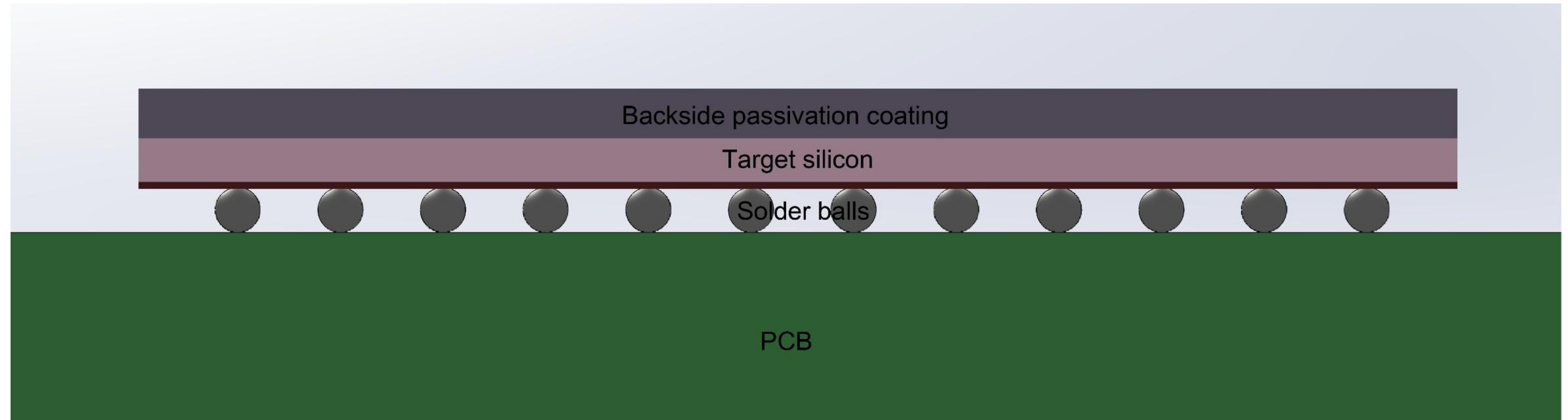
Cross  
section



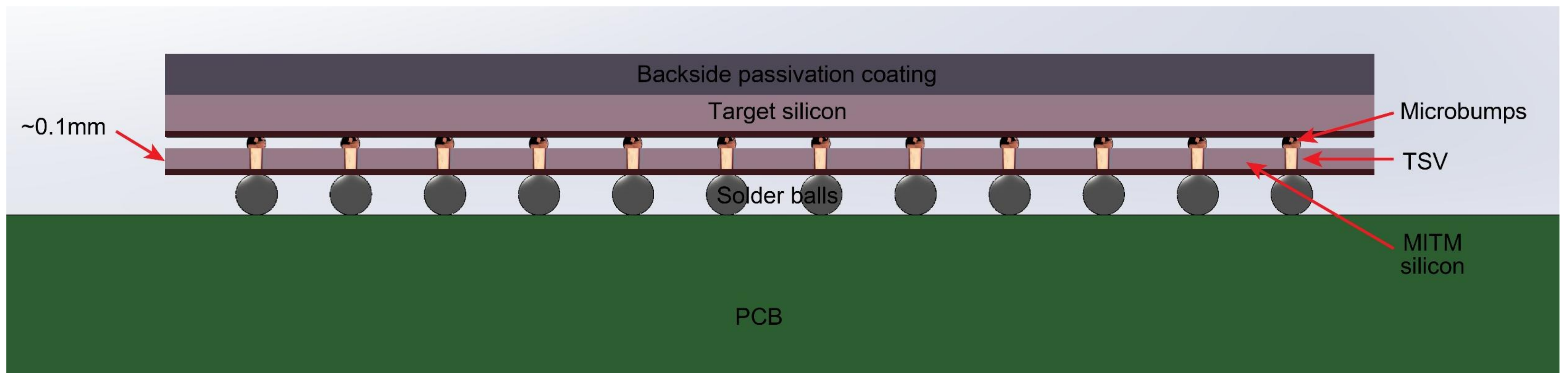


# TSV + WLCSP = Nearly Undetectable Implant

Unmodified



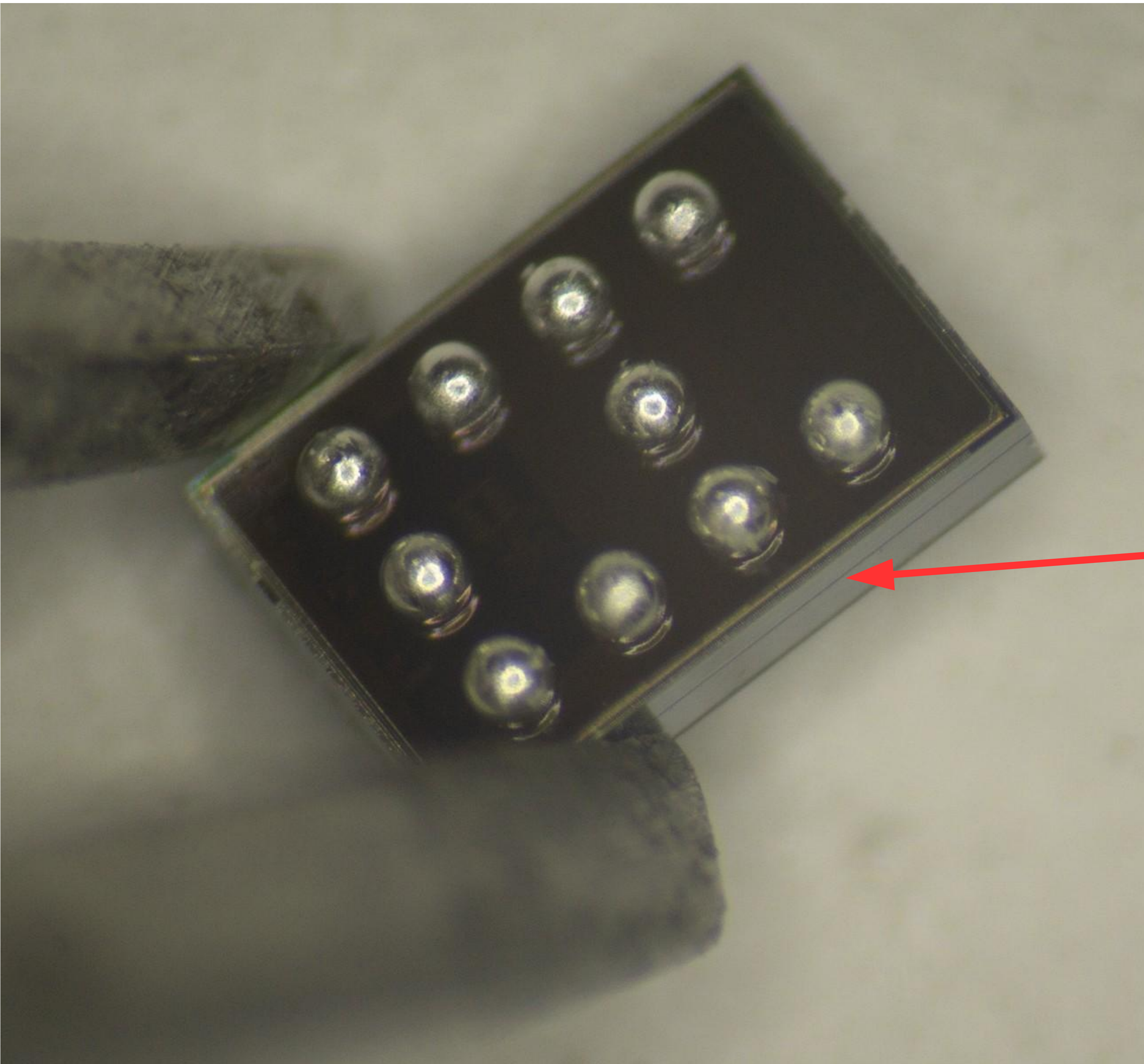
With TSV  
implant





# Threat & Mitigation

- Scalable
  - Targets off-the-shelf chips
  - No decap / debond
- Hard to detect
  - Many WLCSP already have a small seam
  - No X-ray footprint
- Mitigation:
  - TSV templates are "expensive" (\$100k's)
  - But modern attacks (e.g.,) Pegasus is even more expensive (\$1mm+)...

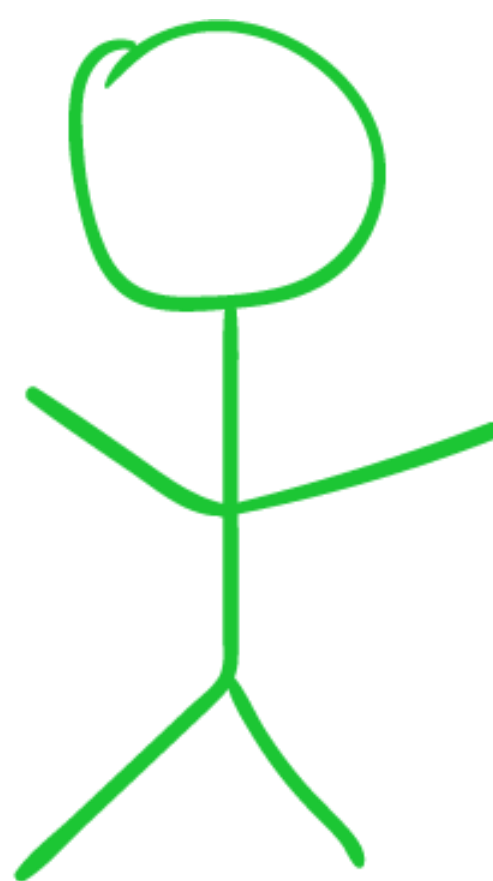




# Execution of Supply Chain Attacks:

## The Attack Surface





**you**



# We're Not Going to Talk about "Evil Maids" (But They are Also Real)





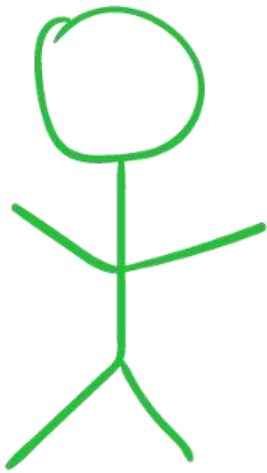
**distributor**



**courier**



**"evil maid"**



**you**

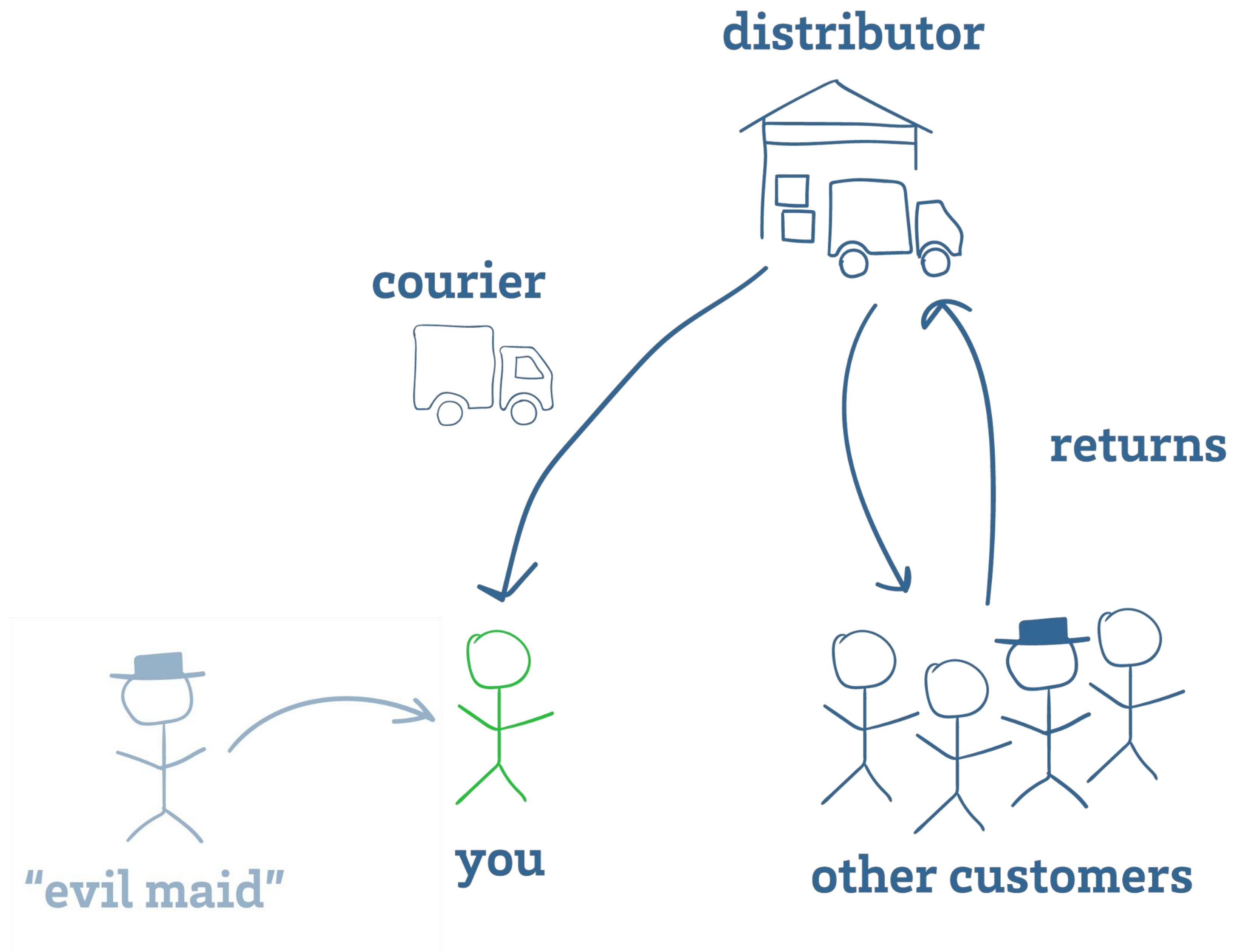




(TS//SI//NF) Left: Intercepted packages are opened carefully; Right: A “load station” implants a beacon

[https:// arstechnica.com/tech-policy/2014/05/photos-of-an-nsa-upgrade-factory-show-cisco-router-getting-implant/](https://arstechnica.com/tech-policy/2014/05/photos-of-an-nsa-upgrade-factory-show-cisco-router-getting-implant/)







# Everyday Hacks for Everyday People Targets

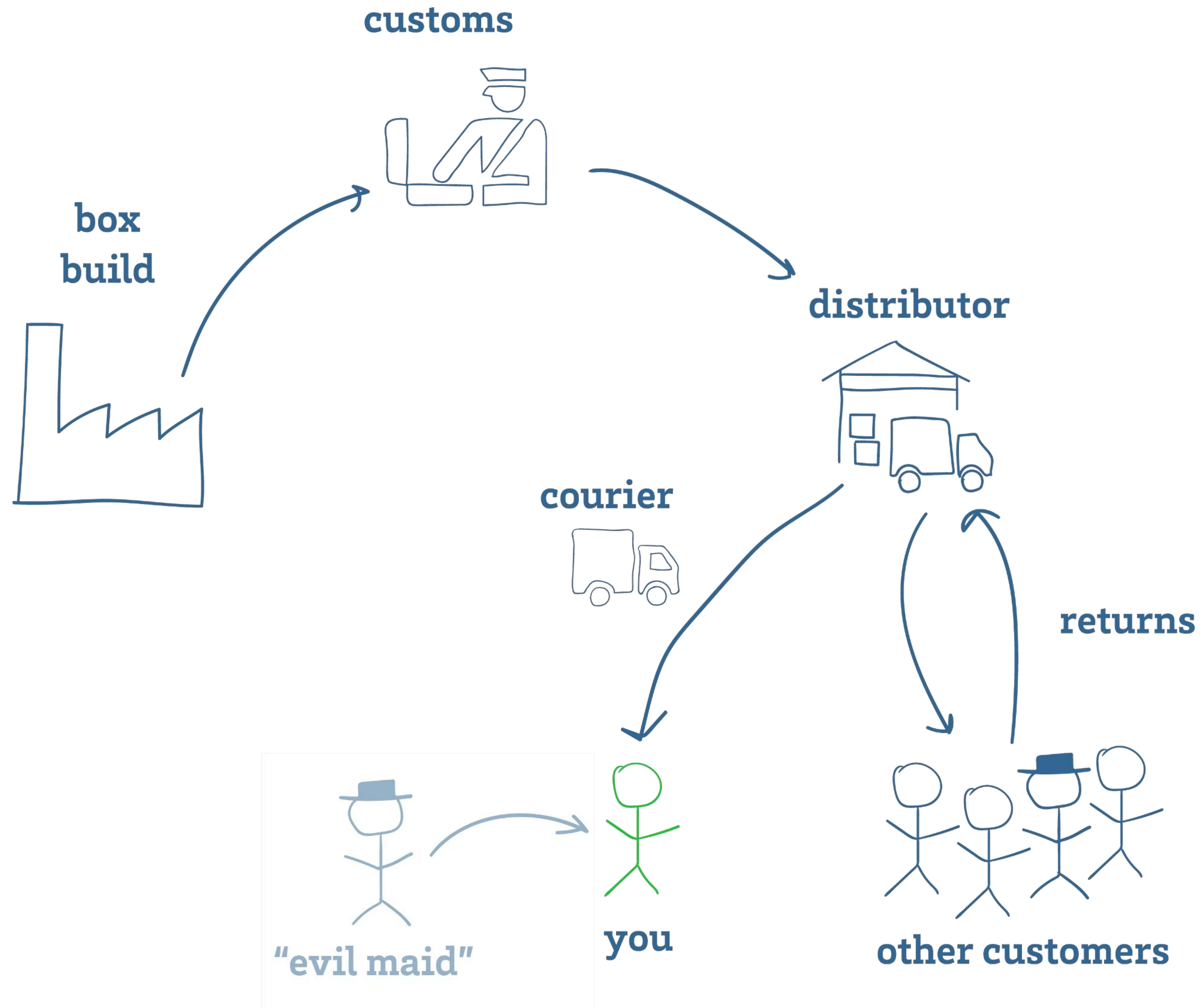
- DIY supply chain attack:
  - Buy item online
  - Hack it
  - Return it to warehouse
  - ???
  - Profit!



## First try: Before and After

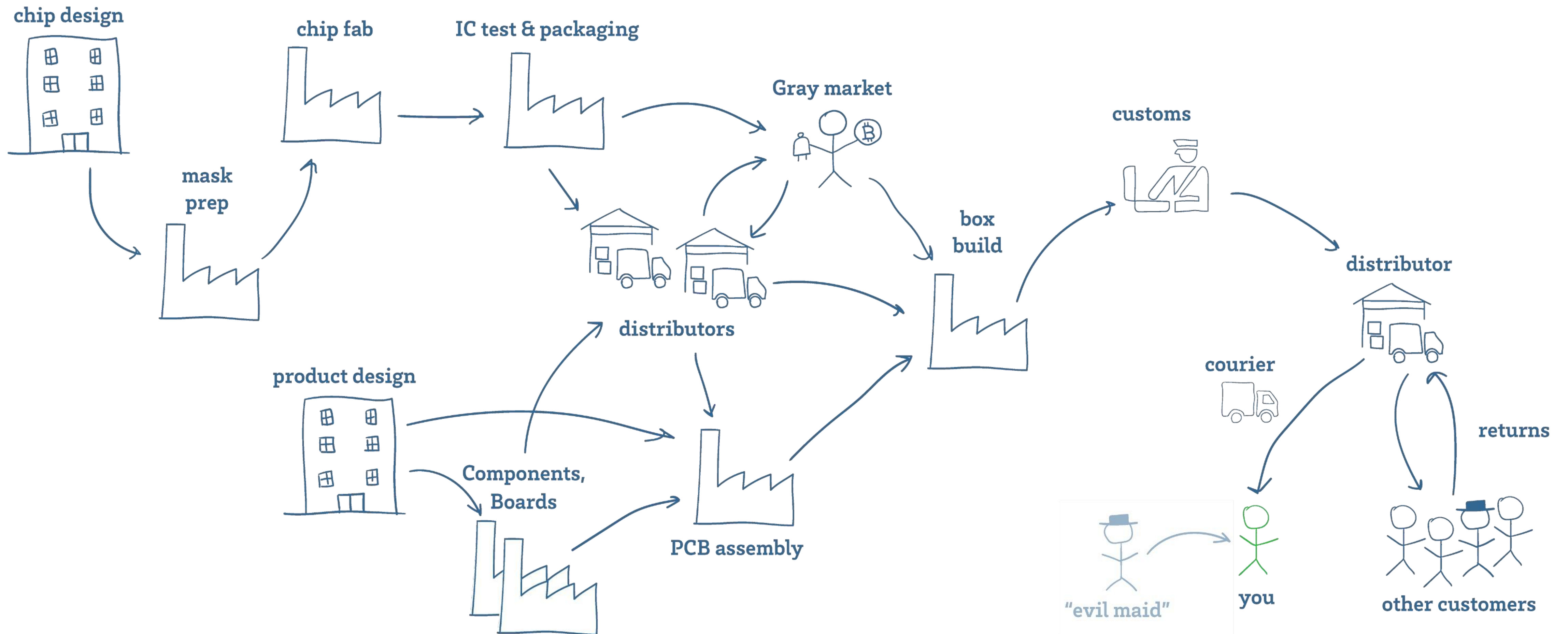








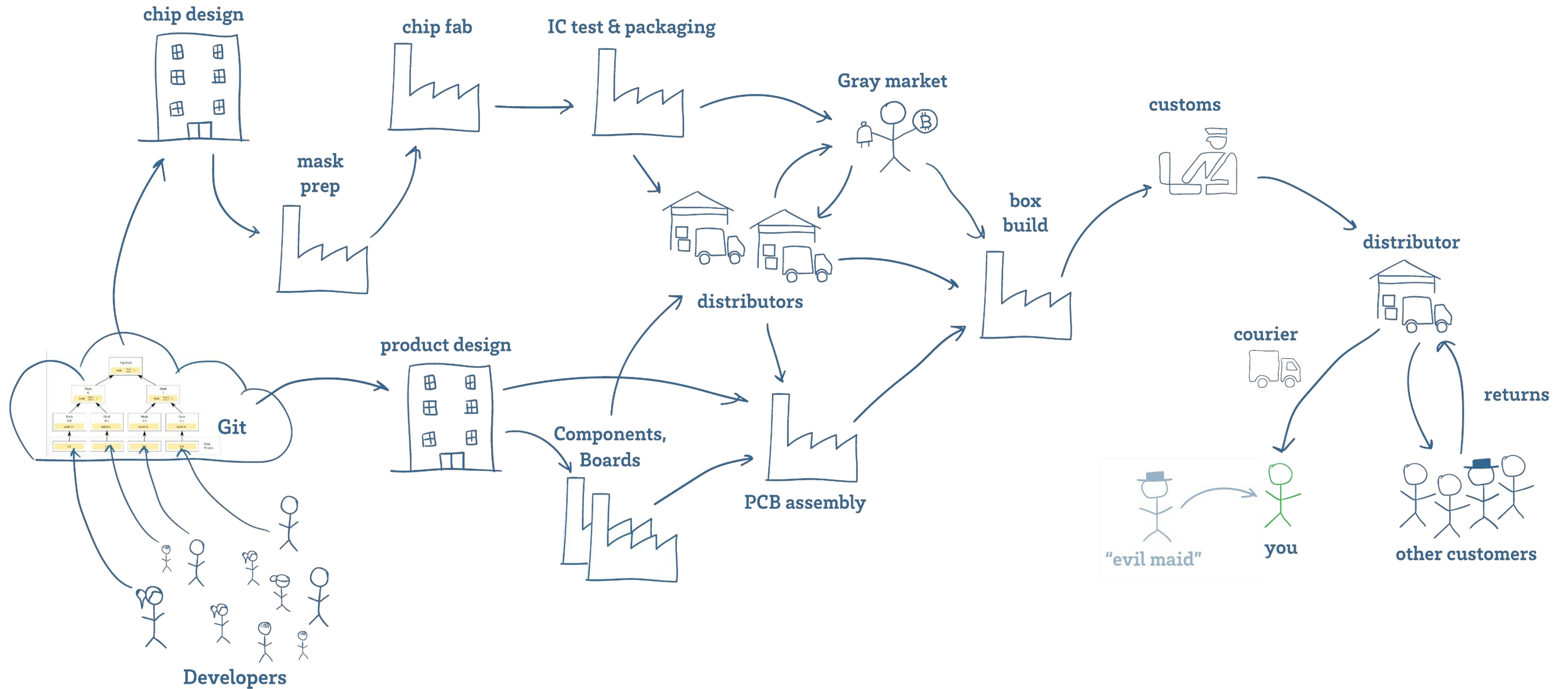
# It's a Big Attack Surface





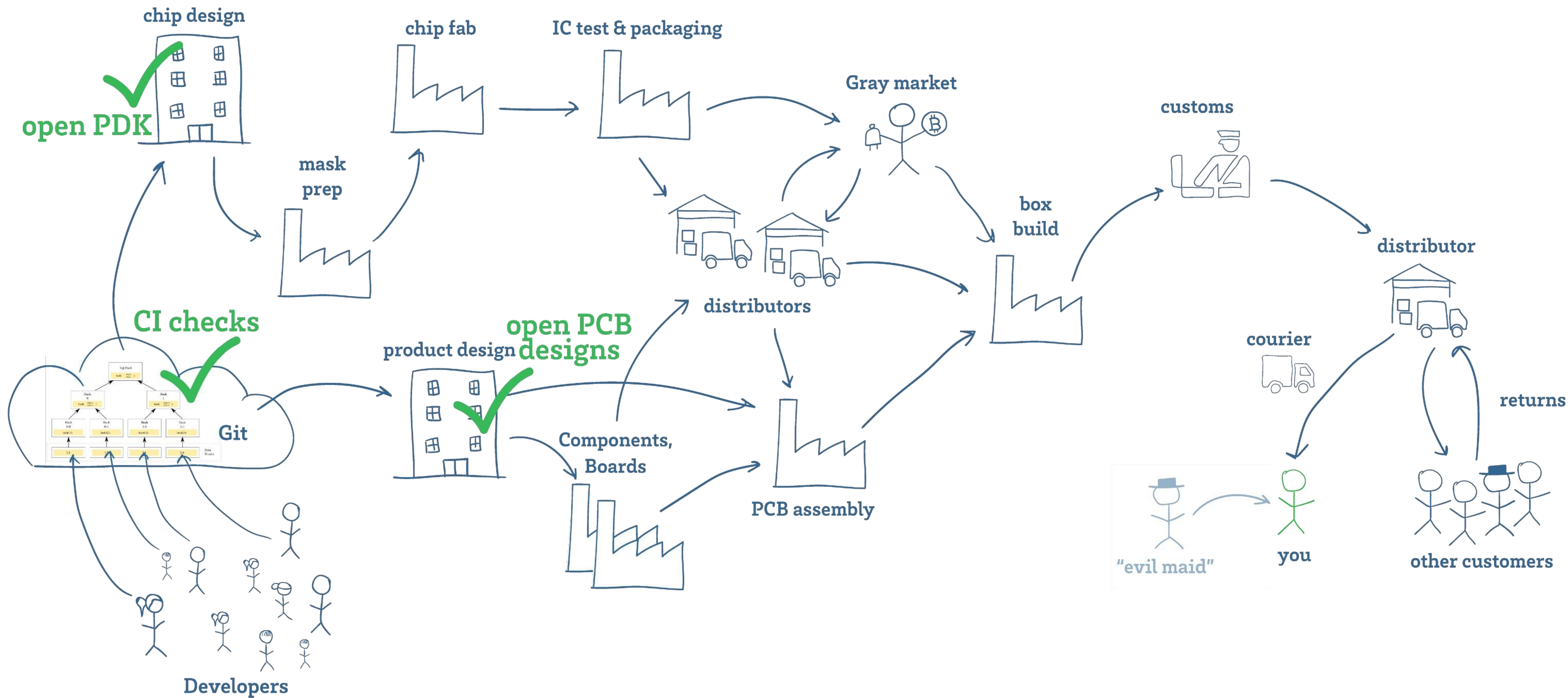
What Can We Do About It?

# Can Open Source Save Us?

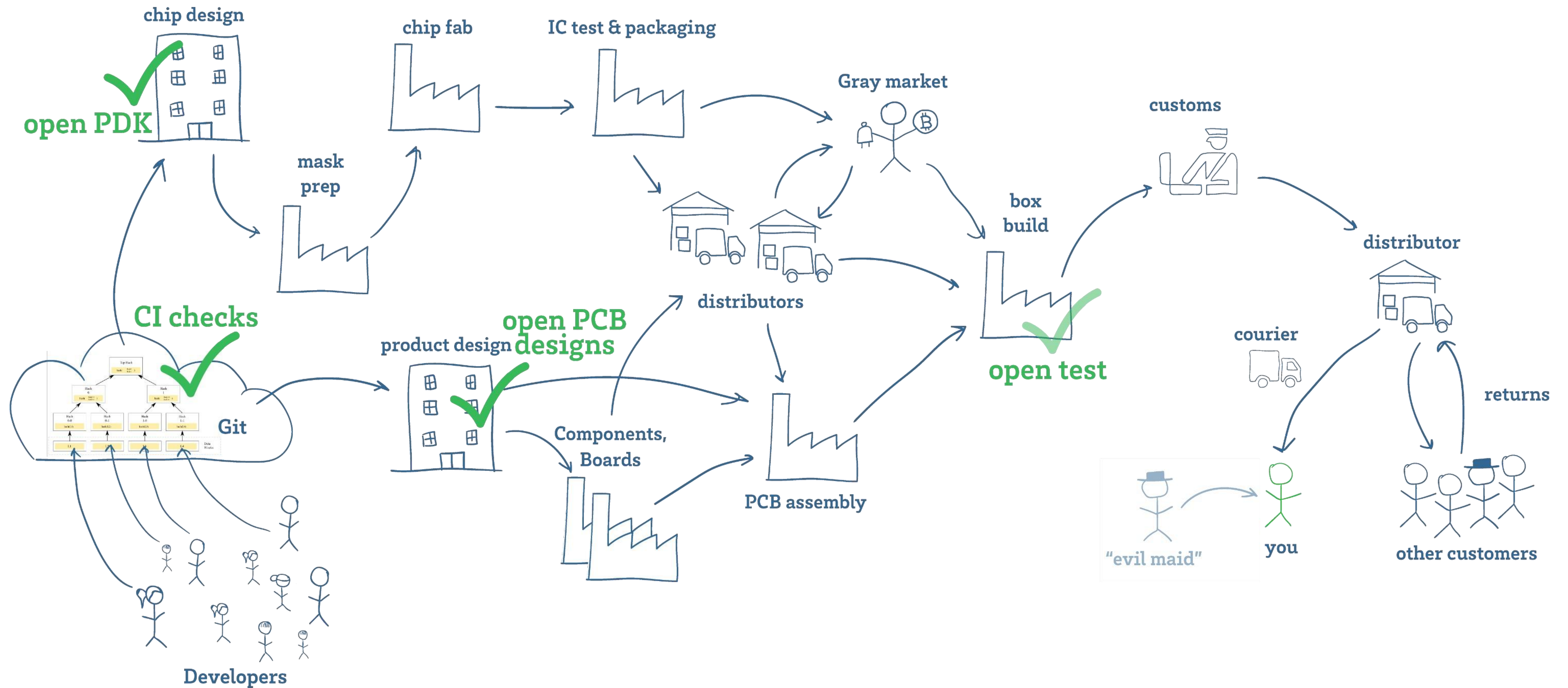




# Problem: Place of Check Too far from Place of Use



# Open Factory Test (Trustable Factory) Is Only a Marginal Improvement





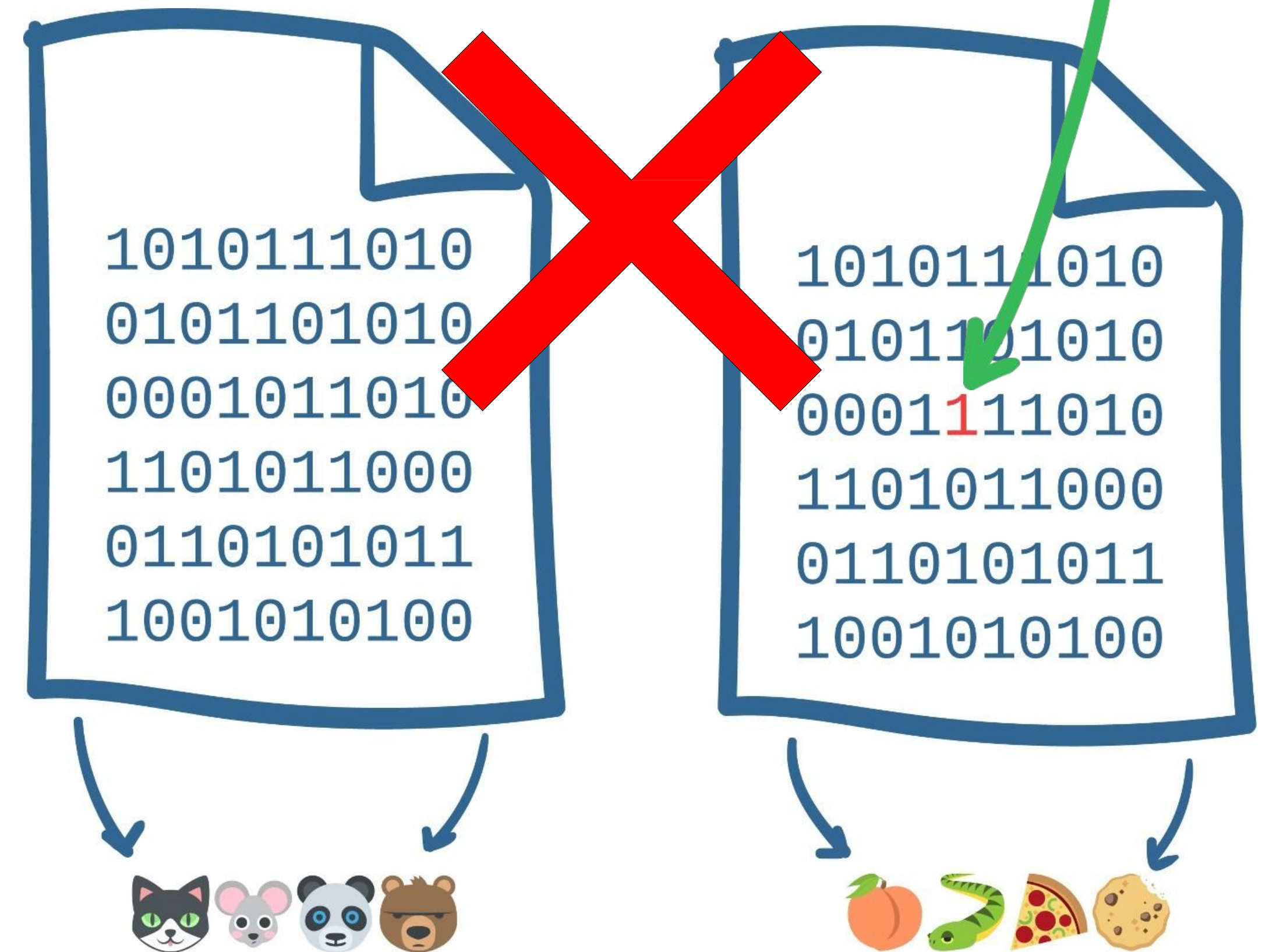
# What, Then Is the Role of Open Source in Trustable Hardware?

- Design Correctness
  - Peer review can find bugs
  - SPECTRE hardening
    - Microarchitectural state modeling in compilers
    - Potential for provably correct compiler mitigations



# The Big Problem: You Can't "Hash" Hardware

- There is no convenient, easy-to-use method to confirm the correctness of hardware immediately before its use
- Hardware is one big "Time of Check versus Time of Use" (TOCTOU) problem!

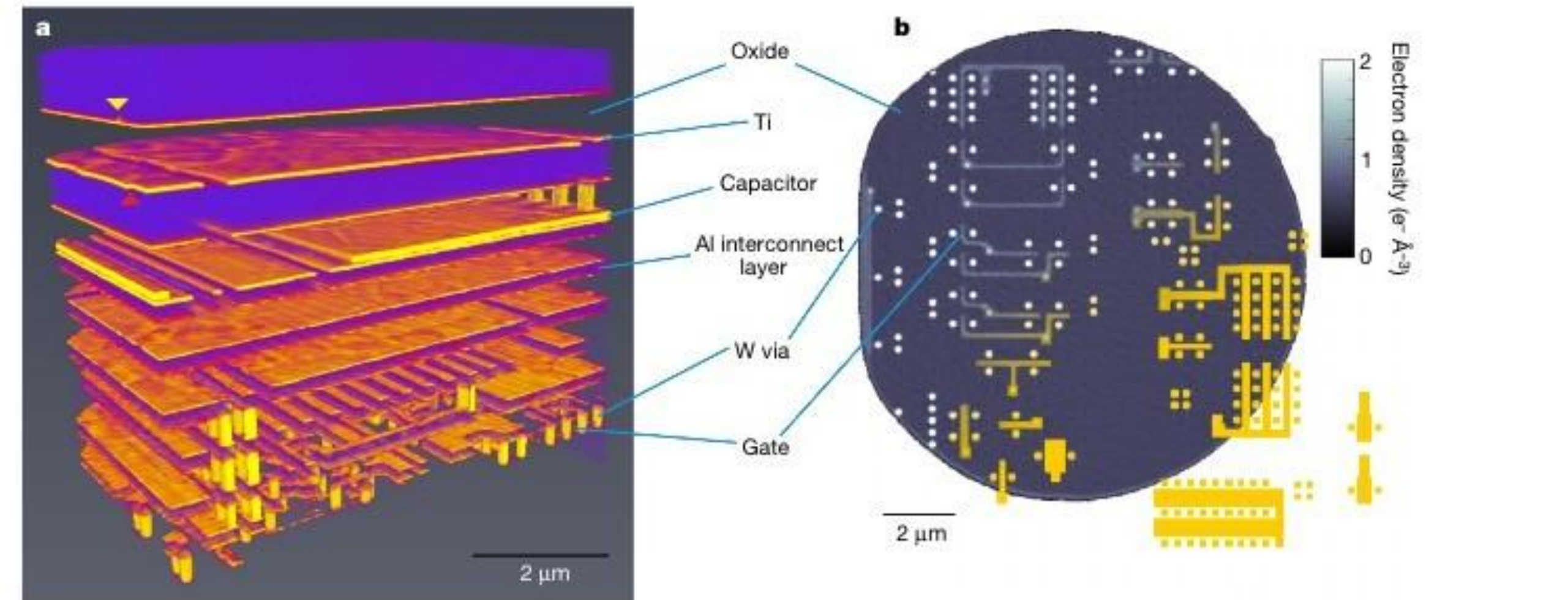




# But You Once Said:

## "There's Always a Bigger Microscope..."

- "Ptychographic X-Ray Imaging" to the rescue?
  - Non-destructive
  - 3D imaging of complex chips
  - Great for reverse engineering and design verification



**Figure 2 | PXCT of detector ASIC chip.** **a**, 3D rendering of the PCXT tomogram with identified elements. The yellow triangle indicates a manufacturing fault in the Ti layer. The Al layer in the region of the red triangle shows variances in thickness causing a waviness of the Ti layer

on top. Via, through-layer connector. **b**, Axial section across the second lowest layer, which contains the transistor gates; the grey scale (top right) represents electron density (in  $e^- \text{ \AA}^{-3}$ ). The corresponding layer from the design file is shown as the partial overlay in yellow.

<https://www.nature.com/articles/nature21698>



# Problem #1: A Building-Sized Microscope



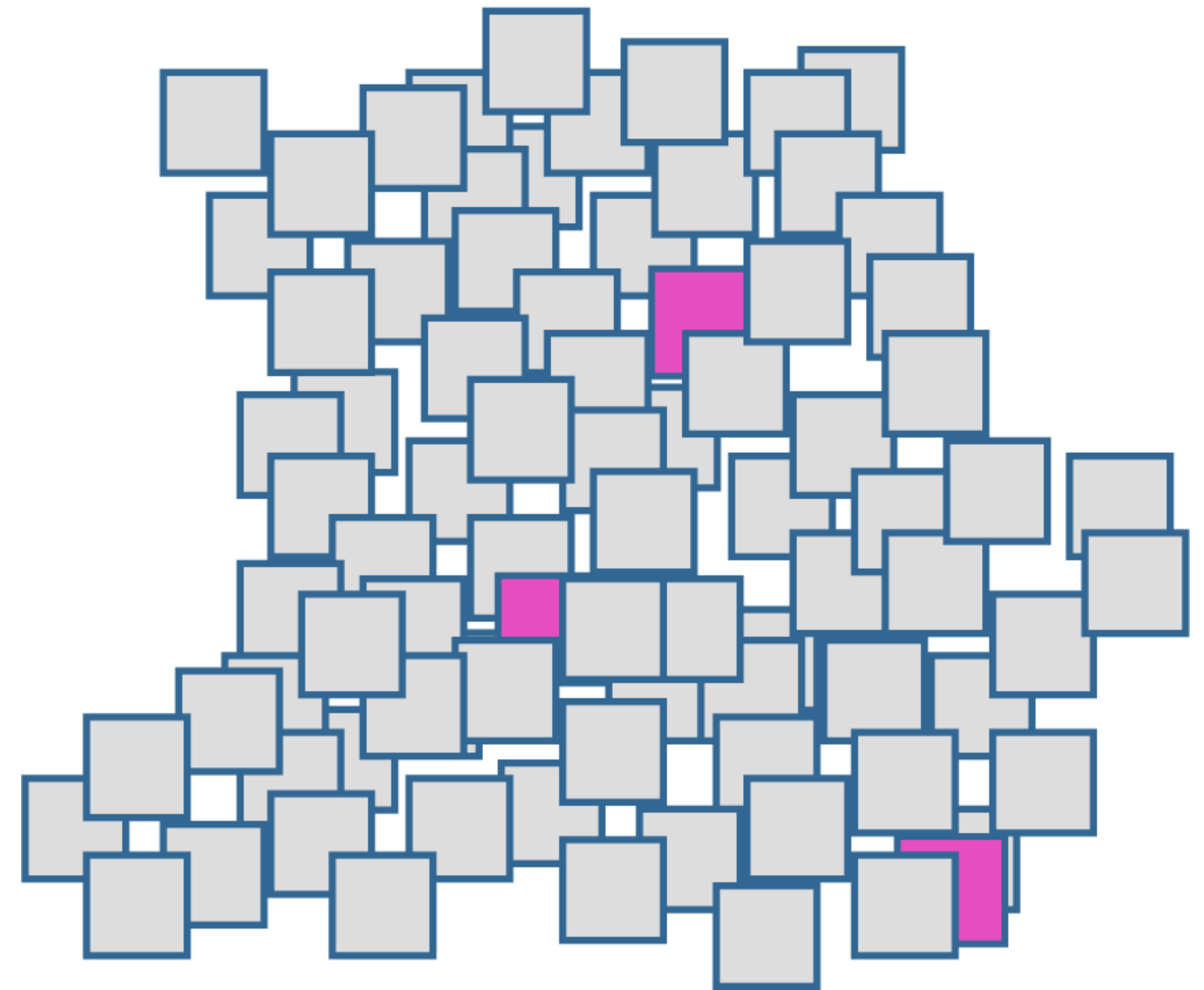
<https://www.psi.ch/en/sls/about-sls>



# Problem #2:

## Verifying One Chip Verifies Only One Chip

- Just because 99.9% of your hardware is OK...
  - Doesn't mean you are safe
  - One compromised server out of thousands is all it takes
- Random sampling is not effective
  - Would you "random sample" signature checks on downloaded software?



# Can We Build an Evidence-Based Case To Trust Our Computers?



TOP SECRET//COMINT//REL TO USA, FVEY

## COTTONMOUTH-I

## ANT Product Data

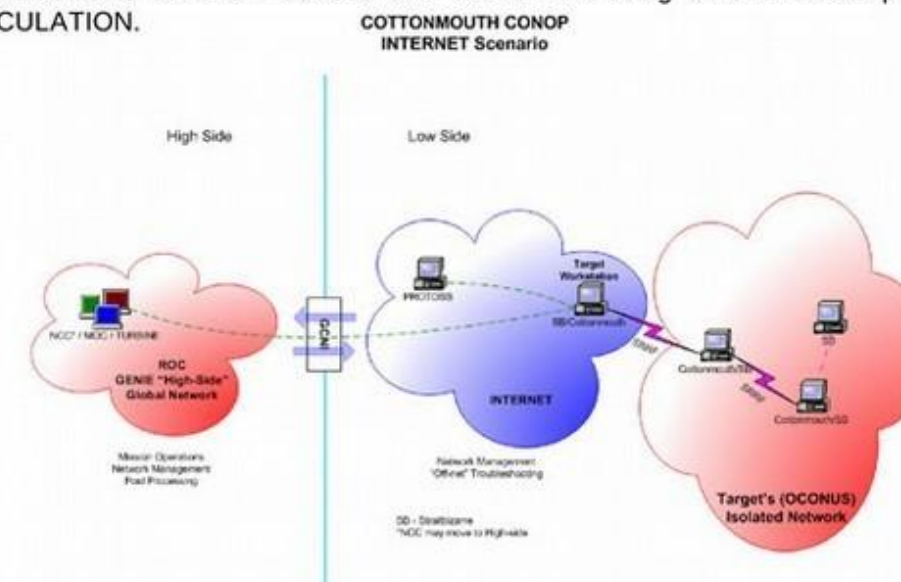
**(TS//SI//REL)** COTTONMOUTH-I (CM-I) is a Universal Serial Bus (USB) hardware implant which will provide a wireless bridge into a target network as well as the ability to load exploit software onto target PCs.

08/05/08



**(TS//SI//REL)** CM-I will provide air-gap bridging, software persistence capability, "in-field" re-programmability, and covert communications with a host software implant over the USB. The RF link will enable command and data infiltration and exfiltration. CM-I will also communicate with Data Network Technologies (DNT) software (STRAITBIZARRE) through a covert channel implemented on the USB, using this communication channel to pass commands and data between hardware and software implants. CM-I will be a GENIE-compliant implant based on CHIMNEYPOOL.

(TS//SI//REL) CM-I conceals digital components (TRINITY), USB 1.1 FS hub, switches, and HOWLERMONKEY (HM) RF Transceiver within the USB Series-A cable connector. MOCCASIN is the version permanently connected to a USB keyboard. Another version can be made with an unmodified USB connector at the other end. CM-I has the ability to communicate to other CM devices over the RF link using an over-the-air protocol called SPECULATION.



**Status:** Availability – January 2009

**Unit Cost:** 50 units: \$1,015K

POC: [REDACTED], S3223, [REDACTED], [REDACTED]@nsa.ic.gov  
ALT POC: [REDACTED], S3223, [REDACTED], [REDACTED]@nsa.ic.gov

Derived From: NSA/CSSM 1-52  
Dated: 20070108  
Declassify On: 20320108

TOP SECRET//COMINT//REL TO USA, FVEY



# Three Principles For Evidence-Based Trust in Hardware

- 1) Complexity is the enemy of verification
- 2) Verify entire systems, not just components
- 3) Empower end-users to verify and seal their hardware

# Problem: Complexity is Complicated

- Absent a robust "hashing" function, verification falls back to bit-by-bit...or "atom-by-atom"
- More complexity ->
  - More difficult to verify
  - More places to hide things
  - Verification might be **destructive**



via iFixit



# Point of Use Verification Tradeoff: Ease of Verification vs. Features & Usability



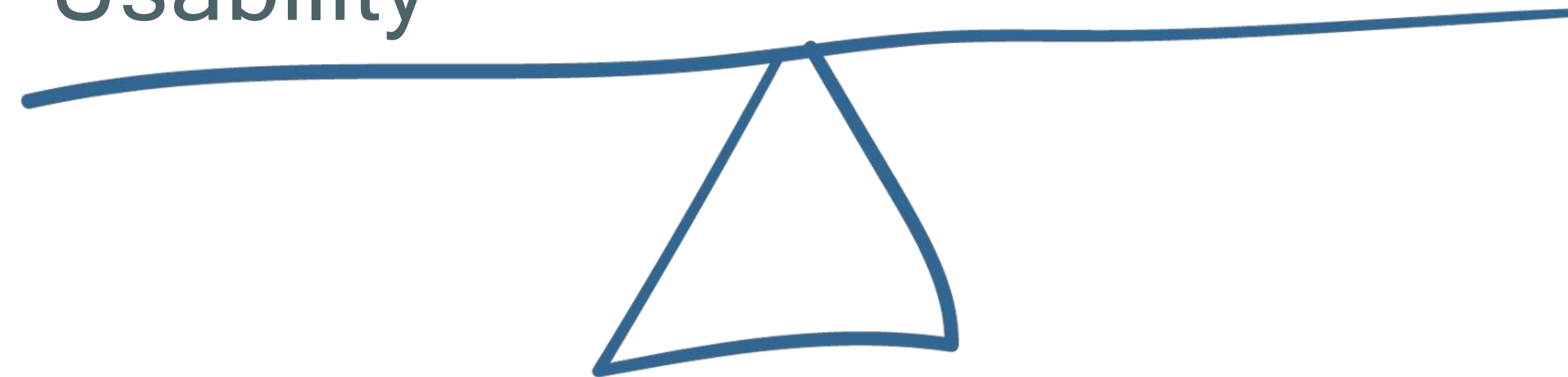
>10<sup>7</sup> transistors

Features &  
Usability



Ease of  
verification

1 transistor



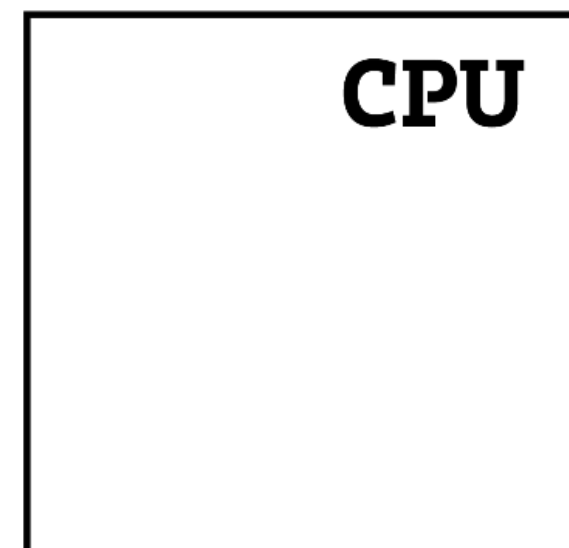
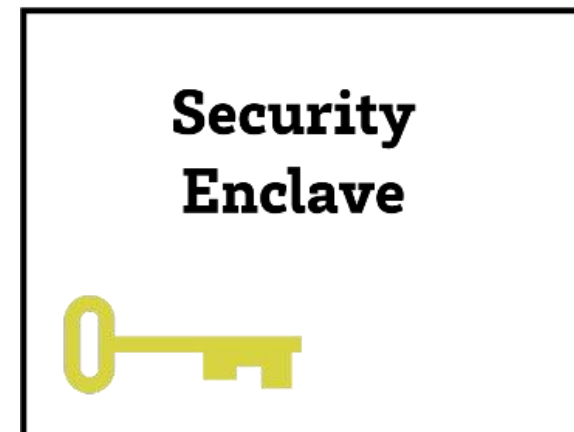
# Three Principles For Evidence-Based Trust in Hardware

- 1) Complexity is the enemy of verification
- 2) Verify entire systems, not just components
- 3) Empower end-users to verify and seal their hardware



# Why a Device, and Not a Chip?

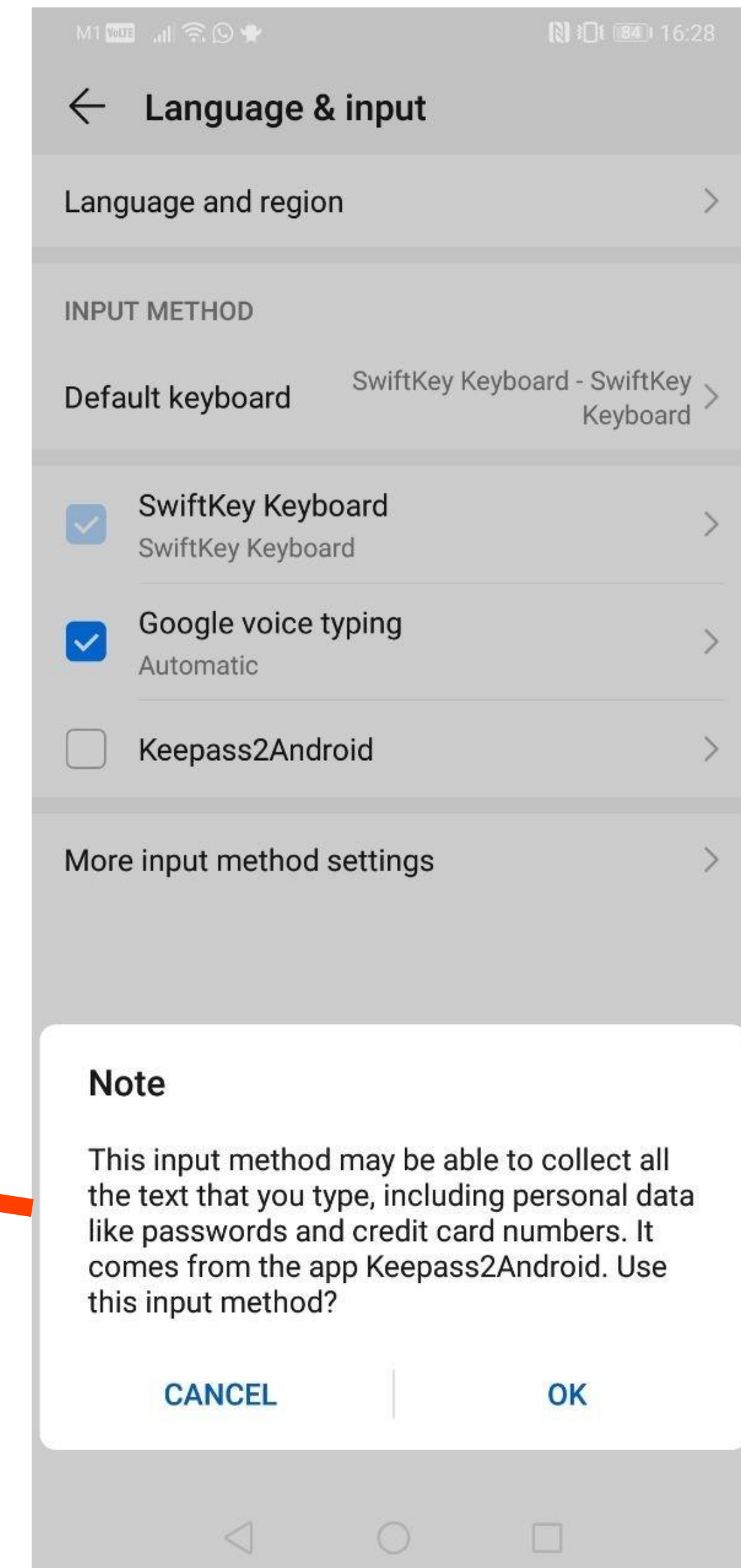
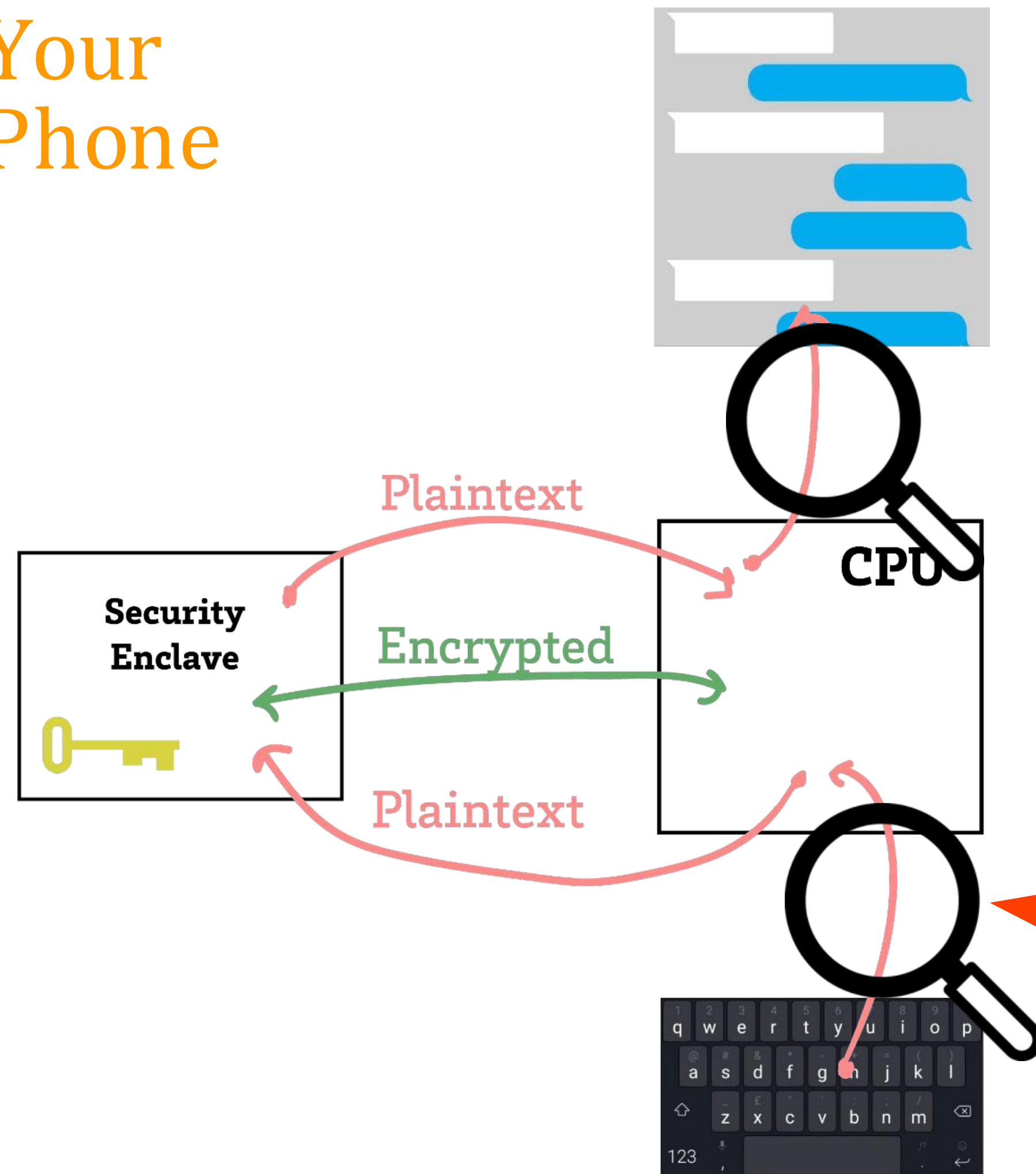
Your  
Phone



- Private keys are not your private matters
  - Screens can be scraped, keyboards can be logged

# The "IME Problem"

Your Phone





# The "IME Problem"

Your  
Phone

Secret  
Encryption



## Note

This input method may be able to collect all the text that you type, including personal data like passwords and credit card numbers. It comes from the app Keepass2Android. Use this input method?

CANCEL

OK

16:28

- SwiftKey  
Keyboard

ollect all  
onal data  
bers. It  
oid. Use

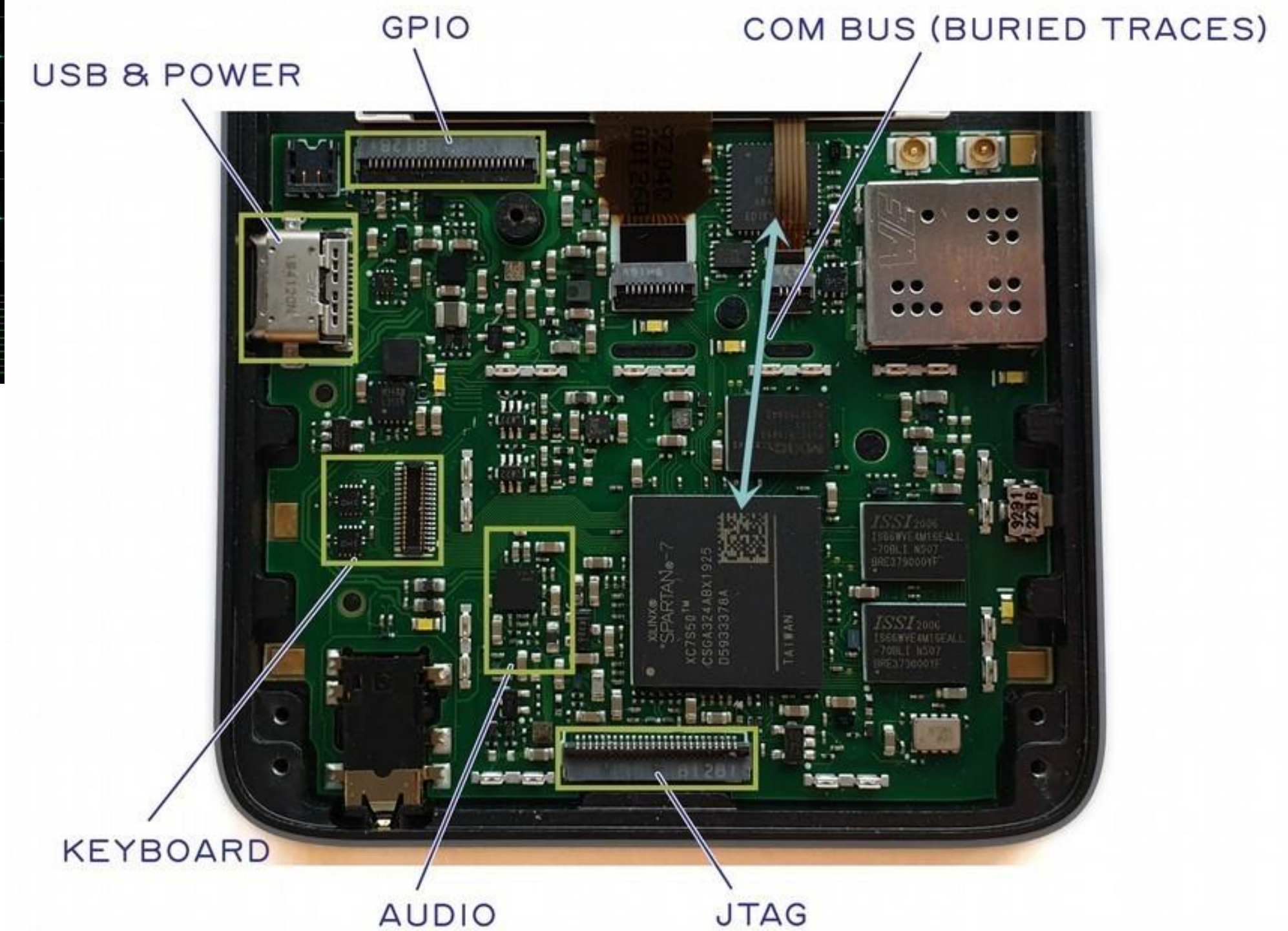
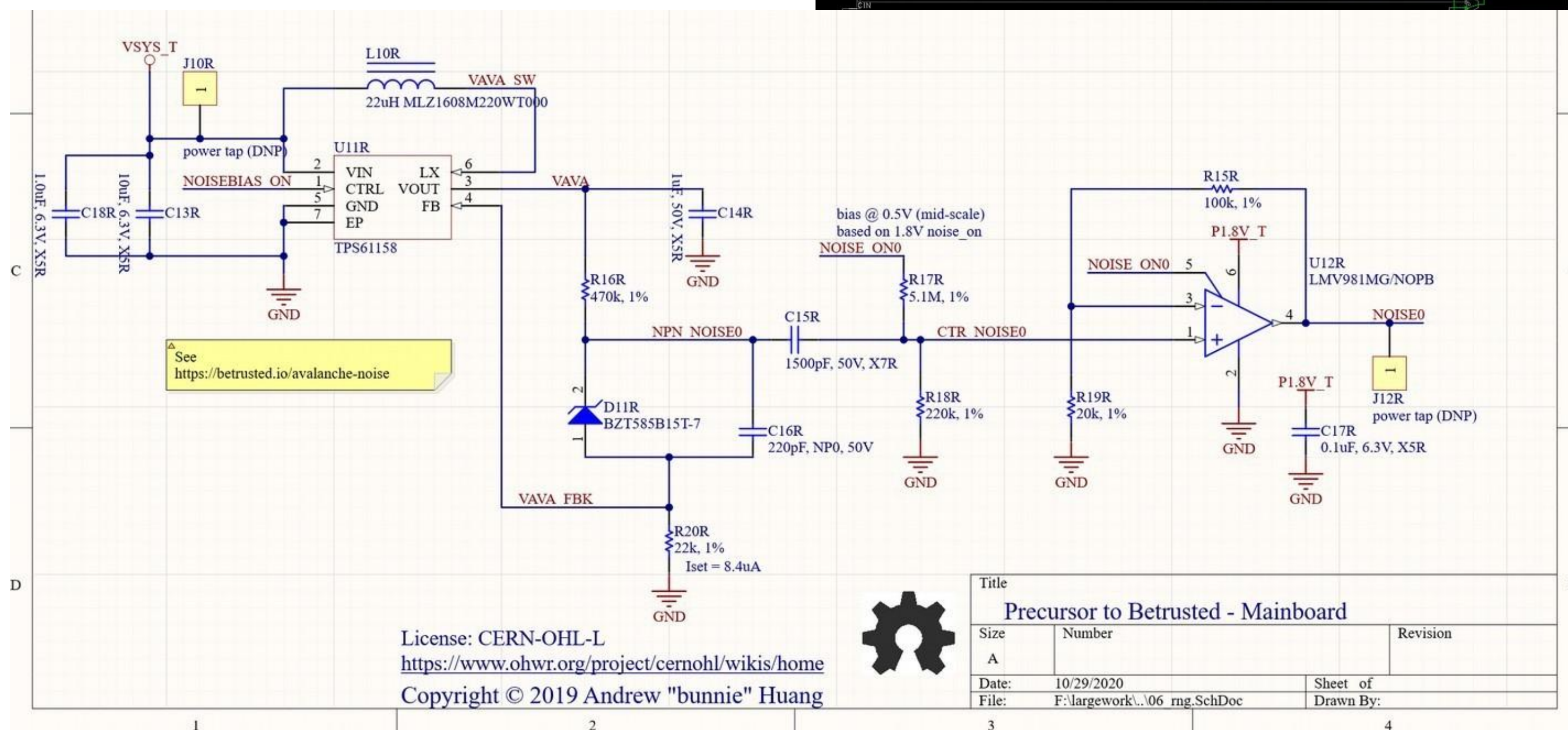
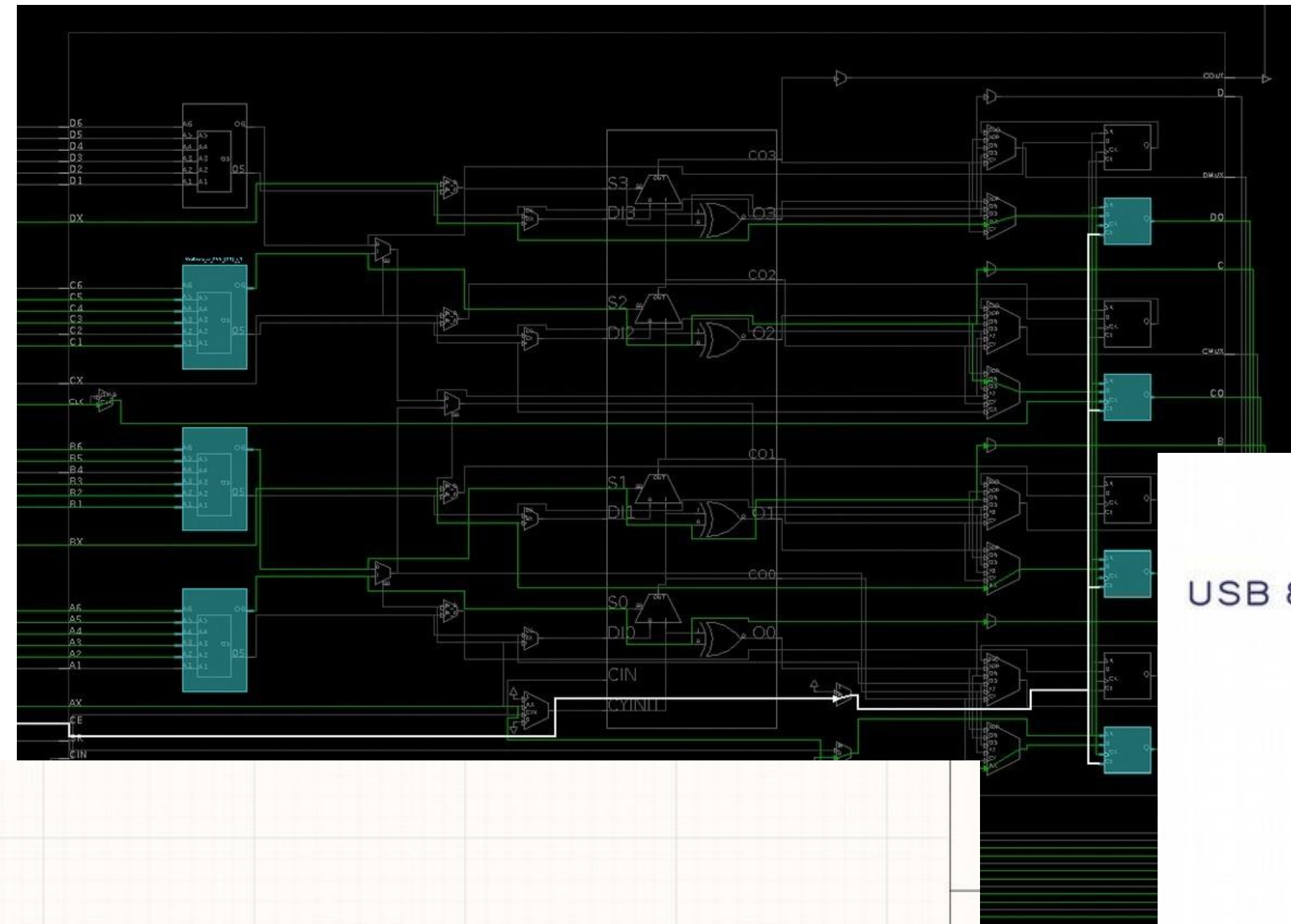
K

# Three Principles For Evidence-Based Trust in Hardware

- 1) Complexity is the enemy of verification
- 2) Verify entire systems, not just components
- 3) Empower end-users to verify and seal their hardware



# Empower Verification At Multiple Levels





# Precursor: A Case Study in Verifiable Hardware

- Designed to facilitate **evidence-based trust**
  - Simple in construction
  - Open in design
  - Sufficient in function



PRECURSOR





# Precursor: What Functions?

- Designed for mostly single-app deployments of:
  - Secure text messaging
  - Voice chat
  - Multi-lingual capability
  - Password management
  - Crypto wallet
- Not designed for
  - Web browsing
  - Games
  - Photos and videos
- Specs:
  - 100MHz RV32IMAC + MMU + AES extensions
  - Curve25519 + SHA2 accel
  - 16MiB RAM
  - 536x336 "memory" LCD
  - USB + Wifi connectivity
  - Audio only via jack
  - Full-custom OS "Xous"
    - QNX-like microkernel, written in Rust

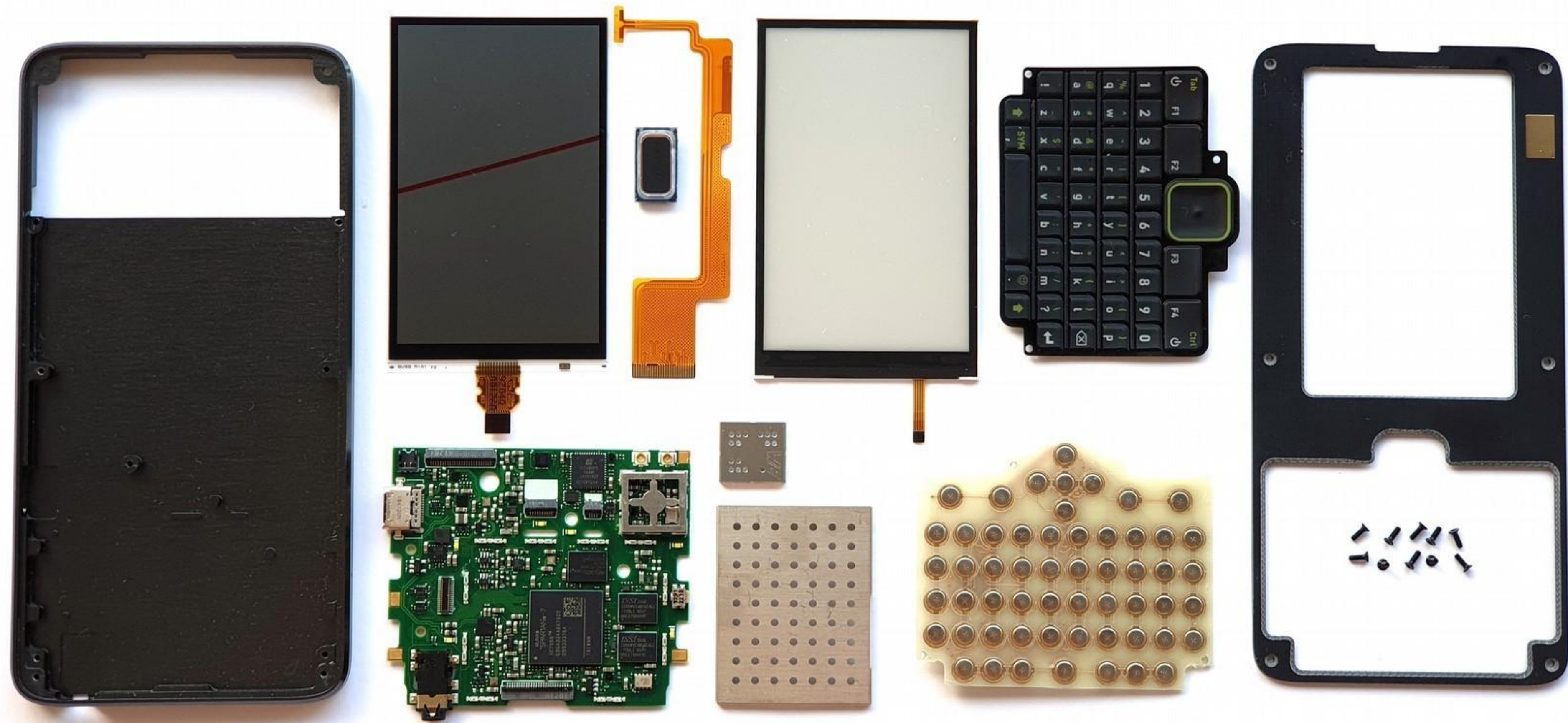


PRECURSOR



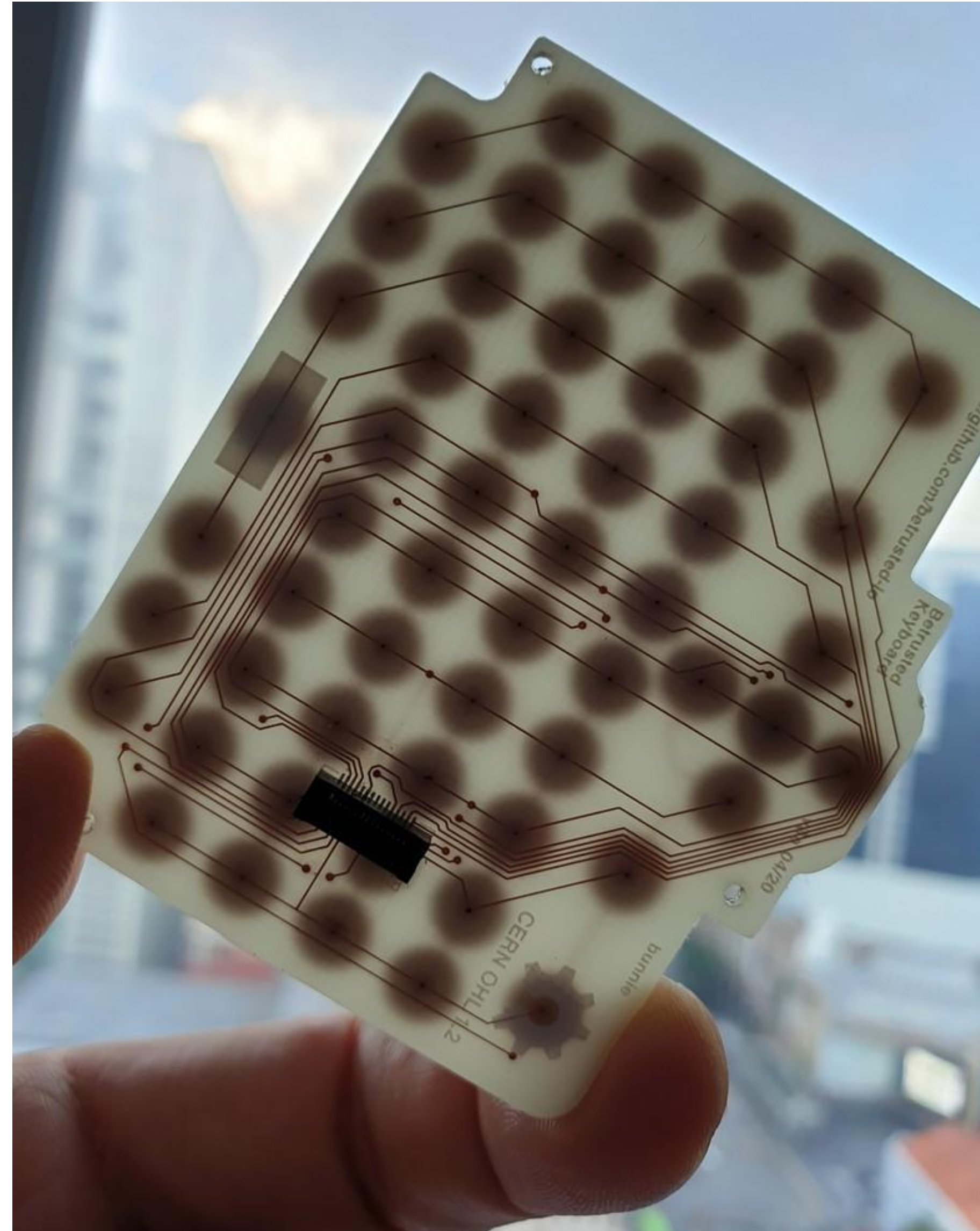


# Precursor: Simple in Construction





# Verification Difficulty: Trivial





# Touch Keyboard Verification: Very Hard

- Captouch screens require the use of a proprietary microcontroller with a firmware blob

## Features

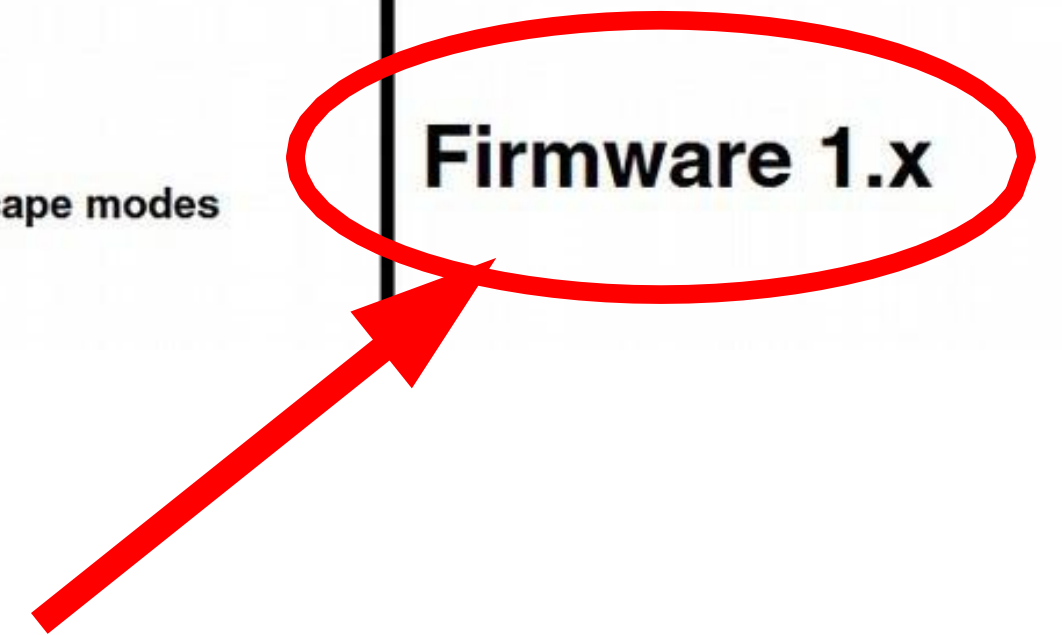
- Chip Set Configuration
  - One master mXT1386 device
  - Three slave mXT154 devices
- maXTouch™ Touchscreen
  - True 12-bit multiple touch reporting and real-time XY tracking for up to 16 concurrent touches per touchscreen
- Number of Channels
  - Electrode grid configurations of up to 33 X and 42 Y lines supported
  - Touchscreens up to 1386 channels (subject to other configurations)
  - Up to 64 channels can be allocated as fixed keys (subject to other configurations)
- Signal Processing
  - Advanced digital filtering using both hardware engine and firmware
  - Self-calibration
  - Auto drift compensation
  - Adjacent Key Suppression® (AKS®) technology
  - Grip suppression
  - Palm suppression
  - Reports one-touch and two-touch gestures
  - Down-scaling and clipping support to match LCD resolution
  - Ultra-fast start-up and calibration for best user experience
  - Supports axis flipping and axis switch-over for portrait and landscape modes
- Scan Speed
  - Maximum single touch 150Hz, subject to configuration



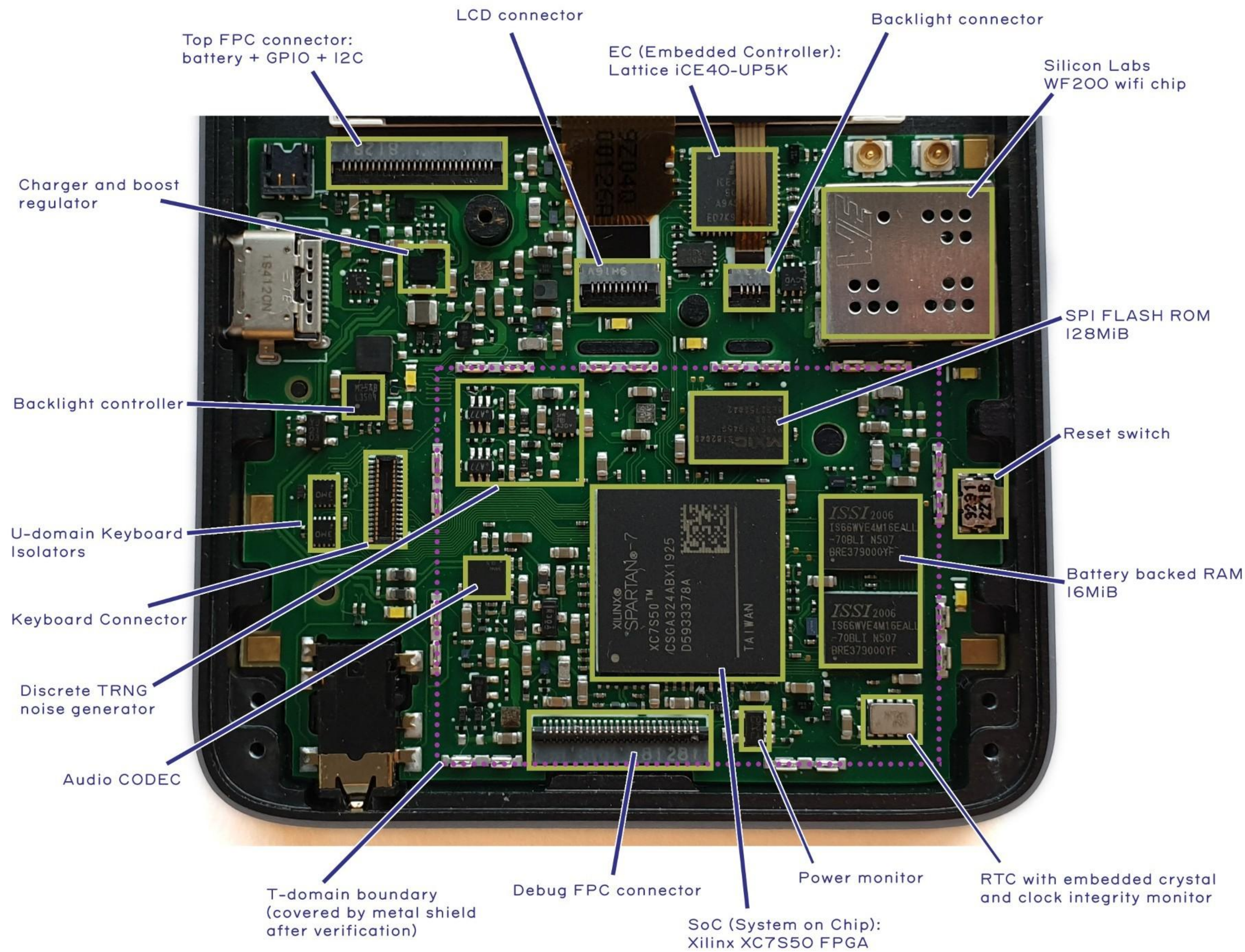
**maXTouch™  
1386-channel  
Touchscreen  
Controller**

**mXT1386**

**Firmware 1.x**







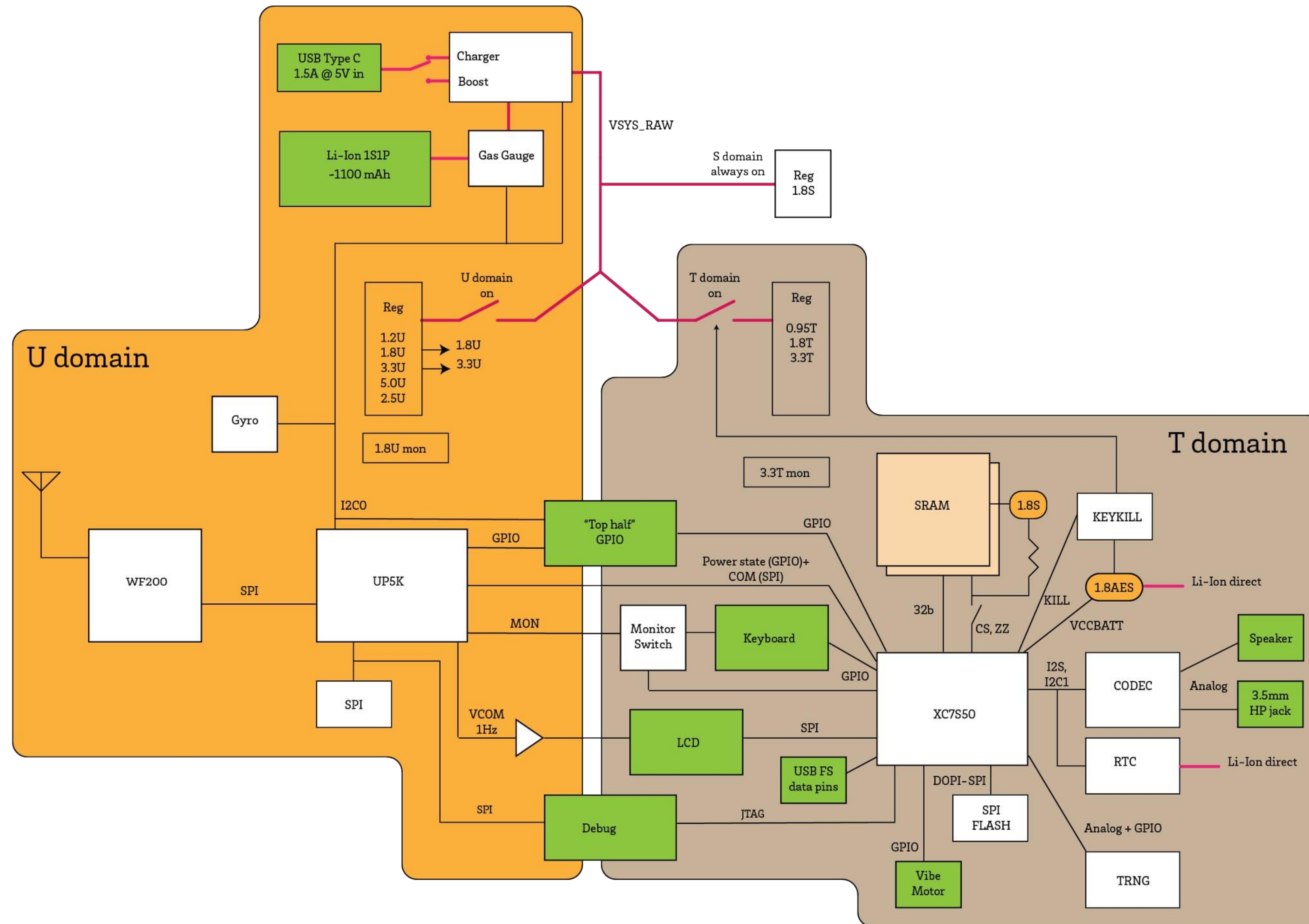
PRECURSOR



PRE-PRODUCTION  
MAINBOARD DIAGRAM  
SEP 2020



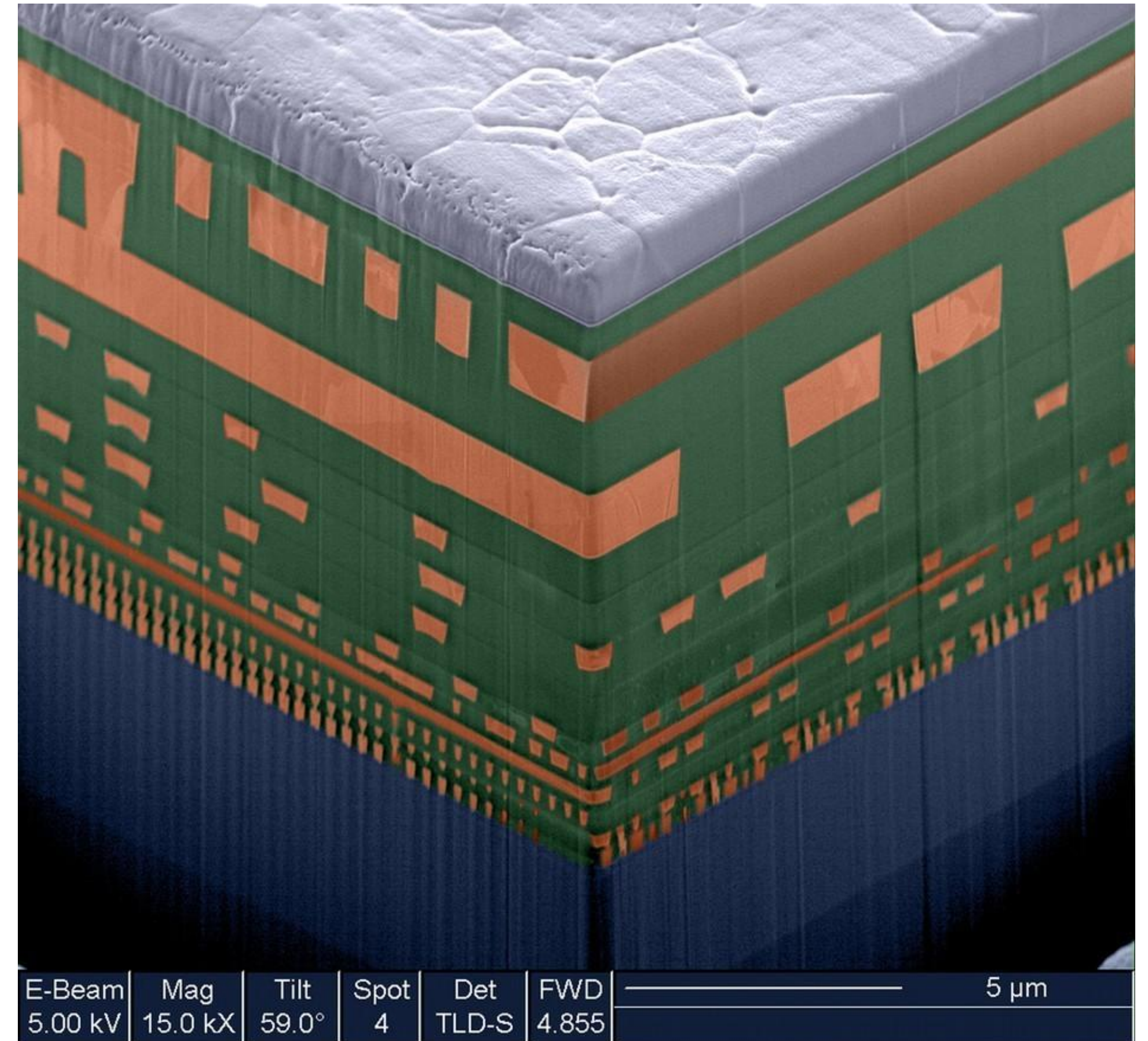
# The PCB: Designed Along Attack Surfaces





# The Hardest Problem: Evidence-Based Trust and the CPU (or SoC)

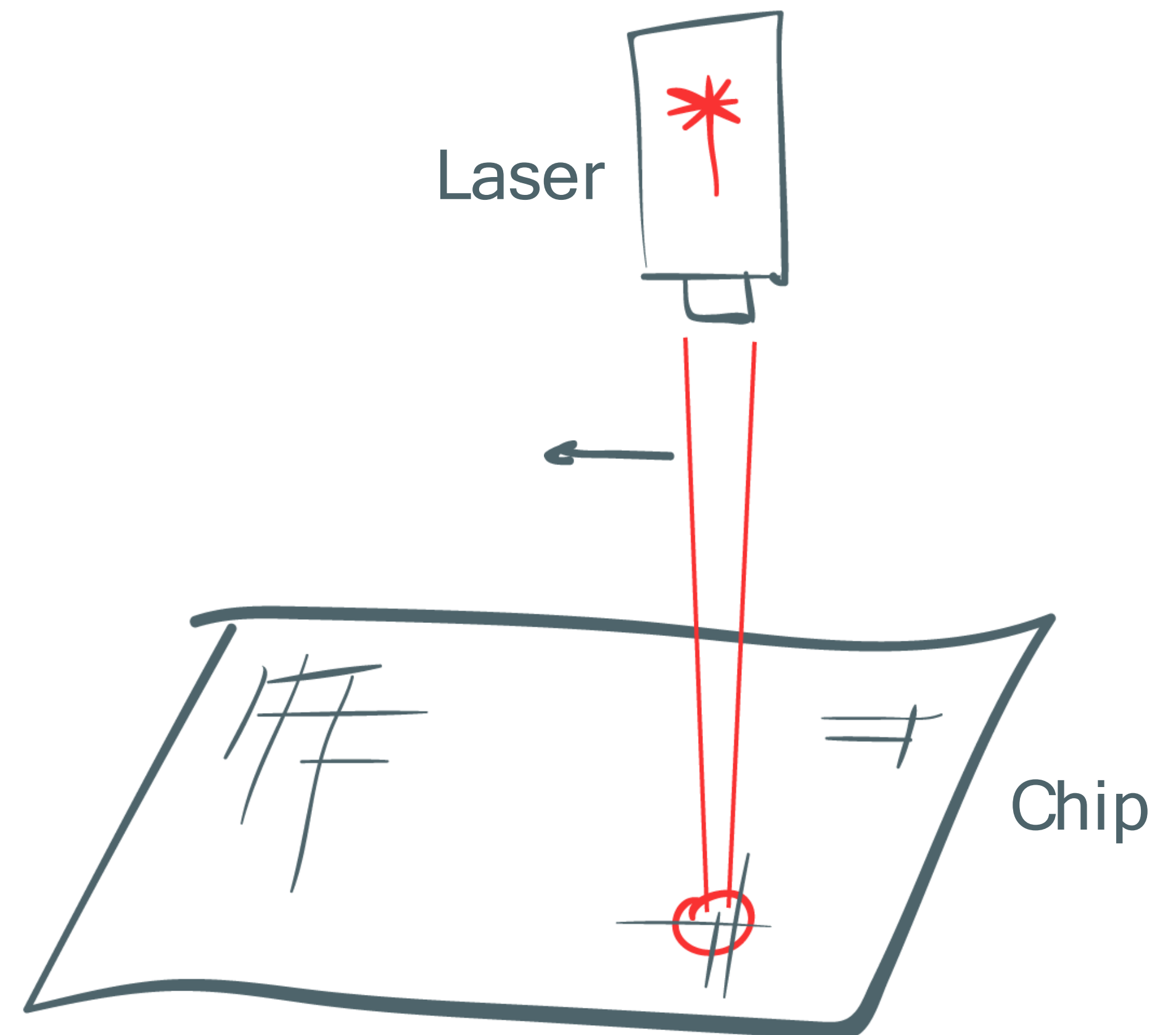
- Silicon inspection is typically destructive and hard
- Difficult to check **and** use a specific chip



[https:// www-03.ibm.com/press/us/en/photo/19014.wss](https://www-03.ibm.com/press/us/en/photo/19014.wss)

# Non-Destructive Silicon Verification???

- Proposal: use optical fault induction
  - Pros:
    - Non-destructive
    - Optical methods are relatively cheap
  - Cons:
    - Lower bound on trojan circuit complexity
      - RTL-level design methods can make small trojans difficult
    - Probably requires chip thinning for effective back-side illumination
      - Top metal scatters light too much
- **Years to develop**



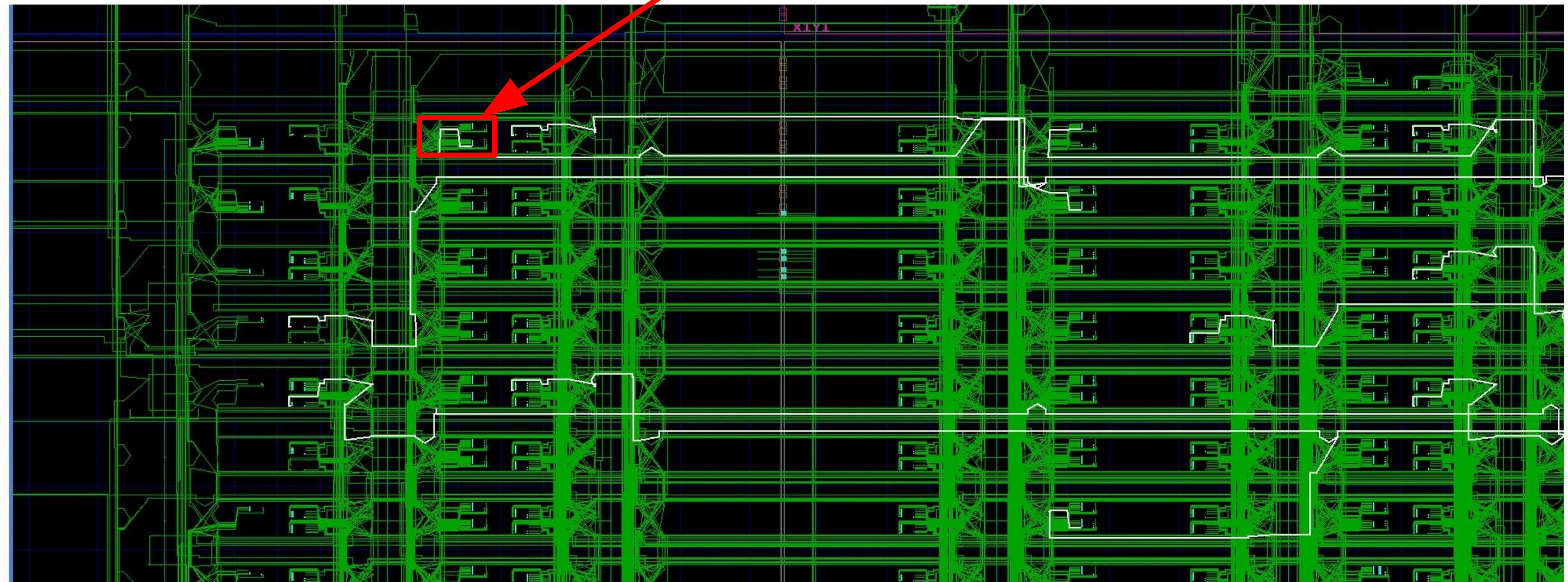
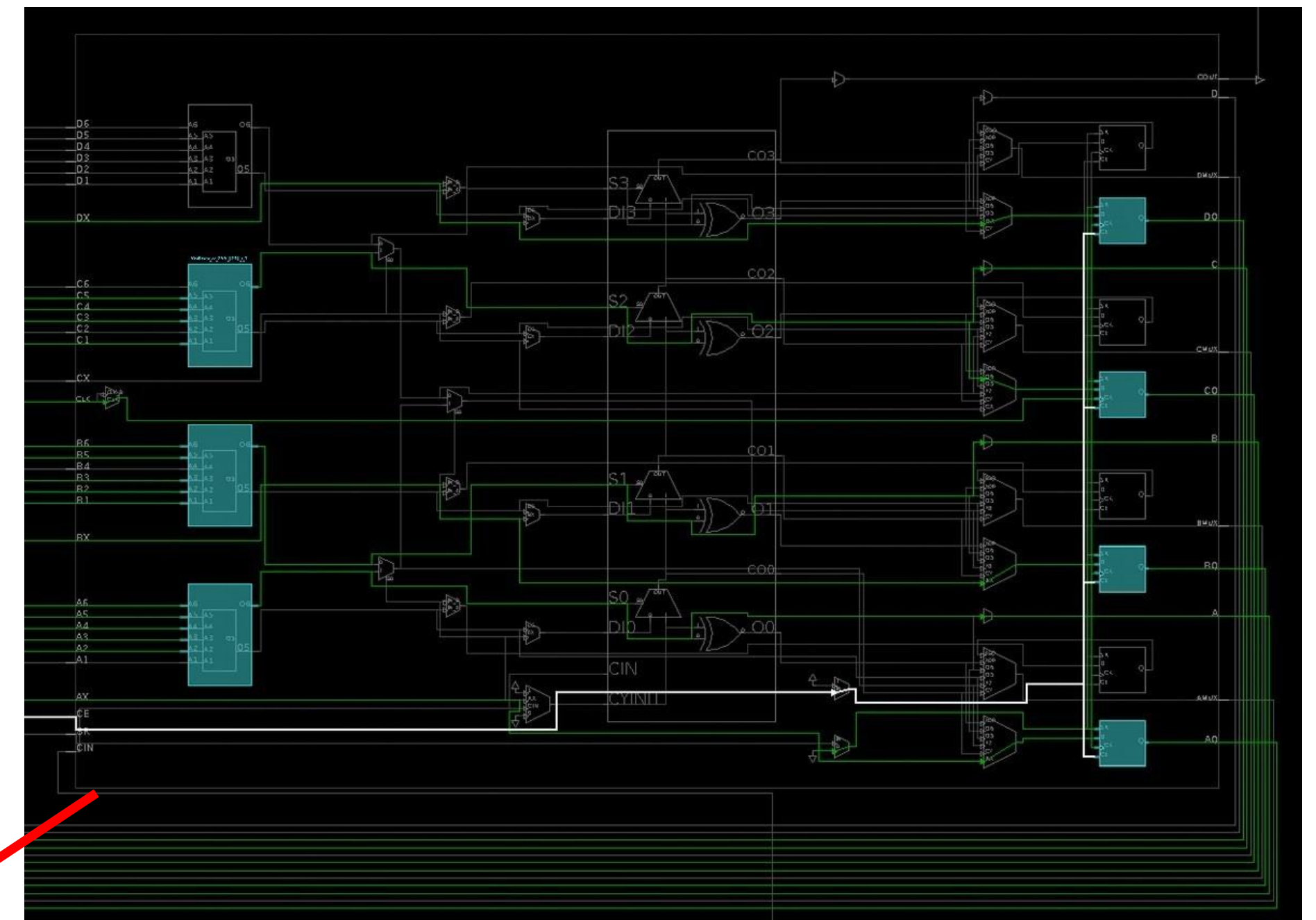
Laser spot size  $\gg$  single transistor

Use sub- $\lambda$  scan overlap + BIST syndrome readout to correlate with expected silicon pattern



# A Solution: The FPGA

- FPGAs are "Field Programmable Gate Arrays"
  - Consist of large arrays of logic + wires that are **user-configured** to implement hardware designs

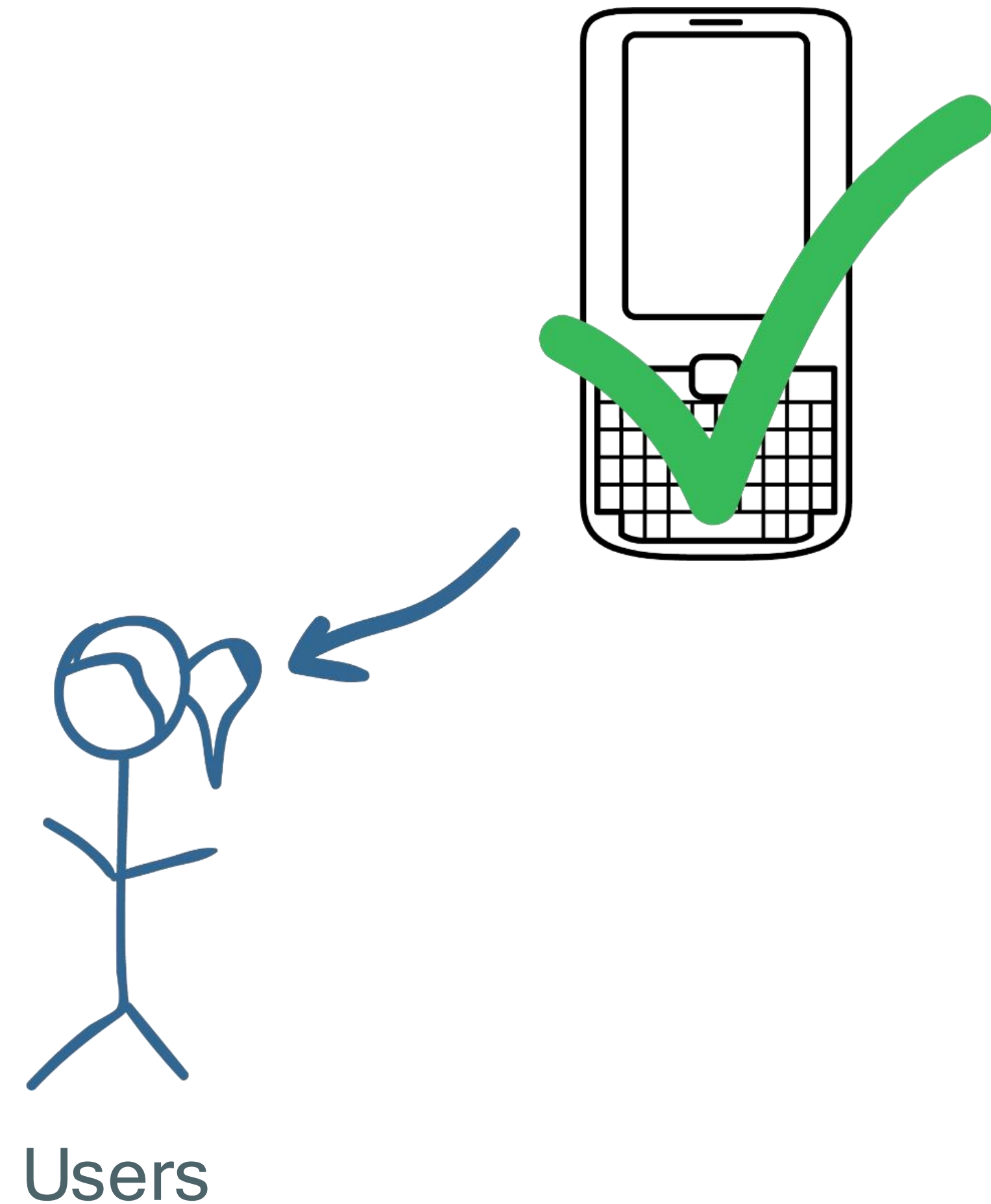


```
>  CsrPlugin_hadException_reg_0 (1)
>  CsrPlugin_hadException_reg_1 (1)
>  CsrPlugin_hadException_reg_3 (1)
>  CsrPlugin_hadException_reg_4 (1)
>  CsrPlugin_scause_exceptionCode_reg[3] (3)
>  CsrPlugin_sepc_reg[31] (32)
>  CsrPlugin_stval_reg[31] (32)
>  D (1)
>  data4 (1)
>  dataCache_1_io_cpu_writeBack_data (18)
>  dataCache_1_io_mem_cmd_payload_address (29)
>  dataCache_1_io_mem_cmd_s2mPipe_payload_length (3)
>  dataWriteCmd_payload_address (3)
>  DBusCachedPlugin_mmuBus_rsp_physicalAddress (20)
>  DebugPlugin_busReadDataReg_reg[31] (32)
>  decode_to_execute_INSTRUCTION_reg[12]_0 (4)
>  decode_to_execute_INSTRUCTION_reg[20] (1)
>  decode_to_execute_INSTRUCTION_reg[20]_0 (1)
>  decode_to_execute_INSTRUCTION_reg[22] (2)
>  decode_to_execute_INSTRUCTION_reg[22]_0 (1)
>  decode_to_execute_INSTRUCTION_reg[26]_2 (1)
>  decode_to_execute_INSTRUCTION_reg[26]_3 (1)
>  decode to execute INSTRUCTION reg[26]_3[0]
```



# FPGA's Biggest Potential Advantage: Moves Point-of-Check Towards the End User

- One can imagine a bitstream checker
  - Correlate design-to bitstream
- Vision: a "one-click" tool to verify the FPGA bitstream!
  - Point of check = Point of use



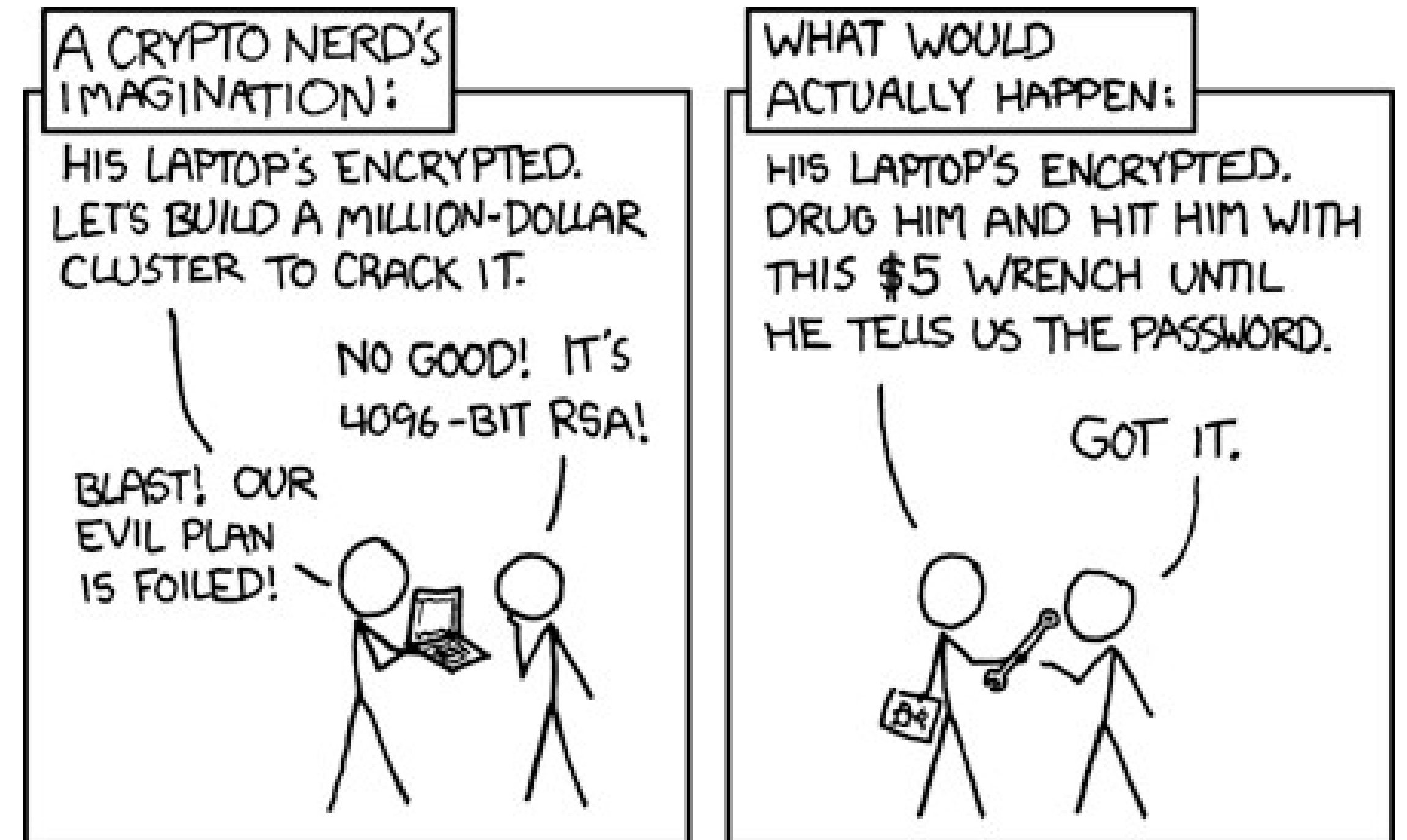
“From Boot to Root in One Hour”

<https://www.bunniestudios.com/blog/?p=6336>



# What About Direct Attacks Against Users?

- Strong security makes humans the weakest link
  - Lawful (and unlawful) coercion of secrets through search, seizure, subpoena
- Philosophical debate:
  - Should security prioritize the user's safety, or the secret's safety?

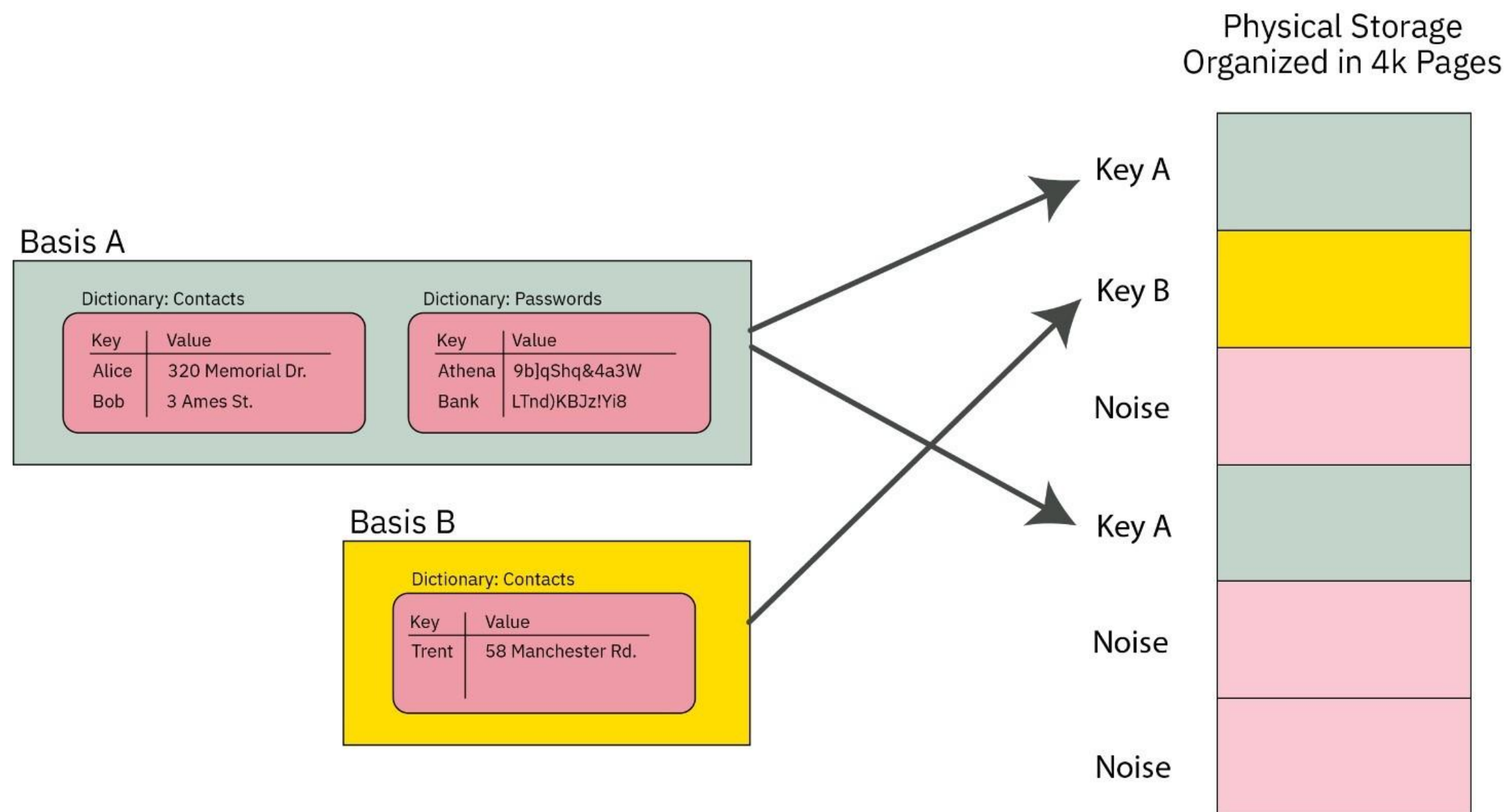


# Effective Plausible Deniability

- Requirement: An omniscient adversary cannot prove or disprove that a secret exists
  - With a full forensic image of a device:
    - Encrypted data is indifferentiable from empty space (free space wipe)
    - No metadata leakage (veracrypt, truecrypt in certain modes)
      - No mysterious partitions
      - No "missing" free space on device
    - No application leaks of pointers to encrypted data (PDDB, [1])
      - No password-specific salts, usernames
      - No dangling file references
      - No record in browser history, application history

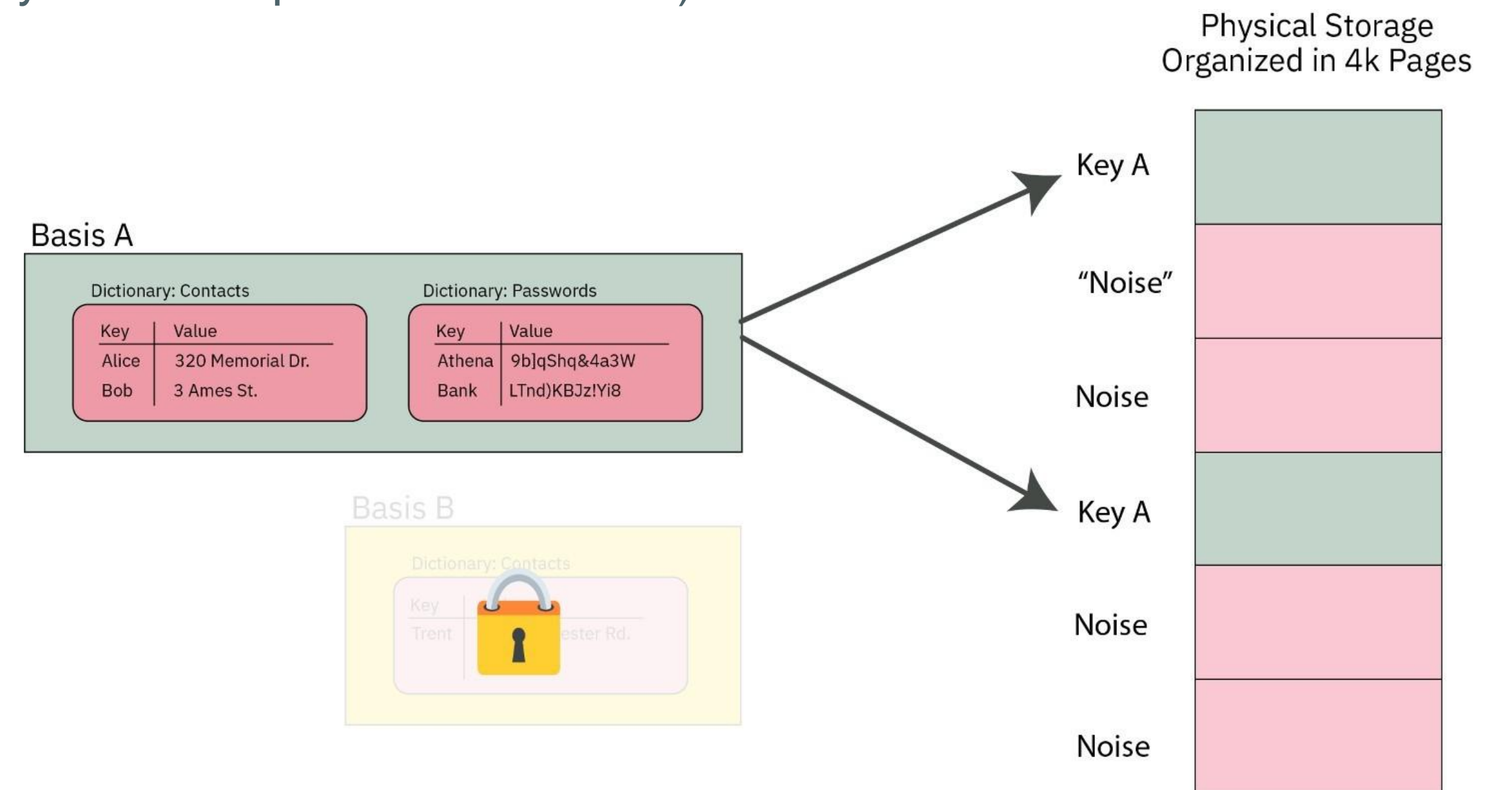


# Mitigating Forensic Disclosure



Both Basis A and Basis B Unlocked

Cipher Requirement: IND\$-CPA [1]  
("indistinguishable from uniform randomness by a chosen-plaintext attacker")



Only Basis A Unlocked

[1] <https://web.cs.ucdavis.edu/~rogaway/papers/ad.pdf>

# PDDDB Is Not a Panacea

- Deniability is fundamentally a **social tool**
  - Not all people can execute deniability to the same proficiency
  - Deniability is **optional**; it is *not appropriate for all situations*
  - However, **no** users can successfully deny anything without the option of strong plausible deniability
- PDDDB is just one tool of many that are needed to help navigate upcoming legal challenges to privacy and security

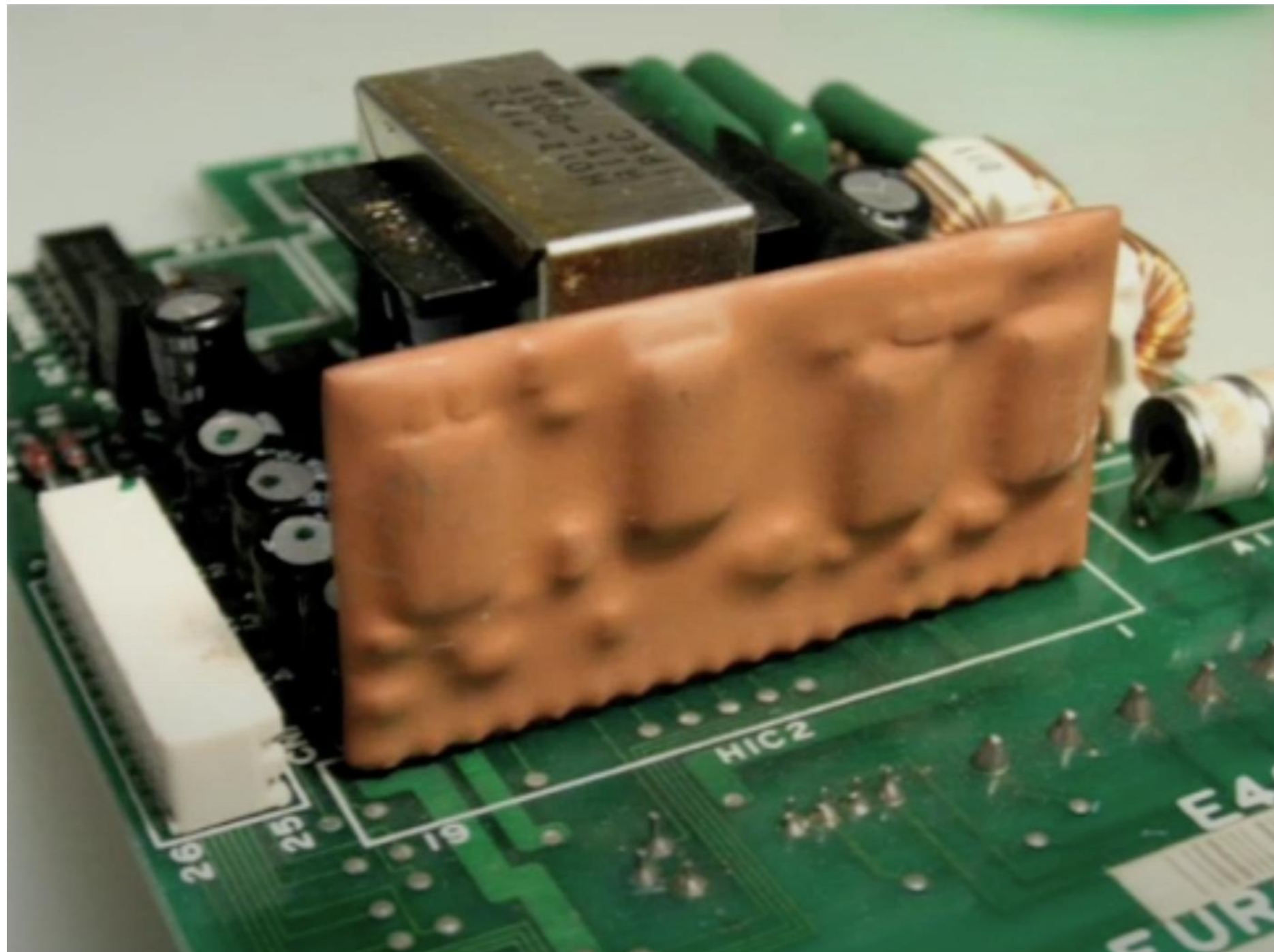


# Tamper Evident Devices





# Tamper Evident Devices





# Tamper Evident Features

- Durable, but weak
- One-way lock mechanism
- Unique identifiers
- Sensitive to:
  - Physical stress
  - Temperature
  - Chemicals
  - Anything other than examination / tug test.